alcifra

# Benutzerhandbuch

Ein souveräner Arbeitsplatz
— die Web-Workbench und der Desktop-Client

erstellt am 2026-11-12
© 2026
Hebel Consulting GmbH
Schweighofplatz 7
6010 Kriens (LU)
Switzerland
support@alcifra.com

# Inhaltsverzeichnis


1 Einführung ..... 1
2 Erste Schritte ..... 3
3 Dokumente durchsuchen und ansehen ..... 4
4 Dokumente hinzufügen und versionieren ..... 6
5 Organisieren ..... 12
6 Aus dem Dateimanager arbeiten (WebDAV) ..... 13
7 Kontakte, Kalender und Ihre Aufgaben ..... 17
8 Ihr eigenes Gerät ..... 38
9 Metadaten & Klassifizierung ..... 41
10 Suche ..... 42
11 Zusammenarbeit ..... 43
12 Teilen ausserhalb von Alcifra ..... 46
13 Workflow & Schriftgutverwaltung ..... 51
14 Administration & Konto ..... 52
15 Anhang — eine Smartcard oder ein Token vorbereiten ..... 59
16 Anhang — Glossar & Links ..... 73
17 Anhang: das Protokoll des Desktop-Clients ..... 74
18 Anhang — wer was tut ..... 75
19 Anhang — wie Alcifra aufgebaut ist ..... 78
20 Anhang — Sicherheitslage ..... 81
21 Stichwortverzeichnis ..... 86

# 1 Einführung

Alcifra ist eine neue Art von Arbeitsplatz, **souverän von Grund auf**: Es vereint **Dokumentenmanagement**, Verschlüsselung auf den eigenen Schlüssel jeder Person und offene Protokolle, sodass eine Organisation ihre Dokumente, ihre Schlüssel und die freie Wahl ihrer Geräte behält. Es ist zugleich ein Vorzeigebeispiel dafür, wie ein erfahrener, KI-gestützt arbeitender Softwareentwickler in relativ kurzer Zeit ein komplexes System auf Unternehmensniveau erstellen kann — jede Funktion in diesem Handbuch ist tatsächlich implementiert und tatsächlich getestet.

Sie erreichen dasselbe Archiv über **zwei Clients**, die einander Funktion für Funktion entsprechen:

- die **Web-Workbench** — eine Browser-Anwendung, ohne Installation;
- den **Desktop-Client** — eine native Anwendung für Windows / macOS / Linux, die ein Dokument zusätzlich in seinem eigentlichen Desktop-Programm öffnen und Dokumente in den Dateimanager des Betriebssystems ziehen und von dort hereinziehen kann.

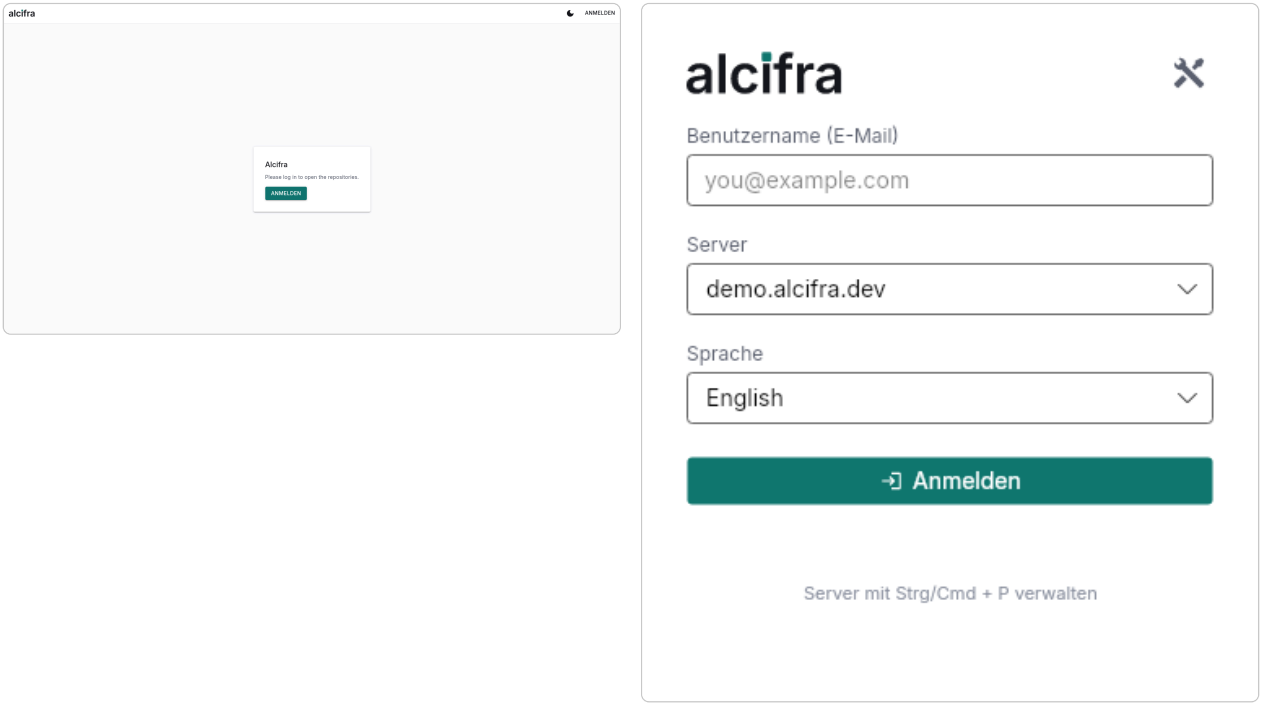



Abbildung 1: Die beiden Clients: die Web-Anmeldung (links) und das Anmeldefenster des Desktop-Clients (rechts).

## 1.1 Grundbegriffe

**Archiv** — eine Ablage auf oberster Ebene; es ist schlicht ein Ordner ohne übergeordneten Ordner. **Ordner** / **Dokument** — der Baum innerhalb eines Archivs. **Version** — jede Änderung an der Datei eines Dokuments wird als neue Version aufbewahrt; nichts wird überschrieben. **Maske (Dokumenttyp)** — eine Vorlage aus **Indexfeldern** (Metadaten), die einem Dokument zugeordnet ist. **ACL** — eine Zugriffssteuerungsliste je Dokument mit **Rechten** (sehen, lesen, bearbeiten, …), die Benutzern und Gruppen erteilt werden.

# 2 Erste Schritte

**Anmelden.** Öffnen Sie den Web-Client und wählen Sie **Anmelden**, oder starten Sie den Desktop-Client und verwenden Sie dessen Anmeldefenster; geben Sie Ihre E-Mail-Adresse und Ihr Passwort ein. Ihre Organisation kann zusätzlich einen zweiten Faktor verlangen (einen Einmalcode oder einen Passkey). Sie können die **Sprache** der Oberfläche (Englisch, Deutsch, Italienisch, Spanisch) wählen und jederzeit zwischen **heller** und **dunkler** Darstellung wechseln.

**Wenn die Anmeldung plötzlich alles ablehnt**, haben Sie sich höchstwahrscheinlich mehrmals hintereinander vertippt. Wiederholte Fehlversuche werden für kurze Zeit abgewiesen — anfangs etwa eine Minute, länger, wenn weitere folgen — und die Wartezeit läuft von selbst ab; Sie müssen also niemanden anrufen und nichts zurücksetzen. Ein Passkey funktioniert die ganze Zeit weiter; wenn Sie einen haben, ist das der schnellste Weg zurück.

**Die Workbench.** Nach der Anmeldung landen Sie in der Workbench **Archive**, die so aufgebaut ist: der **Baum** der Archive und Ordner, die **Inhaltsliste** des ausgewählten Ordners, der **Detailbereich** (Indexdaten) über der **Vorschau** und — am unteren Rand — die **Registerleiste**, die zwischen Archive, Eingangskorb, Suche, Aufgaben und den übrigen Registern wechselt.

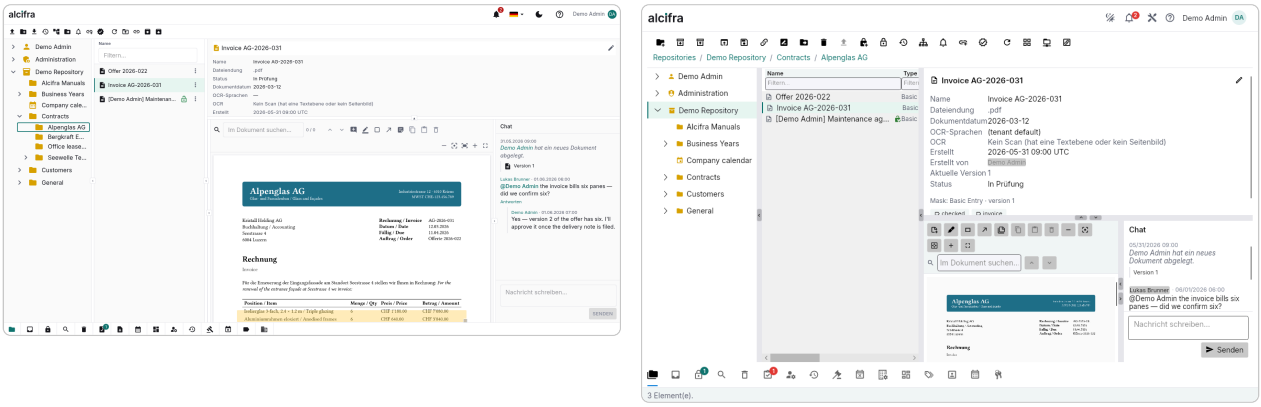



Abbildung 2: Die Workbench im Web-Client (links) und im Desktop-Client (rechts): Baum · Inhalt · Details · Vorschau, mit der Registerleiste am unteren Rand.

# 3 Dokumente durchsuchen und ansehen

Klappen Sie den **Baum** bis zu einem Ordner auf, und seine Dokumente erscheinen in der **Inhaltsliste**, die Sie nach jeder Spalte sortieren können. Wenn Sie ein Dokument auswählen, zeigt der Detailbereich seine **Indexdaten**, und darunter wird eine **Vorschau** dargestellt — für PDFs, Bilder und konvertierte Office-, E-Mail- und Markdown-Dokumente gleichermassen. Treffer der Volltextsuche werden direkt in der Vorschau hervorgehoben, und Sie können jedes Wort anklicken, um es zu kopieren — **Umschalt-Klick** hängt an, statt zu ersetzen, sodass einige Klicks eine Wortfolge sammeln (eine Rechnungsnummer, dann ihr Datum), ohne die Tastatur zu berühren. So füllen Sie Indexfelder im Register **Eingangskorb** am schnellsten aus: Klicken Sie die Werte in der Vorschau des Scans an und fügen Sie sie ins Feld ein.

Ein **Kontakt** oder ein **Termin** erscheint stattdessen als eigene Karte: dasselbe Formular, mit dem die Register **Kontakte** und **Kalender** ihn bearbeiten, schreibgeschützt. Der Stift über der Karte öffnet dieses Formular zum Ändern. Nur was das Archiv als Kontakt oder Termin abgelegt hat, erhält eine Karte; jede andere .vcf- oder .ics-Datei behält ihre gewohnte Vorschau. Die Karte füllt die Vorschau. Unten zeigt ein zugeklappter Abschnitt **vCard-Quelltext** oder **iCalendar-Quelltext** den Eintrag genau so, wie er gespeichert ist, denselben Text wie **Erweitert: der gespeicherte Eintrag** im Bearbeiten-Fenster, ein langes Foto gekürzt; **Kopieren** kopiert ihn vollständig.

Eine **E-Mail** erscheint ebenso: wer sie wann an wen gesendet hat, ihre Anhänge mit **Öffnen** und **Speichern** und ihr Text. Der Web-Client zeigt die E-Mail so formatiert, wie sie geschrieben wurde, ohne das, was ausgeführt werden oder nach Hause melden könnte; der Desktop-Client zeigt ihren Text. Im Desktop-Client können Sie das Dokument ausserdem in seiner nativen Anwendung **öffnen** — über das Kontextmenü der Zeile, das Menüband, einen Doppelklick oder das Tastenkürzel **⌘O** (**Ctrl+O** unter Windows und Linux). Dasselbe Kürzel öffnet im Register **Eingangskorb** den ausgewählten Eintrag.

Die Werkzeugleiste der Vorschau enthält die Bedienelemente zum **Zoomen**. Ein Dokument öffnet sich auf die Breite des Bereichs eingepasst; *Ganze Seite einpassen* verkleinert es, bis die ganze Seite auf einmal sichtbar ist — nützlich, wenn der Bereich breiter als hoch ist und das Einpassen auf die Breite das untere Ende der Seite aus dem Blickfeld schiebt. Zoomen Sie danach heraus, geht es schrittweise bis zur ganzen Seite zurück und hält dort an. Ctrl+Scrollen (⌘+Scrollen auf dem Mac) zoomt ebenfalls.

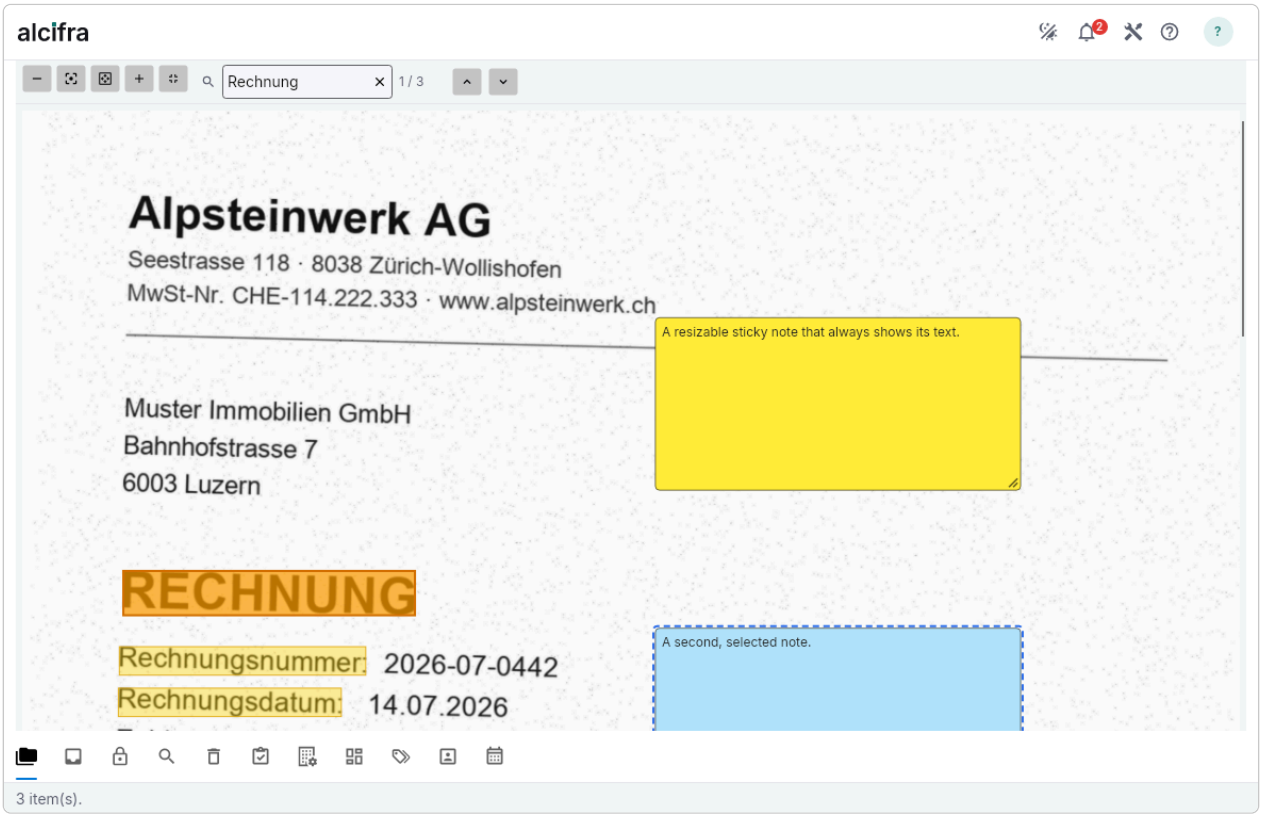



Abbildung 3: Die Vorschau mit hervorgehobenen Suchtreffern auf der Seite — klicken Sie ein Wort an, um es zu kopieren (Umschalt-Klick zum Anhängen), oder springen Sie von Treffer zu Treffer.

# 4 Dokumente hinzufügen und versionieren

## 4.1 Wie Dokumente hineinkommen

Es gibt mehr als einen Weg hinein, und welcher der richtige ist, hängt davon ab, ob das Dokument fertig ist, ob es zu etwas bereits Abgelegtem gehört und wie viele Sie haben. Alle enden am selben Ort.

| Weg | Verwenden Sie ihn, wenn |
|---|---|
| **Hochladen** im Menüband | Sie den Ordner, in den es gehört, bereits vor sich haben. Wählt Dateien aus und legt sie direkt im geöffneten Ordner ab. |
| **Auf einen Ordner ziehen** — eine Zeile in der Liste oder einen Knoten im Baum | Sie das Ziel sehen können. Das Dokument wird dort abgelegt; die Ansicht wechselt zu diesem Ordner, sodass Sie es ankommen sehen. |
| **Auf eine leere Fläche ziehen** in der Inhaltsliste | Wie oben, für den Ordner, in dem Sie sich bereits befinden. |
| **Auf ein Dokument ziehen** | Die Datei eine neuere Fassung dieses Dokuments ist — sie wird als **Version** hinzugefügt, nicht als zweites Dokument, und der Verlauf bleibt erhalten. |
| **Auf Ihren eigenen Bereich ▸ Intray ziehen** | Es noch nicht ablagebereit ist oder Sie noch nicht wissen, wohin es gehört. Es wartet im Eingangskorb, bis Sie es klassifizieren und ablegen. |
| **Ein Dokument auf Ihren eigenen Bereich ▸ Intray ziehen** | Sie von einem bestehenden Dokument als **Vorlage** ausgehen möchten. Eine Kopie landet in Ihrem Eingangskorb, mit dem Dokumenttyp und den Indexdaten dieses Dokuments, sodass Sie nur ändern, was abweicht. Im Archiv entsteht nichts, bis Sie sie ablegen. |
| **Auf Ihren eigenen Bereich ▸ Check-out ziehen** | Sie ein Dokument ausgecheckt, es auf Ihrem Computer bearbeitet haben und es nun zurückbringen. Die Datei muss noch den Namen des Dokuments tragen — daran wird erkannt, zu welchem Dokument sie gehört. |
| **WebDAV** | Sie lieber im Finder, im Explorer oder in Dateien arbeiten. Binden Sie das Archiv als Laufwerk ein und kopieren Sie Dokumente hinein wie in jeden anderen Ordner. |
| **Importieren** | Sie einen ganzen Ordnerbaum auf einmal hereinholen, exportiert aus Alcifra oder anderswoher. |
| **E-Mail-Anhang** | Sie eine E-Mail abgelegt haben und einen ihrer Anhänge als eigenes Dokument möchten. |

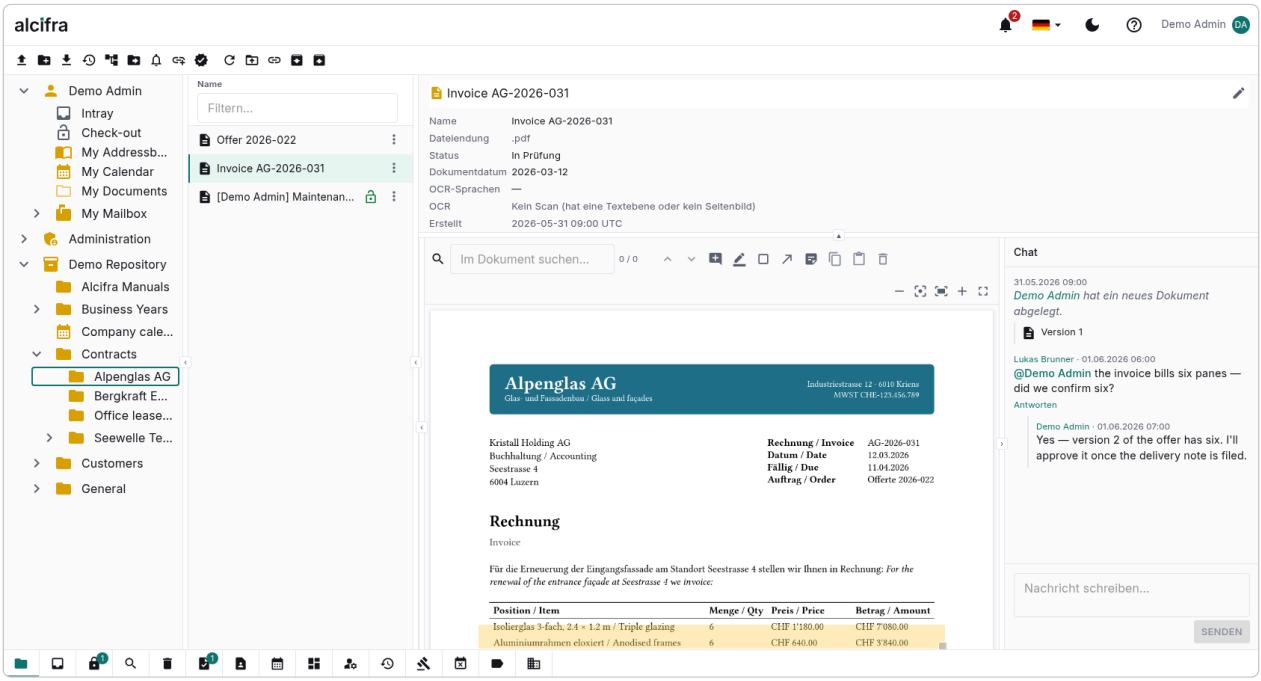



Abbildung 4: Ihr eigener Bereich, aufgeklappt — er trägt **Ihren Namen** oben im Baum: **Intray** und **Check-out** stehen über Ihren eigenen Ordnern. Legen Sie Dateien auf **Intray** ab, um sie bereitzustellen, oder legen Sie eine bearbeitete Arbeitskopie auf **Check-out** ab, um sie zurückzubringen — und ziehen Sie ein Dokument auf **Intray**, um davon ausgehend als Vorlage neu zu beginnen.

> **Zwei dieser Wege erzeugen kein Dokument.** Ein Ablegen auf **Intray** stellt einen Eintrag bereit — zum Dokument wird er erst, wenn Sie ihn ablegen. Ein Ablegen auf **Check-out** ersetzt Ihre Arbeitskopie — das Dokument erhält erst dann eine neue Version, wenn Sie es einchecken. Alles andere wird sofort abgelegt.

**Hochladen.** Ziehen Sie eine Datei direkt auf einen Ordner (die Bytes gehen direkt in den Objektspeicher — der Server leitet sie nie durch). **Der Eingangskorb** ist ein Bereitstellungsbereich: Legen Sie Scans oder Dateien dort ab, klassifizieren Sie dann jeden Eintrag (Name, Dokumenttyp, Indexdaten) und **legen** Sie ihn im Archiv **ab**.

**Was das Archiv nicht aufnimmt.** Programme und Skripte werden abgewiesen — eine `.exe`, eine `.bat`, ein Shell-Skript und alles, was sich als Programm herausstellt, gleichgültig, wie es benannt ist. Alles andere wird aufbewahrt, auch die Formate, für die ein Dokumentensystem oft zu eng ist: Zeichnungen, Datenträgerabbilder, Archivdateien, Videos. Wird der Anhang einer **E-Mail** abgewiesen, wird die Nachricht selbst trotzdem archiviert, und eine Zeile in ihrem Chatverlauf nennt den weggelassenen Anhang, damit nichts stillschweigend verloren geht.

**Wenn der Name bereits vergeben ist.** Ein Ordner kann nicht zwei Dinge gleichen Namens enthalten; legen Sie also `Invoice.pdf` dort ab, wo bereits ein `Invoice` liegt, werden Sie gefragt, was Sie gemeint haben, statt abgewiesen zu werden:

| Auswahl | Was geschieht |
|---|---|
| **Als neue Version dieses Dokuments ablegen** | Die übliche Antwort: Die Datei ist eine neuere Fassung dessen, was bereits da ist. Das Dokument behält seine Indexdaten und seinen Verlauf, und die vorherige Version bleibt verfügbar. |

| | |
|---|---|
| **Als neues Dokument mit anderem Namen ablegen** | Die beiden sind tatsächlich verschiedene Dokumente, die zufällig denselben Dateinamen tragen. Ein freier Name wird vorgeschlagen — `Invoice (2)` — und Sie können ihn ändern. |

In beiden Fällen können Sie einen **Kommentar** hinzufügen, der sagt, was diese Datei ist; er wird zum Kommentar der Version. Ein «Überschreiben» gibt es nicht: Nichts in Alcifra ersetzt Inhalte an Ort und Stelle, und die ehrliche Entsprechung ist eine neue Version.

> Gehört der Name einem **Ordner** statt einem Dokument, ist nur die zweite Auswahl möglich — ein Ordner hat keine Versionen, denen man eine hinzufügen könnte.

**Versionen.** Wenn Sie eine neue Datei zu einem bestehenden Dokument hochladen, entsteht eine neue **Version** — der Verlauf bleibt erhalten. Der Dialog **Versionen** listet jede Version auf; Sie können zwei davon vergleichen oder eine ältere mit **Als aktuell festlegen** wieder zur aktuellen machen. Wenn Sie eine Datei hochladen, die bereits existiert, warnt Alcifra Sie vor dem **Duplikat**.

Geben Sie jeder Version einen **Kommentar**, der sagt, was sich geändert hat. Er macht den Unterschied zwischen einem Verlauf, den jemand lesen kann, und einer Liste von Zeitstempeln: «Preis nach Prüfung des Rahmenvertrags korrigiert» beantwortet die Frage, die ein Leser der Liste tatsächlich hat, und das kann kein Datum.

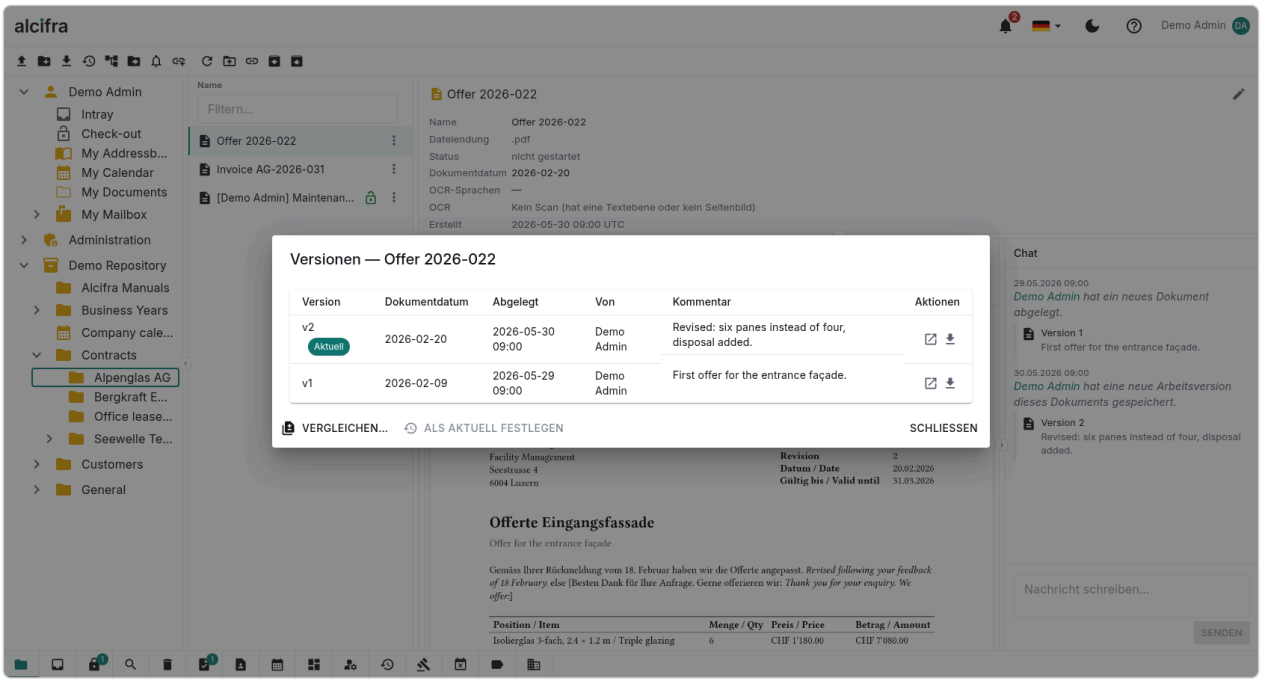



Abbildung 5: Der Dialog **Versionen**: jede Version des Dokuments mit der Angabe, wer sie wann gespeichert hat, und — dem Teil, der die Liste lesenswert macht — dem Kommentar, der beschreibt, was sich geändert hat.

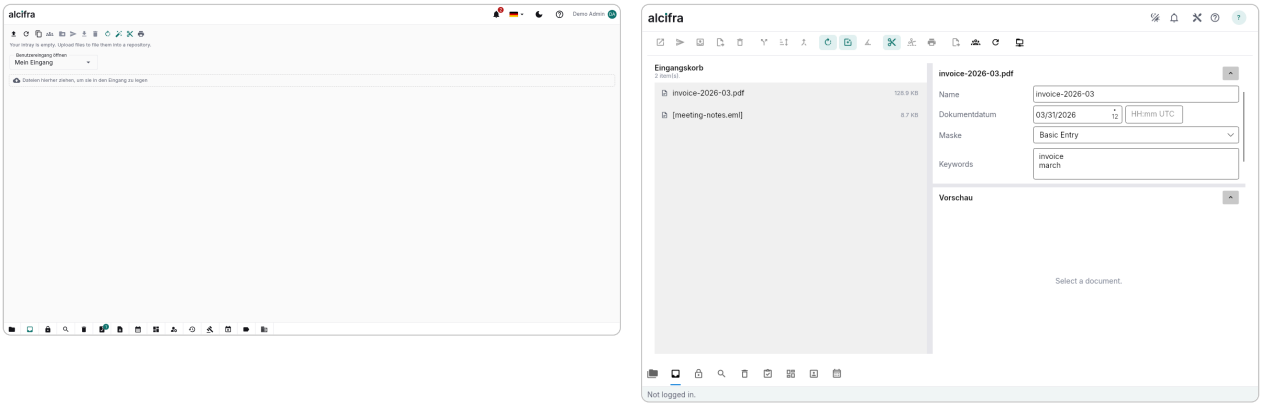



Abbildung 6: Der Eingangskorb: bereitgestellte Einträge, die darauf warten, klassifiziert und abgelegt zu werden, im Web-Client (links) und im Desktop-Client (rechts).

## 4.2 Einen Scan vor dem Ablegen aufbereiten

Ein Scan kommt selten ablagebereit an: Ein Stapel enthält mehrere Dokumente, eine Seite lief quer durch den Einzug, eine leere Rückseite kam mit. Im Eingangskorb wird all das in Ordnung gebracht — **vor** dem Ablegen, denn ein bereitgestellter Eintrag lässt sich frei umgestalten, während die Seiten eines abgelegten Dokuments Teil des Bestands sind. Jede Funktion hier arbeitet mit `.pdf`- und mehrseitigen `.tif`-Dateien; bei allen anderen werden sie schlicht nicht angeboten.

| Funktion | Was sie bewirkt |
|---|---|
| **In Seiten aufteilen** | Ein neuer Eintrag pro Seite. Das Original bleibt erhalten, sodass eine Aufteilung, die sich als falsch erweist, durch Löschen ihres Ergebnisses rückgängig gemacht wird — ein Scan kann die einzige Kopie eines Blatts Papier sein. |
| **Drehen/Sortieren** | Öffnet den unten gezeigten Seitendialog: Bringen Sie die Seiten in die richtige Reihenfolge, löschen Sie eine Seite mit dem Papierkorb auf ihrer Kachel und drehen Sie eine Seite mit den Schaltflächen ⟲ ⟳ darunter. Geschrieben wird erst mit **Reihenfolge übernehmen** — ein einziges Speichern für die ganze Anordnung, und **Abbrechen** verwirft alles. Schon ab einer einzigen Seite angeboten, denn das Drehen eines einseitigen Scans, der kopfüber eingezogen wurde, ist genau das, wofür es da ist. |
| **Einträge zusammenfügen** | Mehrere bereitgestellte Einträge werden zu einem, in der Reihenfolge, in der Sie sie gewählt haben. Die Quellen bleiben erhalten. |
| **An Trennblättern schneiden** | Schneidet einen Stapel an den gedruckten Trennblättern zwischen den Dokumenten in einen Eintrag pro Dokument (siehe unten). |

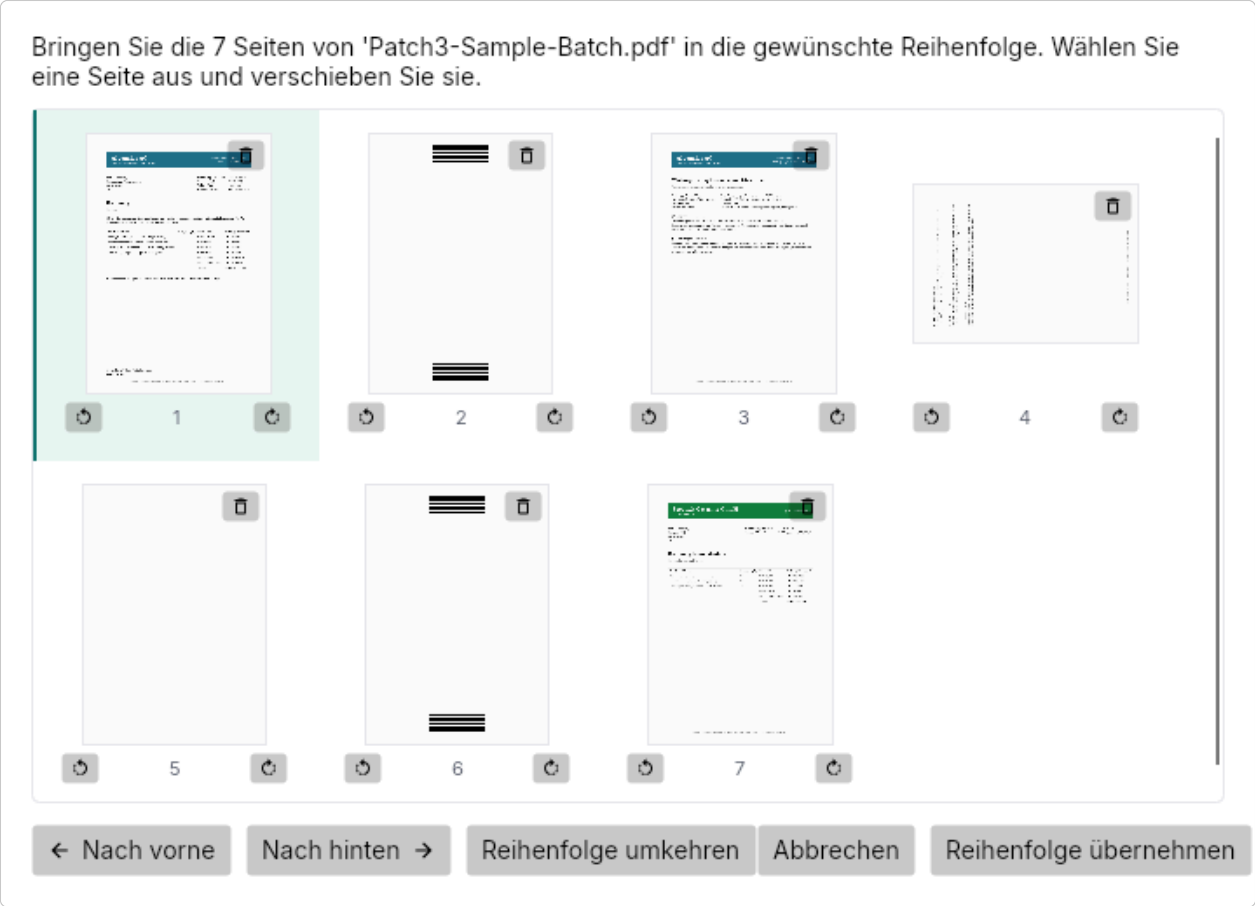



Abbildung 7: Der Dialog **Drehen/Sortieren** mit dem Beispielstapel: Seite 4 lief kopfüber durch den Scanner und wurde bisher um eine Vierteldrehung gedreht — ein weiterer Druck auf ihre Schaltfläche ⟳ stellt sie aufrecht. Der Papierkorb auf jeder Kachel löscht diese Seite; gespeichert wird erst mit **Reihenfolge übernehmen**.

**Drehen beschädigt kein PDF.** Beim Drehen einer PDF-Seite wird nur die neue Ausrichtung vermerkt — der echte, durchsuchbare Text der Seite bleibt unberührt. Eine `.tif`-Seite kennt so etwas nicht und wird beim Drehen neu kodiert, derselbe Kompromiss, den auch ihr Geraderichten eingeht.

**Trennblätter.** Für einen Stapel Papierdokumente drucken Sie das **Trennblatt** (die Druckerschaltfläche in der Werkzeugleiste des Eingangskorbs), legen eines zwischen je zwei Dokumente und lassen den ganzen Stapel in einem Durchgang durch den Scanner laufen. **An Trennblättern schneiden** erzeugt dann einen Eintrag pro Dokument und verwirft die Trennblätter selbst. Beispieldateien zum Ausprobieren — ein Stapel, wie ihn der Scanner liefern würde, und das Trennblatt — stellt Ihre eigene Installation unter `/download/samples/` bereit.

**Die automatischen Schalter.** Drei dauerhafte Schalter in der Werkzeugleiste des Eingangskorbs wirken auf jeden **eintreffenden** Upload — auch auf Dateien, die im Ordner Intray des eingebundenen Netzlaufwerks gespeichert werden:

| Schalter | Was er mit einem eintreffenden Scan macht |
|---|---|
| **Automatisch drehen** | Dreht Seiten, die kopfüber oder quer angekommen sind, richtig herum. Funktioniert für `.pdf` und `.tif`. |
| **Scans automatisch gerade richten** | Korrigiert die leichte Schräglage eines schiefen Scans — für `.tif` und für ein PDF, das selbst ein reiner Scan ist |

| | |
|---|---|
| | (Bildseiten, kein echter Text). Ein digital erzeugtes PDF bleibt unverändert: Geraderichten rendert die Seiten neu, und das würde seinen echten Text durch eine erkannte Annäherung ersetzen. |
| **Stapel automatisch an Trennblättern schneiden** | Wendet den Trennblatt-Schnitt auf jeden eintreffenden Stapel an, sodass ein Scanner, der direkt in den Eingangskorb liefert, überhaupt keinen Handgriff mehr braucht. |

> **Digital signierte Dokumente werden nie angetastet.** Jede Seitenfunktion würde die Signatur brechen, deshalb wird bei einem signierten Eintrag keine angeboten, und die automatischen Schritte überspringen ihn — die Weigerung ist die Funktion.

**Schon abgelegt? Drehen/Sortieren** gibt es auch im Register **Ausgecheckt**. Dort bearbeitet es die **Arbeitskopie** eines Dokuments, das Sie ausgecheckt haben — die archivierte Version bleibt genau so, wie sie war, und Ihre Neuanordnung wird erst zur neuen Version, wenn Sie **Einchecken** drücken (oder mit **Verwerfen** weggeworfen, wie jede andere Änderung an einer Arbeitskopie). Aufteilen und Zusammenfügen bleiben im Eingangskorb: Sie machen aus einem Eintrag mehrere Dokumente, und das ist Ablagearbeit.

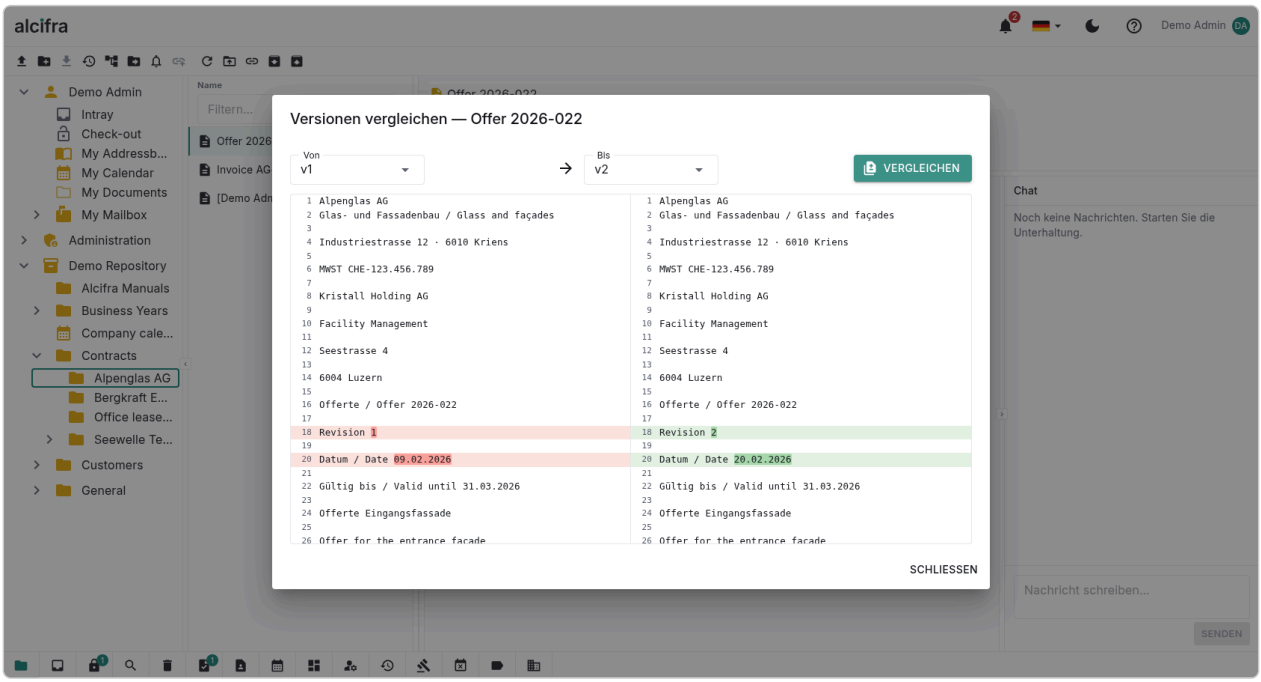



Abbildung 8: **Versionen vergleichen**: zwei Fassungen eines Dokuments nebeneinander — alt links, neu rechts, geänderte Zeilen aufeinander ausgerichtet und die geänderten Wörter darin hervorgehoben. Funktioniert für jedes Paar, dessen Inhalt Text ergibt, Notizen und E-Mails eingeschlossen.

# 5 Organisieren

Legen Sie **Ordner** an und **verschieben** Sie Dokumente per Drag-and-drop zwischen ihnen. Ein **Verweis** (Verknüpfung) lässt ein Dokument an mehreren Orten erscheinen, ohne es zu kopieren. **Schlagwörter** kennzeichnen Dokumente zur schnellen Gruppierung — Ihr Mandant kann einen gepflegten Schlagwortkatalog mit Farben führen. **Vertraulichkeitsstufen** geben an, wie vertraulich ein Dokument ist. Jeder Benutzer hat ausserdem ein **persönliches Archiv** für private Dokumente.

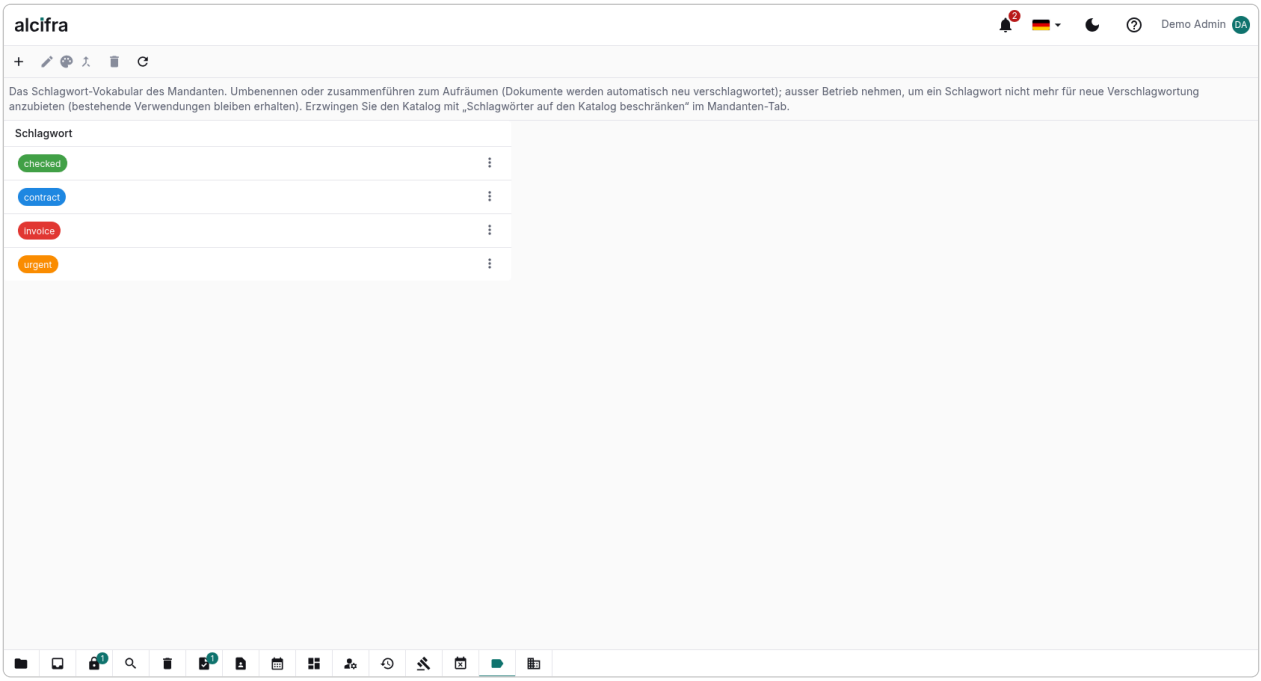



Abbildung 9: Der Schlagwortkatalog: gepflegte, farbcodierte Schlagwörter, die ein Administrator für den ganzen Mandanten verwaltet.

# 6 Aus dem Dateimanager arbeiten (WebDAV)

Das ganze Archiv ist über **WebDAV** als Netzlaufwerk erreichbar — nicht nur Ihr persönlicher Bereich, sondern auch die gemeinsamen Archive, auf die Sie zugreifen dürfen, wobei Ihre Rechte bei jeder Operation durchgesetzt werden. Das eingebundene Laufwerk heisst **webdav** und bildet den Baum der Archive exakt ab: Ihren persönlichen Bereich, dann die Archive, die Sie sehen können, und nichts sonst.

Die Schaltfläche **WebDAV** tut jeweils den nächsten sinnvollen Schritt statt immer dasselbe, und ihr Tooltip sagt, welchen. Im **Desktop-Client**: Erreicht noch keines Ihrer Geräte Dateien, meldet sie **Dieser Computer** an (siehe Abschnitt 8.2), zeigt sein Passwort einmal und bindet dann ein; sonst bindet sie das Laufwerk ein und öffnet es (unter Windows als dauerhafter Laufwerksbuchstabe, S: oder der nächste freie); und ist das Laufwerk bereits eingebunden, geht sie direkt dorthin. «Zeig mir meine Dokumente im Finder» ist also nach der Einrichtung ein einziger Klick.

**Sie öffnet dort, wo Sie gerade sind.** Es gibt eine Schaltfläche pro Register, und jede öffnet **ihren eigenen** Ordner im Laufwerk statt der obersten Ebene des Archivs:

| Wo Sie sie drücken | Was sich öffnet |
|---|---|
| Menüband im Register **Archive** | Der im Baum ausgewählte Ordner — das Laufwerk bildet den Baum exakt ab, also sind «wo ich bin» und «welcher Ordner auf dem Laufwerk» derselbe Ort. Ist nichts ausgewählt, öffnet sich das ganze Archiv. |
| Register **Eingangskorb**, unten links | Ihr Ordner **Intray**. |
| Register **Ausgecheckt**, unten links | Ihr Ordner **Check-out**, in dem die Arbeitskopien liegen. |

> **Wenn Sie sich mit mehr als einem Alcifra verbinden** — etwa einem lokalen und einem gehosteten —, kann Ihr Computer nicht beiden Laufwerken denselben Namen geben, also heisst das zweite etwa **Alcifra–1**. Die Schaltfläche öffnet immer das Laufwerk des Servers, bei dem Sie angemeldet sind, welchen Namen es auch erhalten hat.

Das Laufwerk meldet sich mit Ihrer E-Mail-Adresse und einem **Gerätepasswort** aus **Geräte…** an (siehe Abschnitt 8.2), nie mit Ihrem Anmeldepasswort. Die Mount-URL endet auf `/webdav`, daher nennt Ihr Dateimanager das Laufwerk «webdav»; unter Windows können Sie es wie jedes Netzlaufwerk umbenennen.

Der **Web-Client** kann kein Laufwerk einbinden: Ein Browser darf das nicht. Statt Sie mit einer URL allein zu lassen, ohne zu wissen, was damit anzufangen ist, zeigt sein Dialog **Geräte** die Schritte zum Einbinden für das Betriebssystem, das Sie verwenden — im Finder *Gehe zu* ▸ *Mit Server verbinden* unter macOS, **Netzlaufwerk verbinden** unter Windows, eine `davs://`-Adresse unter Linux — neben den Werten, die Sie dort einfügen.

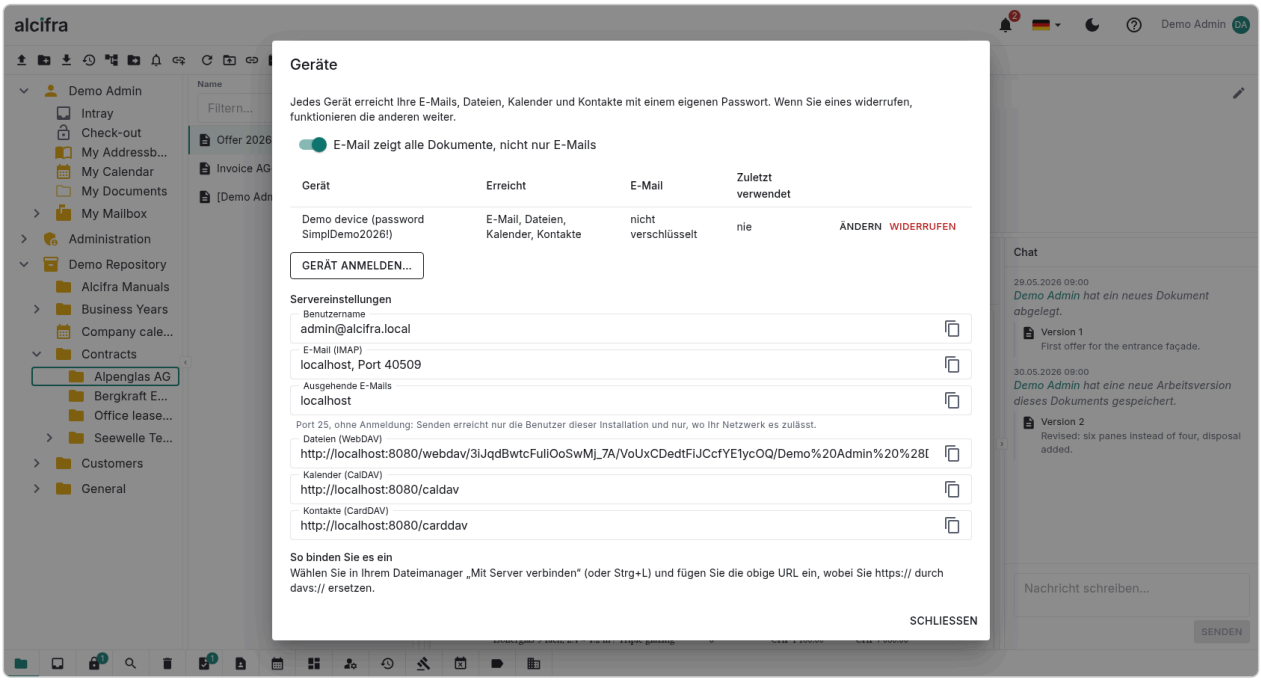



Abbildung 10: Der Dialog **Geräte** des Web-Clients: Ihr Benutzername und jede Serveradresse, jeweils mit einer Schaltfläche zum Kopieren, und die Schritte zum Einbinden für das Betriebssystem, das Sie verwenden.

## 6.1 Ein Dokument direkt bearbeiten

Öffnen Sie ein Dokument aus dem eingebundenen Laufwerk, ändern Sie es, speichern Sie es — das ist der ganze Vorgang, und er funktioniert so, wie Sie es von jedem Netzlaufwerk erwarten.

Was dabei im Hintergrund geschieht, sollten Sie kennen, denn es verändert, was andere sehen. Einfache Editoren schreiben die Datei direkt zurück, und die Änderung wird sofort zu einer neuen Version. Eine **Office-Suite** hingegen überschreibt eine Datei nie an Ort und Stelle: Sie schreibt eine versteckte Begleitdatei, dann eine temporäre Kopie des neuen Inhalts und benennt diese Kopie schliesslich über das Original um. Alcifra erkennt diese Abfolge und macht daraus ein **Auschecken** — dasselbe, das Sie erhalten, wenn Sie in der App **Auschecken** drücken.

Nach dem Speichern aus Ihrem Dateimanager gilt also:

- das Dokument ist **an Sie ausgecheckt** und erscheint in Ihrem Register **Ausgecheckt** mit der Markierung **automatisch**;
- Ihre Änderung wartet dort als Ihre Arbeitskopie — sie ist **noch keine neue Version**, und andere sehen weiterhin die vorherige;
- niemand sonst kann das Dokument ändern, bis Sie fertig sind;
- Sie schliessen ab, indem Sie **Einchecken** drücken, in einem der beiden Clients, oder indem Sie in den Ordner **Check-out** des Laufwerks speichern.

> **Speichern ist nicht dasselbe wie Veröffentlichen.** Das System kann nicht erkennen, wann Sie mit dem Bearbeiten fertig sind — das können nur Sie, und mit **Einchecken** sagen Sie es. Bis dahin wird Ihre Arbeit sicher als Ihre Arbeitskopie aufbewahrt. Ein Auschecken, das lange unberührt bleibt, wird durch die Leerlaufregel Ihrer Organisation automatisch aufgehoben, und Sie werden gewarnt, bevor das geschieht.

Die Markierung **automatisch** gibt es, damit das nie wie ein Fehler aussieht: Ein Dokument, das Sie nie ausdrücklich ausgecheckt haben, ist Ihnen zugefallen, und das Register sagt warum und nennt das Programm, das es ausgelöst hat.

Hat jemand anderes das Dokument bereits ausgecheckt, erfährt Ihr Editor, dass die Datei gesperrt ist, und öffnet sie schreibgeschützt, statt Sie zehn Minuten bearbeiten zu lassen und dann beim Speichern zu scheitern. Dokumente, die Sie nicht bearbeiten dürfen, und Dokumente, die durch eine gesetzliche Aufbewahrungspflicht eingefroren sind, verhalten sich im Laufwerk genau wie in der App: Sie verweigern es.

#### 6.1.1 Wenn im Eingangskorb etwas überschrieben wird

Der **Eingangskorb** enthält blosse Dateien statt Dokumente: keine Versionen, kein Verlauf — das macht es so schnell, Dinge hineinzulegen, und das macht ein Überschreiben endgültig, wie es das bei einem abgelegten Dokument nie ist. Das ist wichtig, weil ein Programm einen Eintrag überschreiben kann, ohne es zu wollen. Eine Office-Suite speicherte korrekt in einen Eintrag des Eingangskorbs und machte dann, sechs Sekunden später, ihr eigenes Speichern rückgängig, indem sie eine **leere** Sicherungsdatei über die Datei verschob.

Wenn das geschieht, geht nichts verloren. Jeder Schreibvorgang, der einen Eintrag des Eingangskorbs ersetzt, **legt zuerst die bisherigen Bytes beiseite**, und ein Administrator kann auflisten, was für Sie beiseitegelegt wurde, und alles davon wiederherstellen. Ist ein Eintrag im Eingangskorb also nach einem Speichern leer oder falsch, melden Sie das, statt neu anzufangen — die vorherigen Bytes sind mit ziemlicher Sicherheit noch da. Abgelegte Dokumente brauchen nichts davon: Sie bewahren von Haus aus jede Version auf, und das ist das Argument dafür, alles abzulegen, dessen Verlust Sie stören würde.

> **Eine Warnung Ihrer eigenen Software ist kein Fehler unserer.** Manche kommerziellen Hersteller betrachten eine WebDAV-Verbindung zu einer Adresse, die nicht auf ihrer eigenen Freigabeliste steht, als verdächtig oder lehnen sie rundweg ab. Das ist eine Richtlinienentscheidung in der Software des jeweiligen Herstellers, keine Einschränkung von Alcifra — dasselbe Laufwerk, das ein Programm ablehnt, funktioniert in der Regel in einem anderen auf demselben Rechner.

## 6.2 Das Archiv im E-Mail-Programm lesen (IMAP)

Wo WebDAV das Archiv zum Netzlaufwerk macht, lässt **IMAP** ein E-Mail-Programm darin blättern: Richten Sie ein beliebiges IMAP-fähiges E-Mail-Programm auf Ihren Alcifra-Server, und Sie durchsuchen denselben nach ACL gefilterten Baum als Postfächer. **INBOX** ist Ihr persönlicher Ordner; die gemeinsamen Archive, die Sie sehen können, erscheinen daneben. Archivierte E-Mails werden nativ gelesen; jedes **andere** Dokument kann ebenfalls erscheinen — als Nachricht, die die Datei als Anhang trägt —, wenn Sie das einschalten.

> **Das ist Ihr Archiv mit einem IMAP-Gesicht — kein E-Mail-Dienst.** Alcifra holt Ihre E-Mails nicht bei Ihrem Anbieter ab, versendet keine E-Mails und ersetzt Ihr E-Mail-Konto nicht. Nichts hiervon ändert, wo Ihre E-Mails liegen. Was Sie erhalten, ist das zweite Konto in Ihrem E-Mail-Programm: Behalten Sie Ihr echtes daneben und **legen** Sie E-Mails vom einen ins andere **ab** — dafür ist das unten beschriebene Ziehen da.

**Auch Verknüpfungen erscheinen als Postfächer.** Ein Ordner, zu dem Sie einen Verweis abgelegt haben, erscheint in der Liste überall dort, wo der Verweis liegt, mit allem darunter — so

lassen sich die Ziele, in die Sie am häufigsten ablegen, in Ihrem persönlichen Ordner sammeln und aus dem E-Mail-Programm erreichen, ohne den ganzen Baum zu durchsuchen.

Ihr E-Mail-Programm meldet sich mit Ihrer E-Mail-Adresse und einem **Gerätepasswort** aus **Geräte…** im Kontomenü an (siehe Abschnitt 8.2); der Dialog zeigt auch den **Server** und seine Ports. Der Schalter **E-Mail zeigt alle Dokumente** gehört Ihnen, für alle Geräte: Aus (die Voreinstellung) listet nur E-Mails; an listet alles, was Sie sehen dürfen, mit der angehängten Datei, die sich direkt aus dem E-Mail-Programm öffnen lässt.

> **Das E-Mail-Programm kann die Ordner nicht umordnen.** Ordner werden in Alcifra angelegt, umbenannt und gelöscht — ein IMAP-Client, der dasselbe versucht, wird höflich abgewiesen. Mit Nachrichten hingegen können Sie arbeiten: Ziehen Sie eine E-Mail in einen Ordner, um sie **im Archiv abzulegen** (sie wird ein vollwertiges E-Mail-Dokument, benannt nach ihrem Betreff), verschieben Sie eine Nachricht, um sie neu abzulegen, kopieren Sie eine, um einen **Verweis** zu hinterlassen, und löschen + bereinigen (Expunge) Sie sie, um sie in den **Papierkorb** zu schicken — nie ein endgültiges Löschen. Gelesen/Ungelesen wird pro Person gespeichert.

**Verschlüsseln, was Ihr E-Mail-Programm empfängt.** Wenn die Nachrichten, die ein E-Mail-Programm abruft, **nur mit Ihrem eigenen Schlüssel** lesbar sein sollen, schalten Sie für dieses Gerät unter **Geräte… E-Mail-Inhalt verschlüsseln** ein (siehe Abschnitt 8.2): Ab seiner nächsten Verbindung kommt jede Nachricht an Ihre hinterlegten Leserzertifikate versiegelt an, und das E-Mail-Programm entschlüsselt sie, sobald es den Schlüssel verwenden kann. Zum Einschalten braucht es einen hinterlegten, **bestätigten Hardware-Schlüssel** — eine Smartcard oder einen Sicherheitsschlüssel —, den Sie mit **Zertifikat hinterlegen…** im Kontomenü hinterlegen (Abschnitt 15.8); im Desktop-Client liest **Karte oder Token hinzufügen…** das Zertifikat und seine Bestätigung in einem Schritt vom Token. Lesen Sie, bevor Sie sich für eine Karte entscheiden, Abschnitt 15 darüber, was sie abdeckt: Sie ist die stärkste Option, und manche E-Mail-Programme können überhaupt keine Karte verwenden. Wo Ihre Organisation alle E-Mails versiegelt, ist der Schalter für jedes Gerät eingeschaltet und lässt sich nicht ausschalten.

> **Frühere Versionen liessen Sie im Browser ein Zertifikat für verschlüsselte E-Mail erzeugen oder hochladen.** Dieses Selbstbedienungs-Zertifikat ist ausser Dienst gestellt: Ein Schlüssel, der als Datei existiert, ist genau das, was ein Hardware-Schlüssel vermeidet. Wenn Sie eines hatten, hat das Archiv es übernommen, soweit die Regeln Ihrer Organisation es zulassen, und Ihnen einmal per Benachrichtigung gesagt, falls E-Mails nicht mehr daran versiegelt werden.

Das Einrichtungsprofil, das ein Telefon aus der Übergabe eines Geräts installiert, trägt ausserdem das **eigene Eingangszertifikat des Archivs**: Eine verschlüsselte Nachricht **an** die Eingangsadresse des Archivs (`archive@` die E-Mail-Domain Ihrer Installation) zu verfassen, funktioniert dann sofort — das Archiv entschlüsselt sie beim Eintreffen und legt ein gewöhnliches, durchsuchbares Dokument ab.

**Auch Notizen.** Richten Sie eine Notizen-App, die über IMAP synchronisiert, auf dasselbe Konto, und sie findet das Postfach **Notes** — Ihren persönlichen Ordner **Notes** in Verkleidung. Jede Notiz wird ein vollwertiges Archivdokument mit dem Dokumenttyp **Note**, und das Bearbeiten einer Notiz auf Ihrem Telefon fügt im Archiv eine **neue Version** hinzu statt einer neuen Kopie — der vollständige Verlauf bleibt in der Workbench einsehbar. Der Ordner Notes ist typisiert: Er nimmt nur Notizen auf, und Notizen liegen nur dort (Verweise auf sie dürfen überall liegen).

# 7 Kontakte, Kalender und Ihre Aufgaben

Zwei der Tabs im Arbeitsbereich handeln gar nicht von Dokumenten – oder genauer: von Dokumenten, die zufällig eine **Kontaktkarte** oder ein **Kalendereintrag** sind. **Kontakte** listet die Personen in Ihren Adressbüchern auf; **Kalender** listet Ihre Termine auf. Beide lesen dasselbe Archiv mit denselben Berechtigungen, und beide lassen sich **von Ihrem Telefon aus abonnieren**.

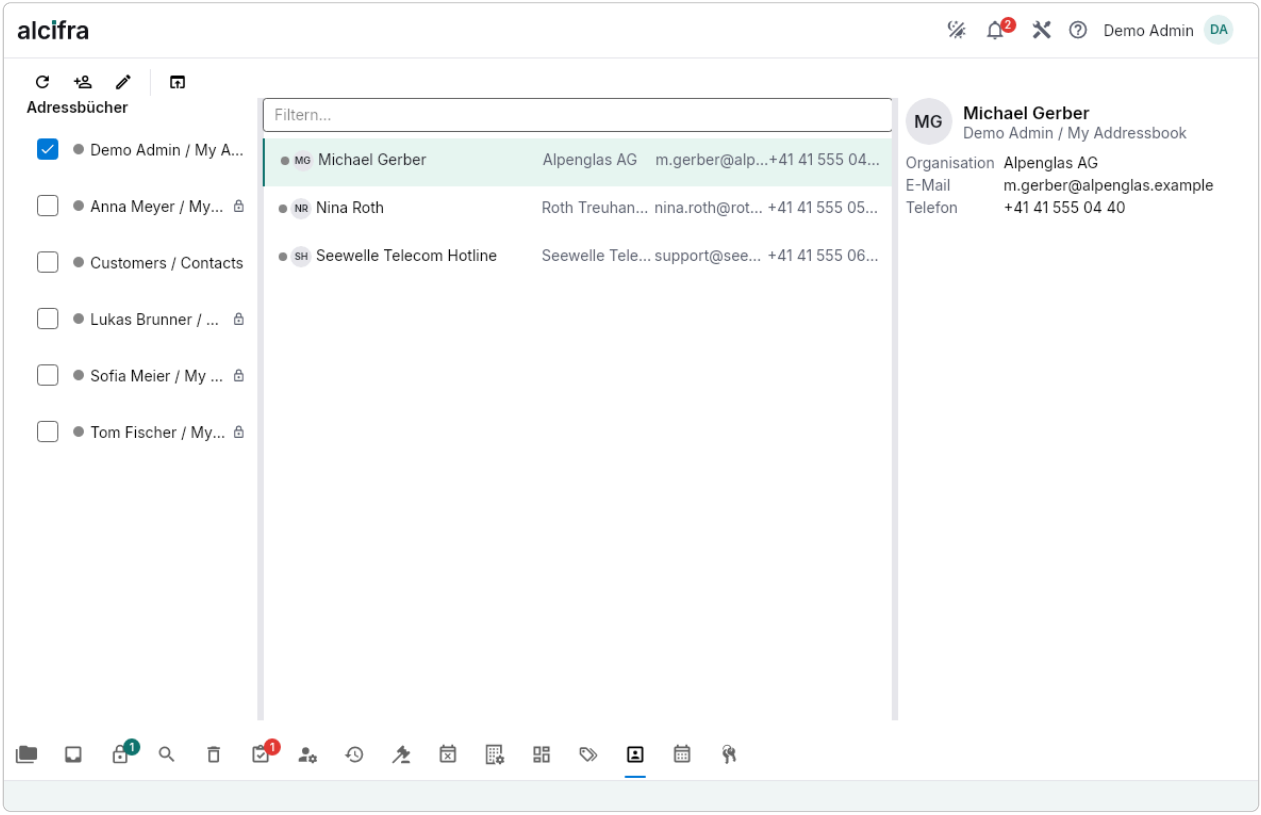



Abbildung 11: Der Tab Kontakte: links die Adressbücher, die Personen der angekreuzten Adressbücher in einer Liste zusammengeführt.

**Sammlungen überlagern sich, statt sich zu ersetzen.** Die Liste links ist eine Reihe von Kontrollkästchen, keine Einzelauswahl – kreuzen Sie zwei Adressbücher an, sehen Sie beide Personengruppen in einer Liste, und jede Zeile trägt ein kleines Farbfeld, das angibt, aus welcher Sammlung sie stammt. Ihre eigenen **My Addressbook** und **My Calendar** sind von Anfang an angekreuzt, damit der Tab nicht leer öffnet. Die Farbe legen Sie selbst fest, und sie gilt nur für Sie: Wenn Sie sie ändern, ändert sich nichts an dem, was andere sehen.

Der persönliche Bereich jedes Benutzers enthält von Anfang an **My Addressbook** und **My Calendar**. Sie lassen sich weder löschen noch verschieben – sie sind die festen Punkte, die Ihr Telefon abonniert, und sie bereitzustellen wäre sinnlos, wenn der nächste Klick sie entfernen könnte. Adressbücher und Kalender können aber auch **an jeder anderen Stelle** im Archiv liegen: Ein gemeinsames Archiv kann ein Team-Adressbuch enthalten, und wer die Berechtigung hat, sieht es in derselben Liste.

## 7.1 Einen Kontakt oder einen Termin hinzufügen und bearbeiten

**Neuer Kontakt** und **Neuer Termin** öffnen ein Formular. Füllen Sie es aus und speichern Sie, dann wird der Eintrag angelegt – vor dem Speichern existiert nichts, wer das Formular schliesst, hinterlässt also nichts. Sind mehrere Sammlungen angekreuzt, fragt das Formular, in welche der Eintrag gehört; gibt es nur eine mögliche, fragt es nicht, und die Bestätigung nennt, wo er gelandet ist.

**Bearbeiten** öffnet **dasselbe** Formular für einen bestehenden Eintrag. Das ist Absicht und kein Zufall: Ein Erfassungsformular mit weniger Feldern als der Editor würde stillschweigend verwerfen, was Sie in die Felder eingetragen haben, die ihm fehlen.

Ein Kontakt enthält weit mehr als einen Namen – mehrere **E-Mail-Adressen** und **Telefonnummern**, jede mit eigenem Typ, mehrere **Postadressen**, eine Organisation, eine Position, einen Geburtstag, eine Website und eine Notiz. Fügen Sie Zeilen hinzu und entfernen Sie sie, wie Sie sie brauchen.

> **Alles, was das Formular nicht zeigt, bleibt erhalten.** Ein auf einem Telefon angelegter Kontakt enthält Dinge, die dieses Formular nicht abbildet – ein Foto, eigene Bezeichnungen, Felder eines anderen Programms. Speichern hier **bewahrt** all das, statt wegzulassen, was es nicht versteht – und genau das macht es sicher, im Archiv eine Karte zu bearbeiten, die auf Ihrem Telefon lebt.

## 7.2 Erweitert: der gespeicherte Eintrag

Unter jedem Kontakt- und Terminformular gibt es einen zugeklappten Abschnitt **Erweitert: der gespeicherte Eintrag**. Klappen Sie ihn auf, sehen Sie den Eintrag genau so, wie er gespeichert ist – eine **vCard** bei einem Kontakt, einen **iCalendar**-Eintrag bei einem Termin – einschliesslich der Eigenschaften, die das Formular darüber nicht zeigt.

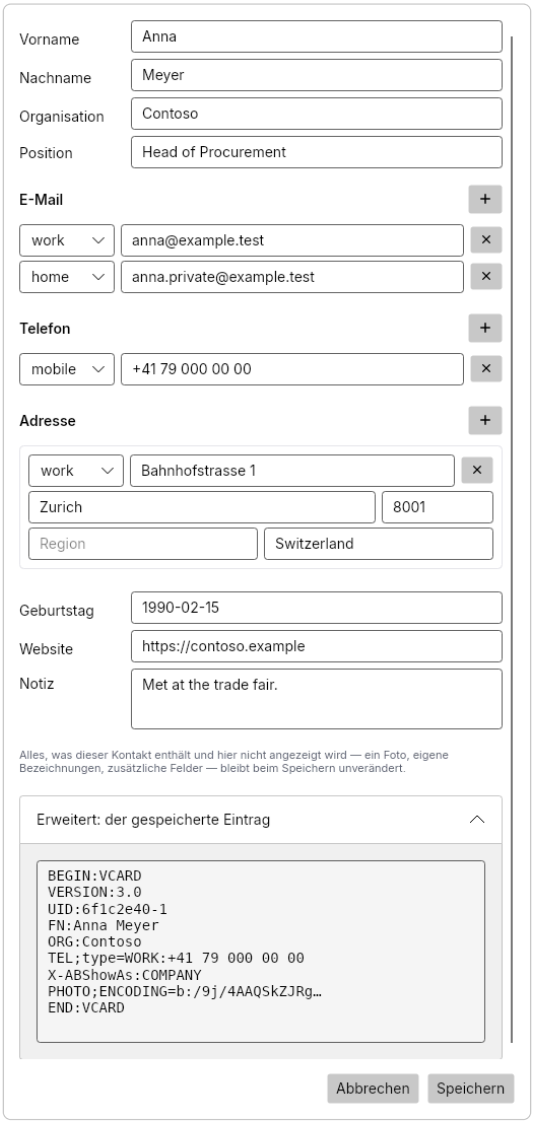



Abbildung 12: Der Kontakteditor mit geöffnetem Abschnitt **Erweitert: der gespeicherte Eintrag** – die gespeicherte vCard, einschliesslich der Eigenschaften, die kein Formularfeld zeigt.

Er ist bearbeitbar, und dies ist die einzige Stelle im Produkt, an der Speichern **ersetzt** statt zusammenführt. Löschen Sie hier eine Zeile, ist die Eigenschaft weg; genau das muss «roh» bedeuten, und ein Zusammenführen würde sie zurückholen und Ihnen dabei melden, das Speichern sei gelungen. Zwei Dinge werden abgelehnt statt angenommen: Text, der keine gültige Karte und kein gültiger Eintrag ist, und eine Änderung der **UID** – der Kennung, an der jedes Telefon und jedes Mailprogramm diesen Eintrag wiedererkennt. Eine geänderte UID würde den Eintrag nicht umbenennen, sondern zu einem **anderen** machen; Ihr Telefon würde also die alte Kopie behalten und die neue hinzufügen. In beiden Fällen wird nichts geschrieben, und der gespeicherte Eintrag bleibt unverändert. Die UID-Zeile zu entfernen ist keine Änderung; die gespeicherte UID bleibt erhalten.

> **Während Sie den Rohtext bearbeiten, sind die Felder darüber schreibgeschützt.** Beide beschreiben denselben Eintrag, und nur eines von beiden kann gespeichert werden. Eine Zeile unter dem Feld sagt, auf welchem Weg gespeichert wird.

Jedes Speichern – aus dem Formular oder aus dem Rohtextfeld – schreibt eine **neue Version**, genau wie jede andere Änderung an einem Dokument. Eine Rohbearbeitung, die Sie bereuen, lässt sich wie alles andere aus dem Versionsverlauf wiederherstellen.

## 7.3 Vom Telefon aus abonnieren (CalDAV und CardDAV)

Adressbücher und Kalender sprechen **CardDAV** und **CalDAV** – die Standards, die Telefone, Tablets und Mailprogramme bereits verwenden. Richten Sie ein Gerät auf Ihren Server von Alcifra, und es findet jedes Adressbuch und jeden Kalender, den Sie sehen dürfen, wo immer er im Archiv liegt; danach wählen Sie aus, was synchronisiert wird. Änderungen gehen in beide Richtungen: Ein auf dem Telefon geänderter Kontakt wird zu einer neuen Version im Archiv, und einer, der im Arbeitsbereich geändert wird, erscheint auf dem Telefon.

Ein Gerät meldet sich mit Ihrer E-Mail-Adresse und seinem eigenen **Gerätepasswort** aus **Geräte…** im Kontomenü an (siehe Abschnitt 8.2), demselben, das sein Dateimanager und sein E-Mail-Programm verwenden.

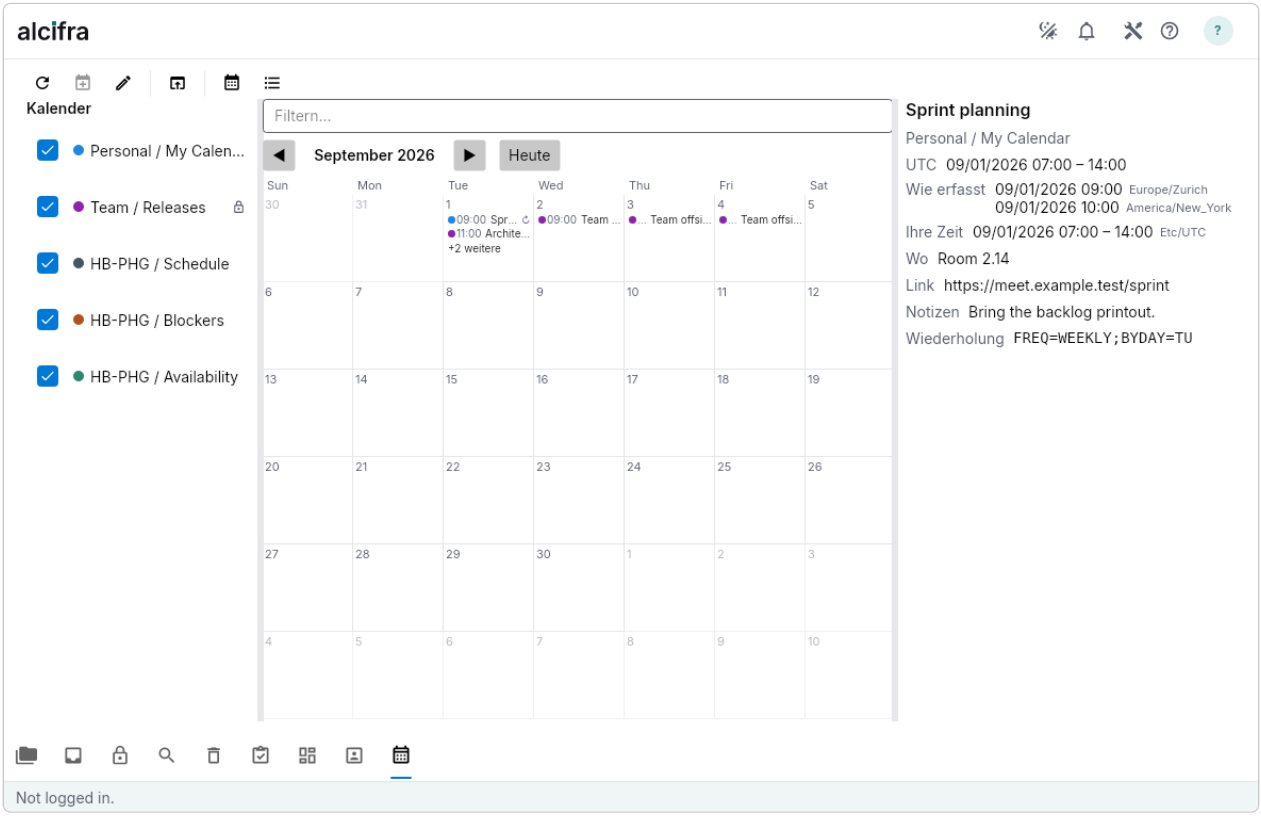



Abbildung 13: Der Tab Kalender, nach Zeit geordnet – Einträge ohne Datum stehen am Ende statt in den obersten Zeilen.

## 7.4 Ihre Aufgaben auf dem Telefon

Neben Ihren Kalendern erscheinen zwei weitere Sammlungen, die überhaupt keine Dokumente enthalten:

- **My tasks** – die Ihnen zugewiesenen Prüfungen als Aufgaben. Diese Sammlung abonniert eine Erinnerungs- oder Aufgaben-App.
- **My task deadlines** – dieselben Prüfungen als datierte Einträge, für Kalenderprogramme, die keine Aufgaben anzeigen.

Beide sind **schreibgeschützt**. Sie sind eine Ansicht des Tabs **Aufgaben**, veröffentlicht, damit Sie sehen, was auf Sie wartet, ohne das Archiv zu öffnen; eine Prüfung genehmigen oder ablehnen Sie weiterhin im Arbeitsbereich, wo festgehalten wird, wer es getan hat und warum.

> **Eine Prüfung erhält nur dann eine Frist, wenn ihr Dokumenttyp eine festlegt.** Die Prüf-SLA wird pro Dokumenttyp festgelegt, und wo keine festgelegt ist, hat die Prüfung schlicht kein Fälligkeitsdatum – sie erscheint trotzdem in **My tasks**, kann aber nicht in **My task deadlines** erscheinen, das eine Liste von Daten ist. Eine leere Fristenliste bedeutet meist, dass in Ihrem Mandanten für keinen Dokumenttyp eine SLA eingerichtet ist.

## 7.5 Einen Besprechungsraum reservieren

Ein **Besprechungsraum** ist ein Ordner vom Typ *Meeting room* – eine Administratorin oder ein Administrator legt ihn dort an, wo Räume liegen sollen, und wer den Ordner sehen darf, darf auch seine Reservierungen sehen. Wählen Sie einen Raum aus, dann bieten sein Kontextmenü und das Menüband unter **Aktionen** den Eintrag **Buchungen…** an: die bestehenden Reservierungen und eine Zeile, um eine neue vorzunehmen.

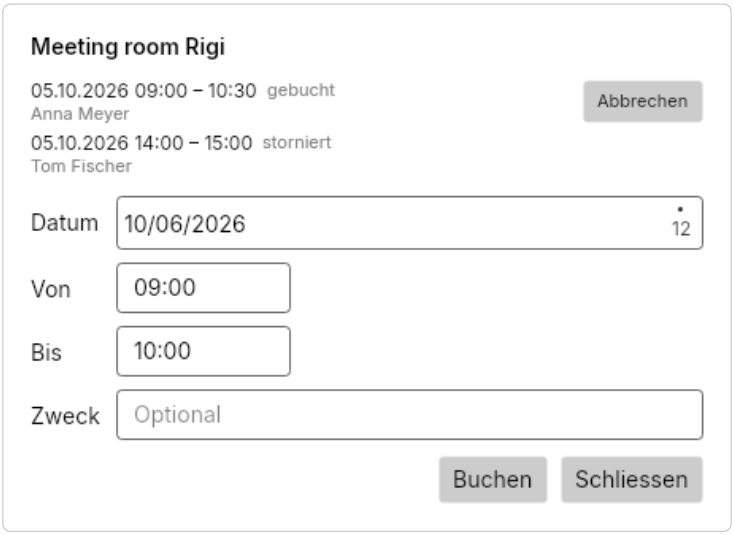



Abbildung 14: Der Dialog Buchungen zu einem Raum: oben die bestehenden Reservierungen – eine stornierte bleibt als Verlauf sichtbar – und unten die neue Reservierung, deren Zeiten eingetippt statt ausgewählt werden.

Wählen Sie das Datum, tippen Sie die Zeiten ein – `0950`, `9:50` und `09:50` funktionieren alle –, fügen Sie bei Bedarf einen Zweck hinzu und klicken Sie auf **Buchen**. Ein Zeitfenster, das sich mit einer bestehenden Reservierung überschneidet, wird **abgelehnt, und die Ablehnung sagt das**: Der Raum wird nie stillschweigend doppelt gebucht, und es gibt keine Warteschlange, über die man rätseln müsste. **Abbrechen** behält die Zeile, als storniert markiert, sodass die Frage «Wer hatte

den Raum gebucht?» beantwortbar bleibt; das Stornieren gibt das Zeitfenster für die nächste Person frei.

**Eine Reservierung kann sich wiederholen.** Der Dialog bucht einzelne Zeitfenster; ein wöchentlicher Jour fixe wird als sich wiederholender Kalendereintrag im Schedule des Raums angelegt – im Tab Kalender oder auf Ihrem Telefon –, und **jedes einzelne Vorkommen** wird auf Konflikte geprüft, sodass eine Serie, die an irgendeinem ihrer Termine mit etwas kollidieren würde, als Ganzes abgelehnt wird. Die einzige Bedingung: Eine sich wiederholende **Reservierung** muss ein Ende haben (ein letztes Datum oder eine Anzahl Wiederholungen). «Jeden Montag, für immer» lässt sich nicht gegen die nächste endlose Serie prüfen, deshalb nimmt das Archiv so etwas nicht an.

Hinter dem Dialog steht kein separates Buchungssystem. Die erste Reservierung legt unter dem Raum einen Kalender **Schedule** an, und jede Reservierung **ist** ein Kalendereintrag darin – ein Dokument wie jedes andere, mit Versionen, einem Audit-Trail und den eigenen Berechtigungen des Raums. Öffnen Sie den Schedule im Baum, und Sie sehen dieselben Reservierungen, die der Dialog zeigt; kreuzen Sie ihn im Tab **Kalender** an, und sie überlagern Ihre eigenen Termine, farblich gekennzeichnet wie jede andere Sammlung.

**Und weil der Schedule ein Kalender ist, kann Ihr Telefon ihn abonnieren** – mit demselben CalDAV-Abonnement wie jeden anderen Kalender (Abschnitt 7.3). Das wirkt bewusst in beide Richtungen:

- **Lesen:** Kreuzen Sie den Schedule des Raums auf Ihrem Telefon an, und die Reservierungen des Raums erscheinen neben Ihren eigenen Terminen – die schnellste Antwort auf «Ist der Raum um drei frei?» ist der Kalender, den Sie ohnehin in der Tasche haben.
- **Schreiben:** Einen Termin in diesem Kalender auf Ihrem Telefon anzulegen **ist** eine Buchung des Raums, und sie durchläuft **dieselbe** Konfliktprüfung wie der Dialog. Eine Reservierung auf eine andere Zeit zu ziehen ist eine Umbuchung und wird erneut geprüft; es gibt keinen Zugang – Arbeitsbereich, Telefon oder irgendein Kalenderprogramm –, der die Regel umgeht.

### 7.5.1 Drei Kalender, drei verschiedene Fragen

Etwas Buchbares – ein Raum, ein Fahrzeug, die Zeit einer Person – beantwortet drei Fragen zur selben Zeitachse, und jede bekommt ihren eigenen Kalender, weil jede einer **anderen Regel** folgt. Sie in einen Kalender zu legen hiesse, eine Regel für drei Aufgaben zu haben, und zwei der drei wären falsch.

| Kalender | Er sagt | Und die Regel, die ihn unterscheidet |
|---|---|---|
| **Schedule** | Diese Zeit ist *beansprucht* | Zwei Reservierungen dürfen sich **nie** überschneiden. Ein kollidierendes Zeitfenster wird abgelehnt, und die Ablehnung sagt das. |
| **Blockers** | Diese Zeit ist *entzogen* | Sperren **dürfen** sich gegenseitig überschneiden – zwei an einem Fahrzeug gemeldete Mängel sind zwei Einträge, und die zweite abzulehnen hiesse, dass der zweite Befund nicht erfasst werden kann. |
| **Availability** | Diese Zeit ist *angeboten* | Zeitfenster dürfen sich gegenseitig überschneiden, **und** Reservierungen liegen innerhalb von ihnen – diese Überschneidung ist der ganze Zweck, kein Konflikt. |

**Ausser Betrieb.** Eine in Blockers abgelegte Sperre («Projektor defekt, Dienstag bis Donnerstag») **setzt** jede Reservierung **aus**, mit der sie sich überschneidet, statt sie zu löschen; wird die Sperre

aufgehoben, gelten diese Reservierungen einfach wieder. Nichts wird als «ausgesetzt» gespeichert, also kann nichts veralten, und niemand kann eine Reservierung durch Bearbeiten wieder in Kraft setzen – der einzige Ausweg ist, die Sperre aufzuheben, und das ist ein eigenes Recht. Eine ausgesetzte Reservierung erscheint auf Ihrem Telefon als **vorläufig**, sodass Sie sehen, dass sie in Frage steht, ohne dass sie aus Ihrer Woche verschwindet.

Die beiden Zeitpunkte werden bewusst unterschiedlich behandelt. Eine **neue** Buchung, die in eine Sperre fällt, wird gleich beim Eingang **abgelehnt**; eine Buchung, die schon bestand, als die Sperre hinzukam, wird **ausgesetzt**. Das Archiv lässt Sie nicht in ein bekanntes Problem hineinlaufen, und es storniert nicht stillschweigend eine Zusage, die Sie bereits gemacht haben.

**Angebotene Zeit.** Ein Availability-Zeitfenster ist jemand, der veröffentlicht, wann etwas gebucht werden darf – die Unterrichtszeiten einer Fluglehrerin, die Ausleihzeiten eines Poolfahrzeugs. Zwei Regeln dazu sollten Sie kennen, weil die naheliegende Vermutung in beiden Fällen falsch ist:

- **Ein Zeitfenster muss die ganze Buchung allein abdecken.** Zwei aneinandergrenzende Zeitfenster addieren sich nicht: 09:00–11:00 und 11:00–13:00 tragen zusammen keine Buchung von 10:00–12:00. Ein halbes Angebot als Zustimmung zu einer ganzen Buchung gelten zu lassen, wäre ein Fehler, den niemand bemerken würde – die Buchung gelingt, jemand ist auf eine Zeit verpflichtet, die er nie angeboten hat, und das erfährt man erst, wenn er nicht erscheint.
- **Kein Zeitfenster heisst: nicht angeboten.** Etwas, für das niemand Zeit veröffentlicht hat, bietet nichts an. Das Fehlen eines Angebots ist keine Zustimmung.

Ob eine Reservierung überhaupt ein Angebot **voraussetzt**, hängt davon ab, was gebucht wird, und darüber entscheidet das Branchenmodul, dem das Gebuchte gehört, nicht das Archiv: Um einen Fluglehrer zu buchen, braucht es vielleicht seine veröffentlichten Zeiten als seine Zustimmung, während ein Besprechungsraum nichts dergleichen braucht. Das Archiv speichert das Angebot und beantwortet die Frage; wozu die Antwort **verpflichtet**, ist die Regel des Moduls.

## 7.6 Nachrichten auf dem Desktop

Wo das Archiv den **Messenger** anbietet, zeigt der Arbeitsbereich einen Tab **Nachrichten**: links Ihre Unterhaltungen – eine Gruppe mit der Zahl ihrer Mitglieder, ungelesene Nachrichten als Zähler –, rechts die ausgewählte, dargestellt und bedient genau wie auf dem Telefon. Eine Nachricht wird mit Ihrem eigenen Schlüssel geöffnet – einem Schlüssel auf diesem Computer, falls Sie einen haben, sonst mit Ihrer Karte, die einmal nach ihrer PIN fragt.

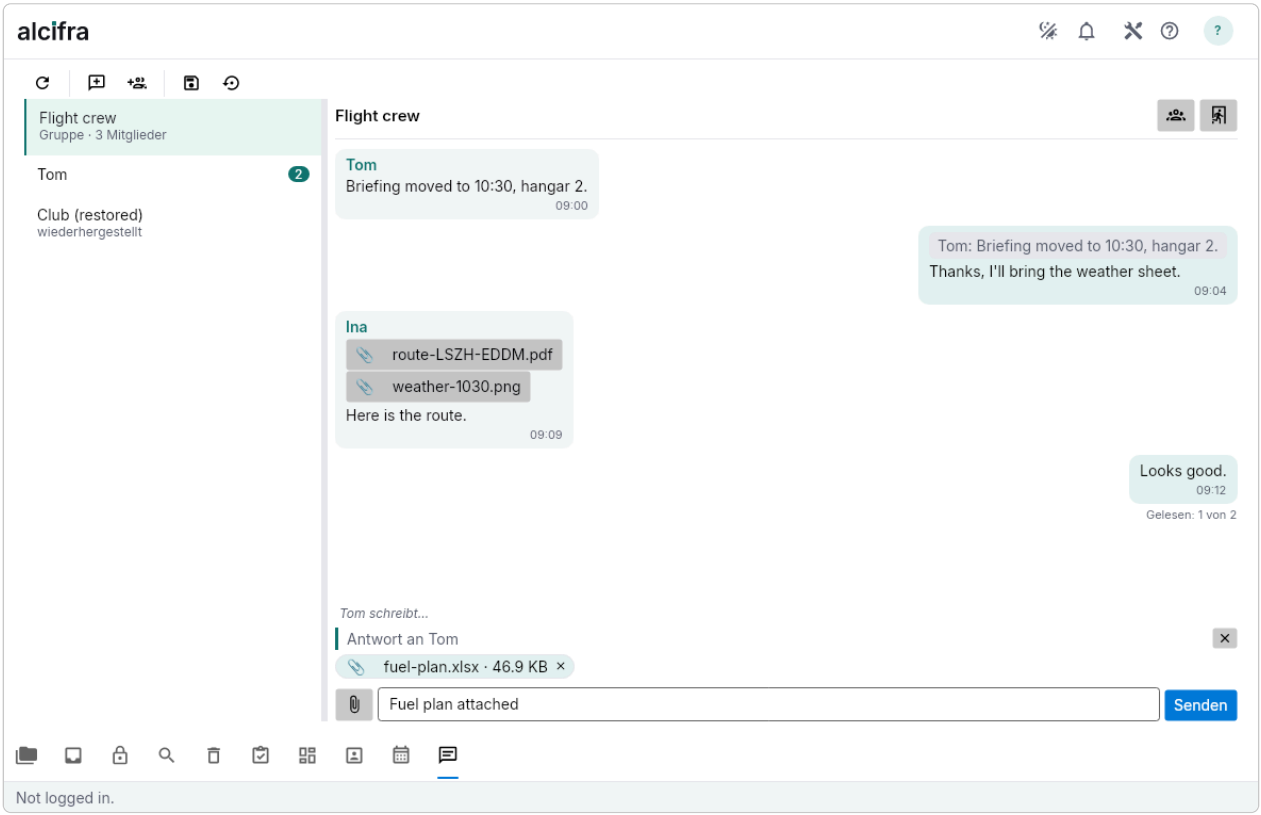



Abbildung 15: Der Tab Nachrichten: ein Verlauf mit einer Antwort, zwei Dateien in einer Nachricht und einer Lesebestätigung; darunter wird eine Antwort geschrieben, mit einer wartenden Datei als Chip.

**Schreiben.** Tippen Sie in das Feld unten: **Enter** sendet, **Shift+Enter** beginnt eine neue Zeile. Solange eine Nachricht unterwegs ist, zeigt sie **Wird gesendet…**, und das Feld wartet, sodass ein Klick nie doppelt sendet. Die Büroklammer fügt Dateien hinzu – mehrere auf einmal – als Chips über dem Feld, jeder mit eigenem ×; **Dateien auf die Unterhaltung ziehen** bewirkt dasselbe. **Senden** verschickt sie zusammen mit Ihrem Text als **eine** Nachricht, der Text als ihre Beschriftung. Ein Rechtsklick auf eine Nachricht zeigt, was Sie damit tun können: **Antworten** (eine Leiste über dem Feld sagt, an wen; × oder **Esc** nimmt es zurück), Ihre eigene Nachricht **Bearbeiten** (sie wandert ins Feld; **Speichern** oder **Ctrl+S** bzw. **Cmd+S** übernimmt die Änderung, **Esc** lässt sie, wie sie war), **Text kopieren**, **Gelesen von…** in einer Gruppe sowie **Für alle löschen** oder **Für mich löschen**. Wer sonst gerade tippt, erscheint unter dem Verlauf; die Tastatur-Schaltfläche im Menüband schaltet das in beide Richtungen ab. Haben Sie nach oben gescrollt, um ältere Nachrichten zu lesen, zieht Sie etwas Neues nicht nach unten: **Neue Nachrichten ↓** bringt Sie dorthin.

**Dateien bleiben in der App.** Ein Foto, ein PDF oder ein reiner Text öffnet sich direkt hier, über der Unterhaltung, mit Suche und Zoom – aus dem Arbeitsspeicher gelesen, nichts wird auf die Festplatte geschrieben. Was der Desktop nicht anzeigen kann (ein Office-Dokument, ein Video oder eine Tonaufnahme), lässt sich mit **Öffnen mit…** an eine andere Anwendung übergeben

oder mit **Speichern unter…** sichern – erst nach einer Warnung, dass die Kopie den Schutz des Archivs verlässt, und gar nicht, wo Ihre Organisation Dateien in der App behält.

**Versiegelt bleibt versiegelt.** Brechen Sie die PIN-Abfrage ab oder öffnet kein Schlüssel hier eine Unterhaltung, erscheinen ihre Nachrichten als **versiegelt** statt gar nicht; **Mit meinem Schlüssel öffnen** fragt erneut. Eine Unterhaltung, deren neueste Nachricht versiegelt geblieben ist, wird nicht als gelesen markiert. Ziehen Sie Ihre Karte aus dem Lesegerät, werden die Schlüssel der Unterhaltungen mit ihr vergessen, und der Verlauf erscheint versiegelt, bis Sie ihn wieder öffnen.

**Chats und Gruppen.** Das Menüband startet mit **Neuer Chat** einen Chat oder mit **Neue Gruppe** eine Gruppe (ein Name und mehrere Personen); angeboten werden nur Kolleginnen und Kollegen mit einem registrierten Schlüssel, weil sich für niemanden sonst etwas versiegeln lässt. In einer Gruppe zeigt die Personen-Schaltfläche ihre **Mitglieder**, die Administratoren zuerst: Ein Administrator fügt Mitglieder hinzu und entfernt sie – jedes Mal erzeugt dieser Computer einen neuen Schlüssel, sodass ein Neuzugang ab jetzt mitliest und jemand, der entfernt wurde, nichts mehr liest – und macht andere zu Administratoren; der letzte Administrator kann nicht zurücktreten. **Verlassen** fragt zuerst nach.

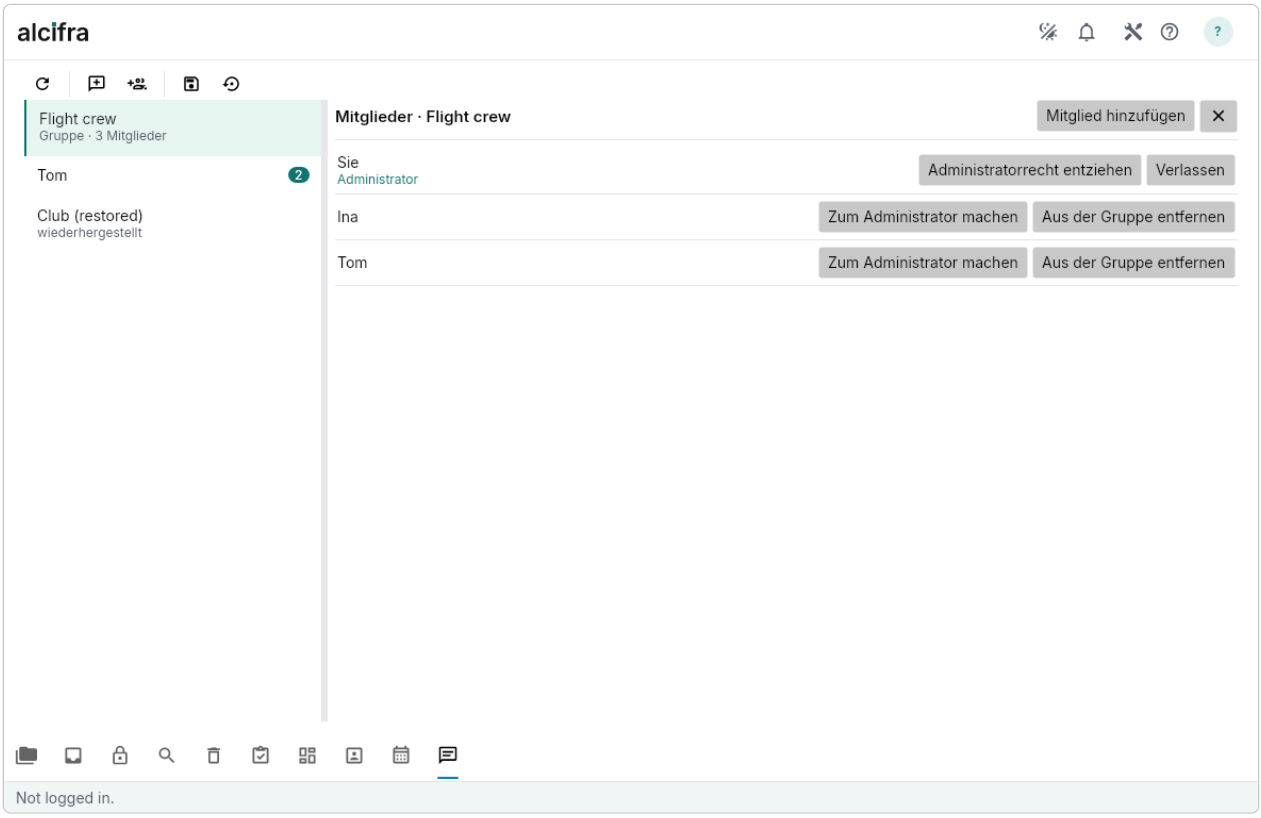



Abbildung 16: Die Mitglieder einer Gruppe, Administratoren zuerst, jeweils mit dem, was Sie tun dürfen.

**In eine Datei sichern…** schreibt alle Ihre Unterhaltungen in eine Datei Ihrer Wahl, versiegelt genau so, wie sie zugestellt wurden – nichts wird dafür entschlüsselt, also öffnet sie nur Ihr eigener Schlüssel wieder. **Aus einer Datei wiederherstellen…** holt eine solche Sicherung als Verlauf zum Lesen zurück; sobald alle Beteiligten einer wiederhergestellten Unterhaltung in dieser Installation sind, macht **Hier fortsetzen** daraus eine aktive Unterhaltung mit dem Verlauf darüber. Eine Benachrichtigung «Neue Nachrichten» in der Glocke öffnet ihre Unterhaltung hier, und eine geöffnete Unterhaltung liest neue Nachrichten, sobald sie eintreffen.

Was der Desktop nicht tut, weil ein Desktop es nicht kann: ein Foto mit einer Kamera aufnehmen (wählen Sie stattdessen eines aus einer Datei), im geschlossenen Zustand durch eine Push-Benachrichtigung geweckt werden oder nach Zeitplan im Hintergrund sichern.

## 7.7 Passwörter auf dem Desktop

Wo das Archiv den **Passwortspeicher** anbietet, zeigt der Arbeitsbereich einen Tab **Passwörter** – den Schlüsselbund am Ende der Tab-Leiste. Links stehen Ihre Speicher: zuerst **Meine Passwörter** (er wird beim ersten Öffnen angelegt), dann die gemeinsamen Speicher, die Sie entschlüsseln können. In der Mitte stehen die Ordner und Einträge des ausgewählten Ordners; rechts zeigt die Vorschau den ausgewählten Eintrag.

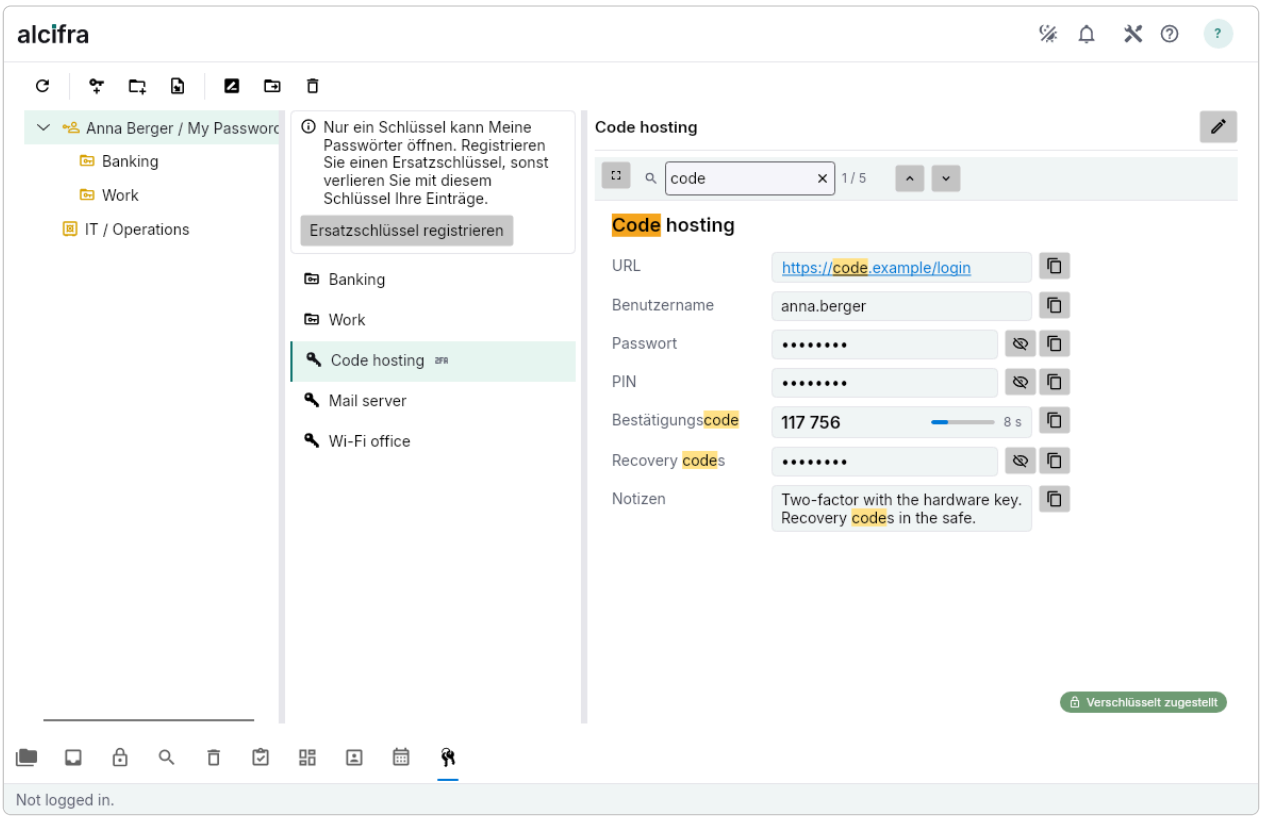



Abbildung 17: Der Tab Passwörter: Meine Passwörter mit seinen Ordnern, ein in der Vorschau geöffneter Eintrag und das Suchfeld, das hervorhebt, was sichtbar ist. Das Passwort, die PIN und die Wiederherstellungscodes bleiben verborgen.

**Einen Eintrag öffnen.** Wenn Sie einen Eintrag auswählen, wird er mit Ihrem Hardware-Schlüssel geöffnet: Die Karte fragt einmal nach ihrer PIN und merkt sie sich, solange sie im Lesegerät steckt. Nur ein Hardware-Schlüssel öffnet einen Eintrag, nie ein auf dem Computer gespeicherter Schlüssel, weil Einträge nur für attestierte Hardware-Schlüssel versiegelt werden. Brechen Sie die PIN-Abfrage ab, bleibt der Eintrag versiegelt, und **Mit Schlüssel öffnen** fragt erneut. Ziehen Sie die Karte heraus, schliesst sich der Eintrag mit ihr.

**Ihn lesen.** Die Felder erscheinen in derselben Reihenfolge wie auf dem Telefon: URL, Benutzername, Passwort, PIN, Bestätigungscode, dann alles Übrige. Das Passwort, die PIN und jedes als geheim markierte Feld zeigen Punkte. Halten Sie die Augen-Schaltfläche gedrückt (oder die Leertaste, während sie den Fokus hat), um den Wert zu sehen; er verschwindet wieder, sobald Sie loslassen oder das Fenster in den Hintergrund geht. Solange ein Geheimnis sichtbar ist, wird das Fenster von Bildschirmfotos und Bildschirmfreigaben ausgenommen, soweit Ihr System das erlaubt. Die Kopieren-Schaltfläche kopiert ein Feld; ein kopiertes Geheimnis wird nach 30 Sekunden aus der Zwischenablage entfernt, sofern Sie nicht inzwischen etwas anderes kopiert

haben. Das Suchfeld über dem Eintrag findet seinen Namen, seine Bezeichnungen und seine offenen Werte, aber nie einen verborgenen Wert, sodass sich damit keiner erraten lässt.

**Bestätigungscodes.** Ein Eintrag kann auch den sechs- oder achtstelligen Code enthalten, den eine Website beim Anmelden als zweiten Schritt verlangt. Seine Zeile zeigt immer den gerade gültigen Code in zwei Gruppen (**123 456**) und daneben die Sekunden, die er noch gilt; sind sie abgelaufen, erscheint der nächste Code. Die Kopieren-Schaltfläche kopiert den Code, und er wird wie jedes Geheimnis nach 30 Sekunden aus der Zwischenablage entfernt. Der Schlüssel hinter den Codes wird nie angezeigt: Sie können ihn nur ersetzen oder entfernen. In der Liste trägt ein Eintrag mit Bestätigungscode ein kleines **2FA**-Zeichen.

**Ihn ändern.** Der Stift neben dem Namen des Eintrags öffnet das Formular an der Stelle der Vorschau, mit **Speichern** und **Abbrechen** dort, wo der Stift war (**Ctrl+S** bzw. **Cmd+S** speichert, **Esc** bricht ab). Das Formular bietet immer URL, Benutzername und Passwort an; **Feld hinzufügen** bietet zuerst die PIN an, dann den Bestätigungscode, dann ein Feld, das Sie selbst benennen und wie ein Passwort verbergen können. Für einen Bestätigungscode fügen Sie den Einrichtungsschlüssel ein, den die Website anzeigt (Leerzeichen und Gross- und Kleinschreibung spielen keine Rolle), oder ihren `otpauth://`-Link; ein Wert, der keines von beiden ist, wird neben dem Feld gemeldet. Die meisten Websites zeigen stattdessen einen QR-Code: Machen Sie mit dem Bildschirmfoto-Werkzeug Ihres Systems ein Bildschirmfoto davon, sodass es in der Zwischenablage liegt, und klicken Sie auf die QR-Schaltfläche neben dem Feld; die Schaltfläche daneben liest den QR-Code aus einer gespeicherten Bilddatei. Im Formular zeigt ein **Klick** auf das Auge eines geheimen Felds den Wert 15 Sekunden lang, damit Sie sehen, was Sie tippen: Jeder Tastendruck startet die 15 Sekunden neu, und ein zweiter Klick, **Speichern**, **Abbrechen** oder das Verlassen des Fensters verbirgt ihn sofort. Die Würfel neben dem Passwort öffnen den Generator: Tippen Sie eine Länge ein, wählen Sie die Zeichenarten, und kreuzen Sie **Verwechselbare Zeichen vermeiden** an für ein Passwort, das Sie von einem Bildschirm abtippen werden; **Dieses Passwort verwenden** übernimmt es ins Formular. Alles wird auf Ihrem Computer versiegelt, bevor es ihn verlässt. Hat jemand anderes den Eintrag geändert, seit Sie ihn geöffnet haben, meldet das Speichern dies und zeigt Ihnen den Eintrag, wie er jetzt ist.

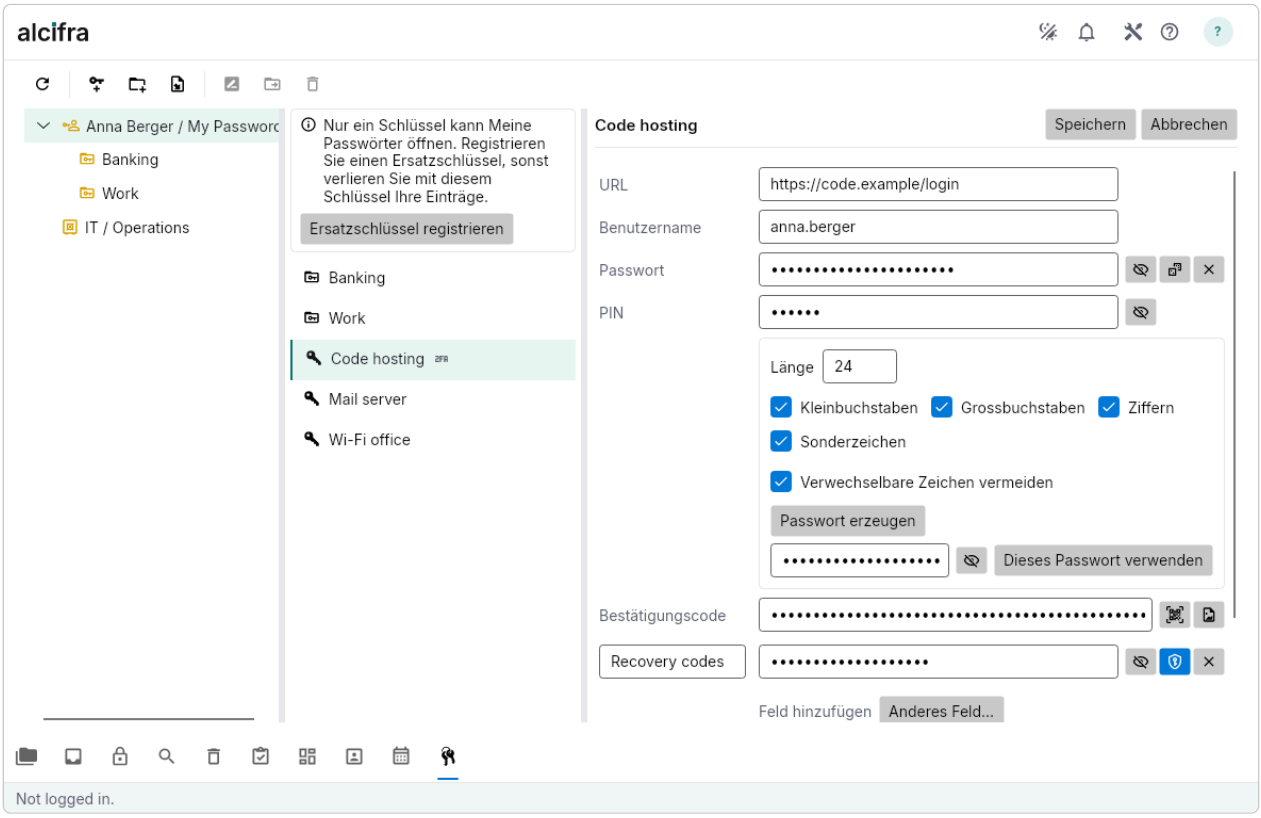



Abbildung 18: Einen Eintrag bearbeiten: die geheimen Felder verborgen, bis ihr Auge angeklickt wird, der Generator unter dem Passwort geöffnet, und Speichern und Abbrechen dort, wo der Stift war.

**Ordnen.** Das Menüband legt Einträge und Ordner an, benennt um, verschiebt und löscht in den Papierkorb. Ein Eintrag lässt sich nur dann in einen anderen Speicher verschieben, wenn Sie beide entschlüsseln können, weil er unterwegs für den Empfängerkreis des neuen Speichers neu versiegelt wird. Hat sich der Empfängerkreis eines Speichers oder der Schlüssel eines Mitglieds geändert, sagt ein Hinweis über der Liste, dass seine Einträge neu versiegelt werden müssen; ein Mitglied, das den Speicher bearbeiten darf, versiegelt mit **Neu versiegeln** und einer PIN alle neu und erfährt, wie viele neu versiegelt wurden, wie viele übersprungen wurden, weil jemand sie inzwischen geändert hat, und welche dieser Schlüssel nicht öffnen konnte. Kann nur ein einziger Schlüssel Meine Passwörter öffnen, empfiehlt ein Hinweis, einen Ersatzschlüssel zu registrieren.

**Wer einen Speicher entschlüsseln kann.** Einen gemeinsamen Speicher sehen zu dürfen ist nicht dasselbe, wie ihn entschlüsseln zu können. Ein Speicher ist für seinen **Empfängerkreis** verschlüsselt: die Personen und Gruppen, die seine **Verwalter** aus denen ausgewählt haben, die ihn lesen dürfen. Wer einen Speicher anlegt, ist sein erster Verwalter. **Verschlüsselt für…** im Menüband zeigt den Empfängerkreis allen, die den Speicher sehen können; ein Verwalter fügt eine lesende Person oder eine Gruppe hinzu, entfernt jemanden oder macht eine weitere Person zum Verwalter, und **Speichern und neu versiegeln** versiegelt den Speicher im selben Schritt mit einer PIN für den neuen Empfängerkreis. Wer entfernt wurde, kann ab dem Speichern nicht einmal mehr die Einträge abrufen, die für ihn versiegelt waren. Ein Speicher muss mindestens einen Verwalter behalten; haben alle Verwalter ihn verlassen, kann ein Mandanten-Administrator aus dem Kreis seiner Lesenden einen neuen bestimmen. Meine Passwörter gehört immer nur Ihnen. Im Tab **Archive** ist ein Speicher oder Eintrag, den Sie sehen, aber nicht entschlüsseln können, mit **Nicht für Sie verschlüsselt** markiert, und einer, zu dem Sie gerade hinzugefügt wurden, mit **Noch nicht für Sie verschlüsselt**, bis ein Mitglied das nächste Mal neu versiegelt.

Ein versiegeltes Dokument funktioniert genauso: Wer es ablegt, wählt seinen Empfängerkreis, und **Verschlüsselt für…** ändert ihn.

**Versiegelung prüfen…** im Menü eines versiegelten Dokuments zeigt, für wen sein Inhalt versiegelt ist, ohne ihn zu öffnen: Format und Verschlüsselung, den Schlüssel jedes Empfängers mit der Person, der er gehört (soweit Sie sie sehen dürfen), ob ein Schlüssel widerrufen oder nicht bestätigt ist, und ob der Umschlag noch zum Empfängerkreis passt. Wer den Empfängerkreis verlassen hat, diese Version aber noch öffnen kann, und wen der Umschlag noch nicht nennt, wird aufgeführt; in der Desktop-App versiegelt ein Verwalter dort neu, im Browser, der keinen Schlüssel hat, tut es die Desktop- oder Telefon-App. Jeder Empfänger klappt auf und zeigt, wie der Schlüssel ihn erreicht, und unten steht die ASN.1-Struktur, wie `alcifra inspect` sie ausgibt. In der Desktop-App versucht **Welcher meiner Schlüssel öffnet es?** die Schlüssel auf diesem Computer und danach Ihren Hardware-Schlüssel (mit PIN-Abfrage wie bei jedem Dokument), und **Schlüsseldatei versuchen…** einen Schlüssel, den Sie auswählen; beide sagen, welcher Schlüssel es geöffnet hat, und verwerfen den Inhalt sofort. **Datei prüfen…** im Werkzeugmenü neben dem Hilfesymbol zeigt dasselbe für eine versiegelte Datei auf Ihrem Computer, ohne sie hochzuladen.

**Importieren.** Die Import-Schaltfläche liest auf Ihrem Computer die CSV-Datei, die ein Passwortmanager exportiert: Jede Zeile wird zu einem Eintrag, hier versiegelt. Nachgefragt wird nur bei einer Zeile, deren Name und Benutzername zu einem Eintrag passen, der schon im Ordner liegt – überspringen, als neue Version hinzufügen oder beide behalten. Eine Spalte mit Bestätigungscodes (`totp`, `otpauth` oder ähnlich benannt) wird zum Bestätigungscode des jeweiligen Eintrags. Danach bietet der Desktop an, die Exportdatei zu löschen, weil sie jedes Passwort im Klartext enthält.

Ein Eintrag, auf den Sie im Baum des Tabs **Archive** stossen, zeigt seine Felder schreibgeschützt in der Vorschau, jedes Mal mit Ihrem Schlüssel geöffnet; ihn zu ändern ist Aufgabe des Tabs Passwörter. In der Liste des Tabs **Archive**, auf dem Desktop wie im Web-Client, ist ein Eintrag mit Bestätigungscode als solcher markiert; der Web-Client öffnet nie einen Eintrag, darum zeigt er nur dieses Zeichen. Die Browser-Erweiterung füllt das Codefeld einer Anmeldung mit dem aktuellen Code des Eintrags, den Sie wählen, und das Kommandozeilenwerkzeug gibt ihn ebenfalls aus (siehe unten).

**Auf der Kommandozeile.** `apass` liest dieselben Speicher im Terminal und öffnet jeden Eintrag mit Ihrem Hardware-Schlüssel und dessen PIN, die es nicht behält. Installiert wird es mit `dotnet tool install --global Alcifra.Pass`, angemeldet mit `apass login --url https://ihr.server`. Ein Eintrag wird mit seinem Pfad benannt, wie ihn der Baum zeigt:

```
apass show Mail/webmail             # alle Felder, in der Reihenfolge des Formulars
apass password Mail/webmail         # nur das Passwort
apass otp Mail/webmail              # der aktuelle Code; "valid 17 s" auf der Zeile darunter
apass otp Mail/webmail --code-only  # nur der Code
apass password Mail/webmail -c      # in die Zwischenablage statt auf den Bildschirm
```

Mit `-c` (`--clip`) legen `apass password` und `apass otp` das Geheimnis in die Zwischenablage, statt es auszugeben, und entfernen es nach 45 Sekunden wieder (einen Code, wenn er abläuft) — aber nur, wenn es noch dort liegt; was Sie inzwischen kopiert haben, bleibt.

`apass show` beschriftet jedes Feld wie das Formular und zeigt einen Bestätigungscode als den jetzt gültigen Code, nie seine Einrichtung. `--store` nennt einen gemeinsamen Speicher (Standard ist Meine Passwörter); `apass ls` und `apass find` listen, was es gibt.

Die Tabulatortaste ergänzt Befehle, Speichernamen und Pfade, sobald Ihre Shell das Ergänzungsskript lädt. Für zsh fügen Sie diese Zeile in `~/.zshrc` ein; für bash schreiben Sie `bash` statt `zsh` und fügen sie in `~/.bashrc` ein:

```
eval "$(apass completion zsh)"
```

`apass show Ma` wird dann zu `Mail/` ergänzt, und der nächste Tabulator geht in diesem Ordner weiter. Ohne die Zeile ergänzt die Tabulatortaste stattdessen lokale Dateien. Sind Sie nicht angemeldet, bietet die Ergänzung nichts an.

Die Anmeldung hält, solange Sie arbeiten: Jeder Befehl verlängert sie, nach 15 Minuten ohne Befehl endet sie, und nach 12 Stunden bestätigen Sie in jedem Fall neu. `apass` und `alcifra` teilen sie, und `apass logout` beendet sie.

**Die Browser-Erweiterung.** Die Erweiterung füllt Anmeldungen aus Ihren Speichern aus. Sie steht noch in keinem Browser-Store, Sie laden sie also selbst, in Chrome oder Edge:

1. Öffnen Sie `chrome://extensions` (oder `edge://extensions`), schalten Sie den **Entwicklermodus** ein, wählen Sie **Entpackte Erweiterung laden** und den Ordner `browser-extension/chrome` des Quellcode-Repositorys. Die Kennung der Erweiterung steht auf ihrer Karte.
2. Verbinden Sie sie mit einem Client. Im Desktop-Client öffnen Sie **Browser-Autofill…** im Kontomenü und geben die Kennung ein. Oder im Terminal:

   ```
   apass browser install chrome --extension-id <die Kennung>
   ```
3. Starten Sie den Browser neu.

Die Erweiterung fragt zuerst den Desktop-Client, dann `apass`. Mit `apass` füllt sie nur aus, solange Sie angemeldet sind: Nach 15 Minuten ohne Befehl oder Ausfüllen führen Sie `apass login` erneut aus.

**Lesezeichen im Browser.** Die Browser-Erweiterung hält auch Ihre Lesezeichen aktuell. Beim ersten Abgleich legt sie in Ihren Eigenen Dokumenten eine Datei namens Bookmarks an, und diese Datei erscheint unter den Lesezeichen des Browsers als eigener Ordner. Fügen Sie in diesem Ordner Lesezeichen hinzu, benennen Sie sie um, verschieben oder löschen Sie sie, und die Änderung wird eine halbe Minute später gespeichert; eine Änderung aus einem anderen Browser kommt beim Start des Browsers an und jede Viertelstunde. Die Datei hat das übliche Lesezeichenformat, das jeder Browser importiert, Sie können sie also auch herunterladen und unverändert verwenden.

Ein Team teilt Lesezeichen, indem es eine Bookmarks-Datei in einen gemeinsamen Ordner legt; die Rechte des Ordners entscheiden, wer sie erhält. Dürfen Sie den Ordner nur lesen, wird eine Änderung im Browser beim nächsten Abgleich rückgängig gemacht. Eine geteilte Datei enthält nur Webadressen; eine Skriptadresse (ein Bookmarklet) funktioniert nur in Ihrer eigenen Datei.

Wurde dasselbe Lesezeichen gleichzeitig an zwei Orten geändert, gewinnt die Änderung im Browser, und die andere bleibt in einem Ordner namens Conflicts erhalten. Wenn Sie den Ordner im Browser löschen, sind Ihre Lesezeichen nicht weg: Er kommt beim nächsten Abgleich zurück.

## 7.8 CI/CD-Geheimnisse

Ein **CI/CD-Speicher** bewahrt die Geheimnisse und Variablen Ihrer Build-Pipelines auf, versiegelt für die Hardware-Schlüssel der Personen, die sie lesen dürfen, wie ein Passwortspeicher. Sie legen ihn mit Neu ▸ **CI/CD Store** in einem beliebigen Ordner an; für wen er versiegelt ist, bestimmt seine Zielgruppe, wie bei einem gemeinsamen Passwortspeicher. Sein Inhalt sind **CI/CD-Geheimnisse**, und jedes ist eine Rotationseinheit: die Werte, die sich gemeinsam ändern, etwa ein Signaturzertifikat und sein Passwort, beieinander.

Ein Geheimnis nennt seine **Ziele**, die Repositorys, auf die es gesetzt wird (`github:owner/repository`, oder `github:owner/repository@environment` für eine Umgebung), und enthält beliebig viele Schlüssel. Jeder Schlüssel ist ein **Geheimnis** als Text, eine **Datei**, aufbewahrt als die Bytes, die sie war (etwa eine `.p12`), und base64-kodiert gesendet, oder eine **Variable**, die nicht geheim ist und im Klartext gespeichert wird. In einem CI/CD-Speicher öffnet Neu ▸ **CI/CD Secret** den Editor: die Ziele je eine pro Zeile und eine Zeile pro Schlüssel. Eine Datei kommt aus **Datei wählen…** in ihrer Zeile oder wird irgendwo auf das Fenster gezogen, wo sie zu einem neuen Datei-Schlüssel mit ihrem Namen wird.

Ein ausgewähltes Geheimnis zeigt seine Ziele, Schlüsselnamen und Variablen sofort, ganz ohne Schlüssel. **Mit Schlüssel öffnen** öffnet die Werte einmal mit Ihrem Hardware-Schlüssel: Ein Textwert ist dann nur sichtbar, solange sein Auge gehalten wird, und wird kopiert wie ein Passwort; eine Datei hat **Speichern unter…**, das sie genau so zurückschreibt, wie sie war. Jeder gezeigte, kopierte oder gespeicherte Wert wird mit dem Namen des Schlüssels protokolliert, nie mit dem Wert. **Bearbeiten…** ändert das Geheimnis in einem Schritt und wird abgelehnt, wenn es inzwischen jemand geändert hat.

Auf der Kommandozeile setzt `apass cicd apply <store>` auf jedem Ziel, was fehlt oder veraltet ist: eine PIN für den ganzen Lauf, jeder Wert über die Standardeingabe an das Werkzeug der Plattform übergeben und nie ausgegeben. `apass cicd apply <store> --dry-run` meldet, was es setzen würde, und braucht keinen Schlüssel; `apass cicd show` gibt einen Wert aus oder speichert ihn; `apass cicd set` legt ein Geheimnis an oder ersetzt es.

## 7.9 Auf einem Telefon oder Tablet

Dieselbe Adresse im selben Browser liefert Ihnen ein Layout, das für den Bildschirm in Ihrer Hand gebaut ist. Es gibt keine separate mobile Website und nichts zu installieren – und nichts wird **weggenommen**: Was die schmaleren Layouts nicht nebeneinander zeigen können, zeigen sie nacheinander.

**Ein Tablet wird an seinem Touchscreen erkannt, nicht an seiner Breite.** Diese Unterscheidung ist wichtiger, als sie klingt: Ein grosses Tablet ist hochkant etwa 1024 Punkte breit und quer 1366, die Breite allein würde dasselbe Gerät also in der einen Lage als Tablet und in der anderen als Desktop einstufen. Wenn Sie Ihr Tablet drehen, ändert sich, wie viele Bereiche Sie bekommen, aber nie, für welche Art Gerät das Archiv es hält.

### 7.9.1 Ein Telefon: ein Bereich und ein Weg zurück

Der Ordnerbaum wird zu einer Schublade, der Inhalt des Ordners füllt den Bildschirm, und ein Dokument öffnet sich darüber mit eigenen Tabs **Vorschau**, **Details** und **Chat** – die Bereiche, die das breite Layout weglässt, sind also nur einen Tipp entfernt statt verschwunden.

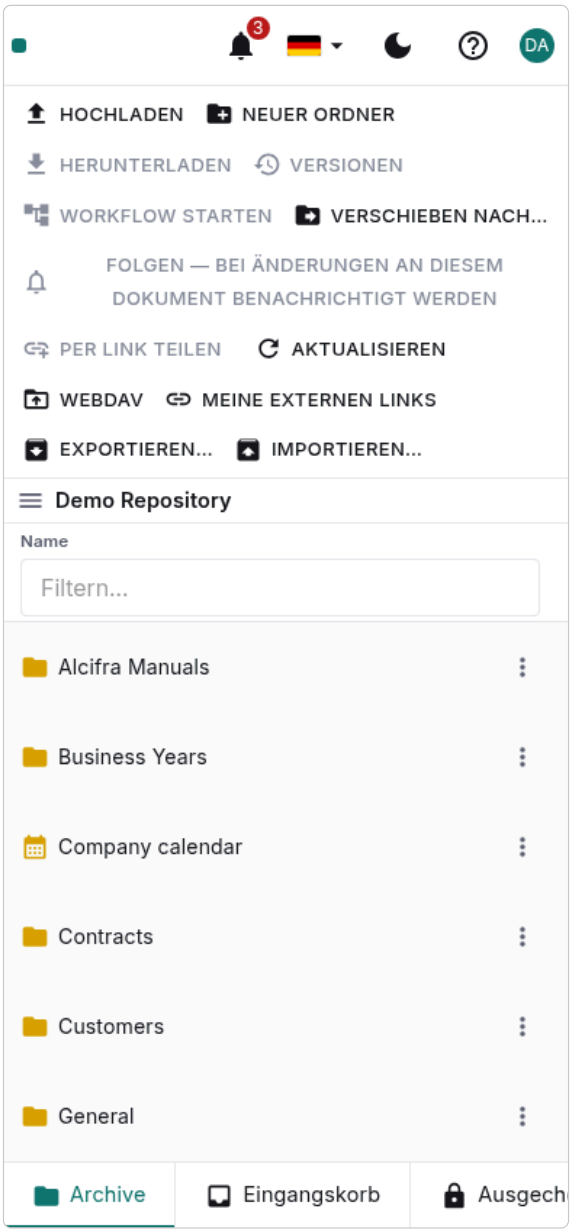



Abbildung 19: Der Inhalt eines Ordners auf einem Telefon, bildschirmfüllend. Ein einfaches Tippen öffnet – einen Doppelklick gibt es hier nicht.

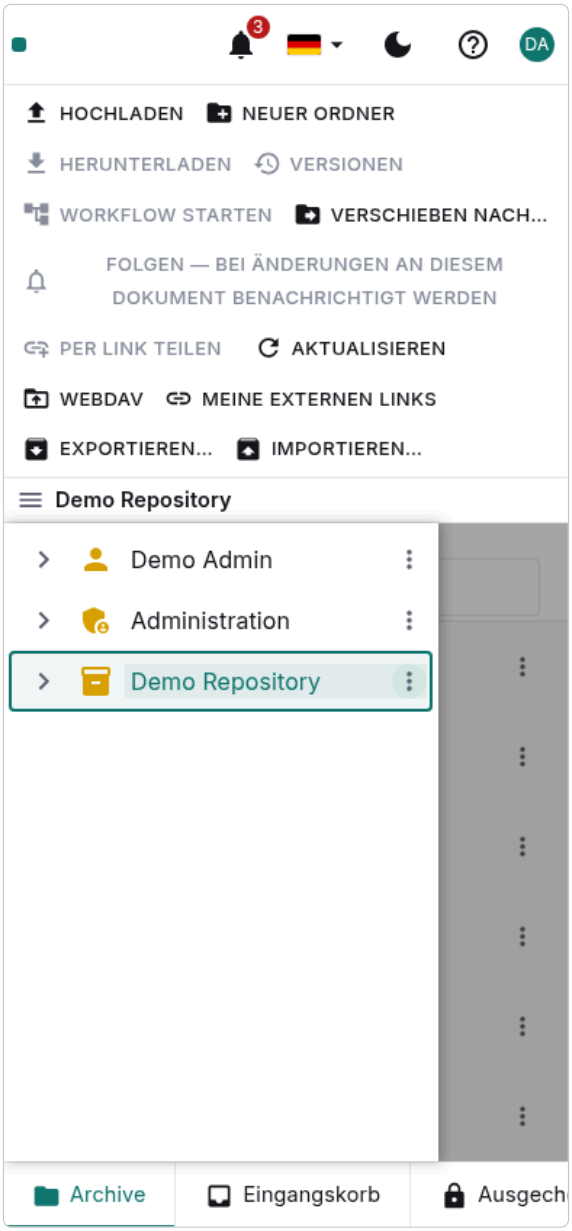



Abbildung 20: Der Baum, von links hereingeschoben. Wählen Sie einen Ordner, schliesst er sich wieder.

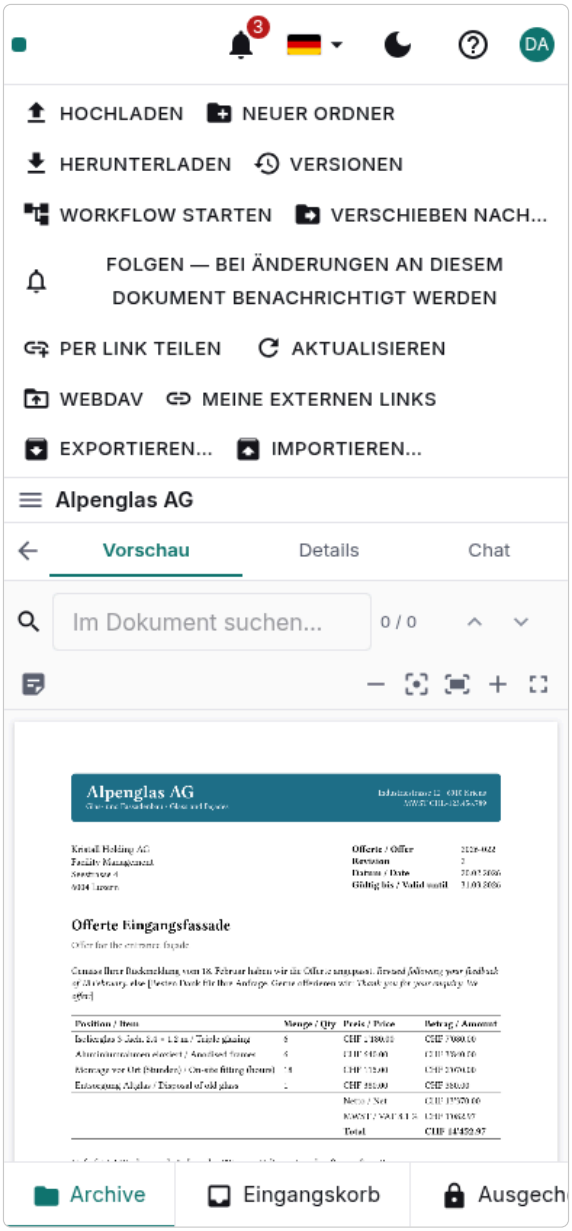



Abbildung 21: Ein Dokument, bildschirmfüllend, mit seinen drei Tabs. Zurück führt zur Liste.

**Auf einem Telefon navigiert ein einfaches Tippen.** Auf einem Desktop wählt ein Klick aus und ein Doppelklick öffnet, weil es einen zweiten Bereich gibt, der die Auswahl zeigt. Auf einem Telefon gibt es keinen, deshalb führt ein Tippen direkt hinein.

### 7.9.2 Ein Tablet: hochkant ein Bereich, quer zwei

Hochkant gehalten verhält sich ein Tablet genau wie ein Telefon – ein Bereich, der Baum in einer Schublade.

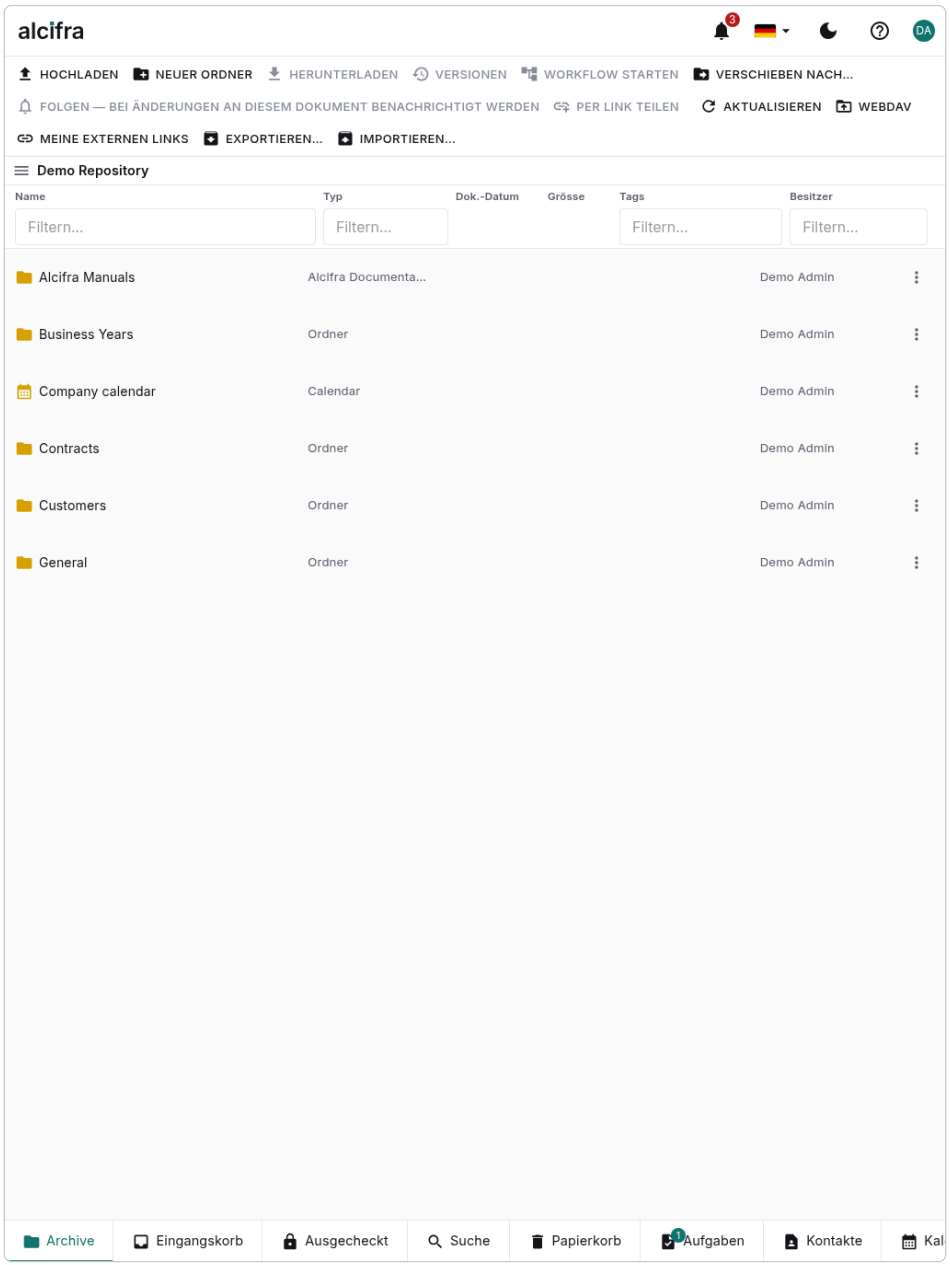



Abbildung 22: Hochkant: jeweils ein Bereich, dieselbe Form wie auf einem Telefon.

Drehen Sie es quer, erhalten Sie zwei der drei Bereiche. Beim Blättern steht der Baum neben dem Inhalt des Ordners.

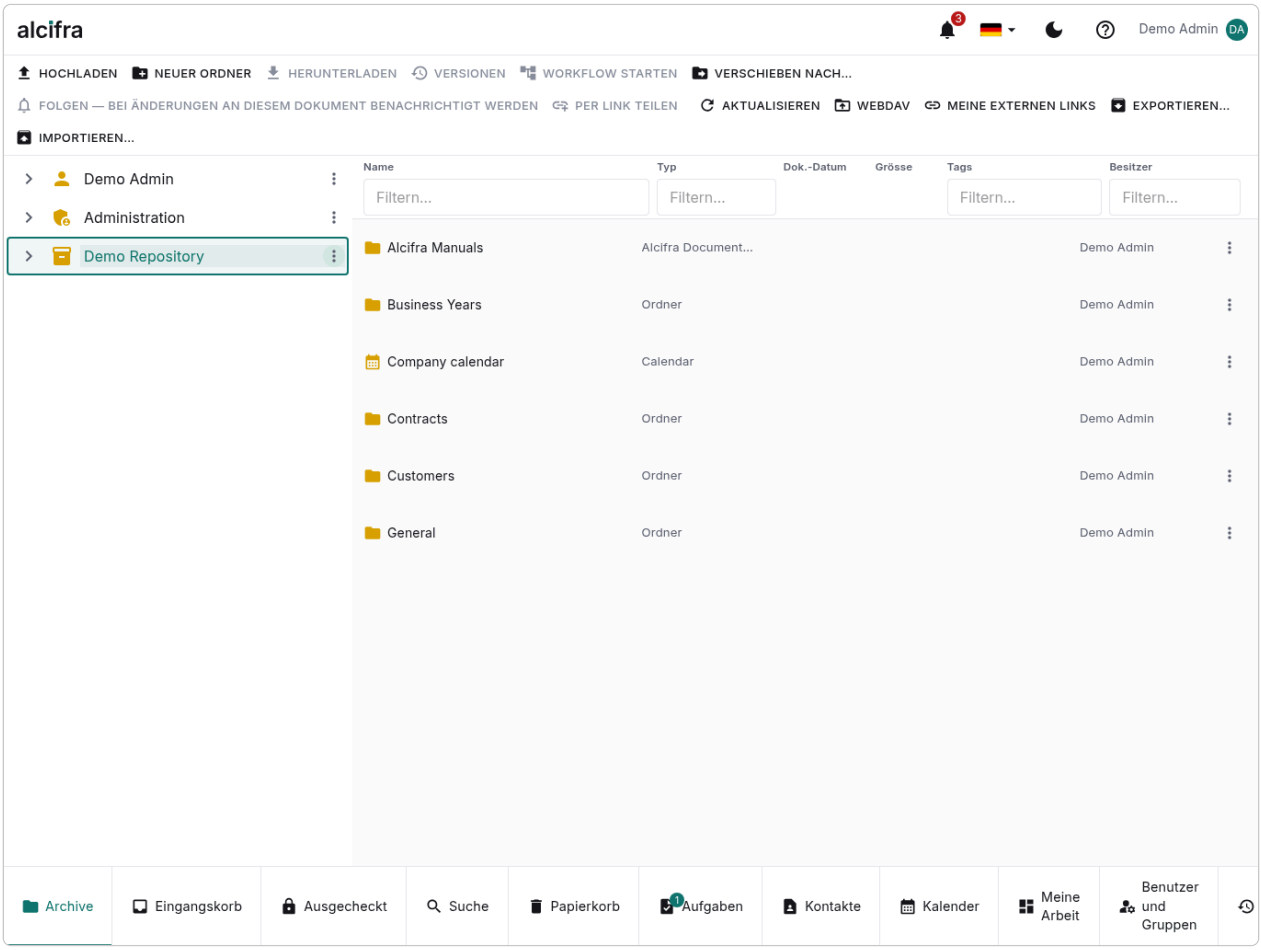



Abbildung 23: Quer, beim Blättern: der Baum neben der Inhaltsliste.

Öffnen Sie ein Dokument, macht der Baum ihm Platz, sodass das, **woher** Sie kamen, neben dem bleibt, was Sie geöffnet haben – und der Baum ist über die Schaltfläche ≡ jederzeit einen Tipp entfernt, wenn Sie ihn zurückhaben möchten.

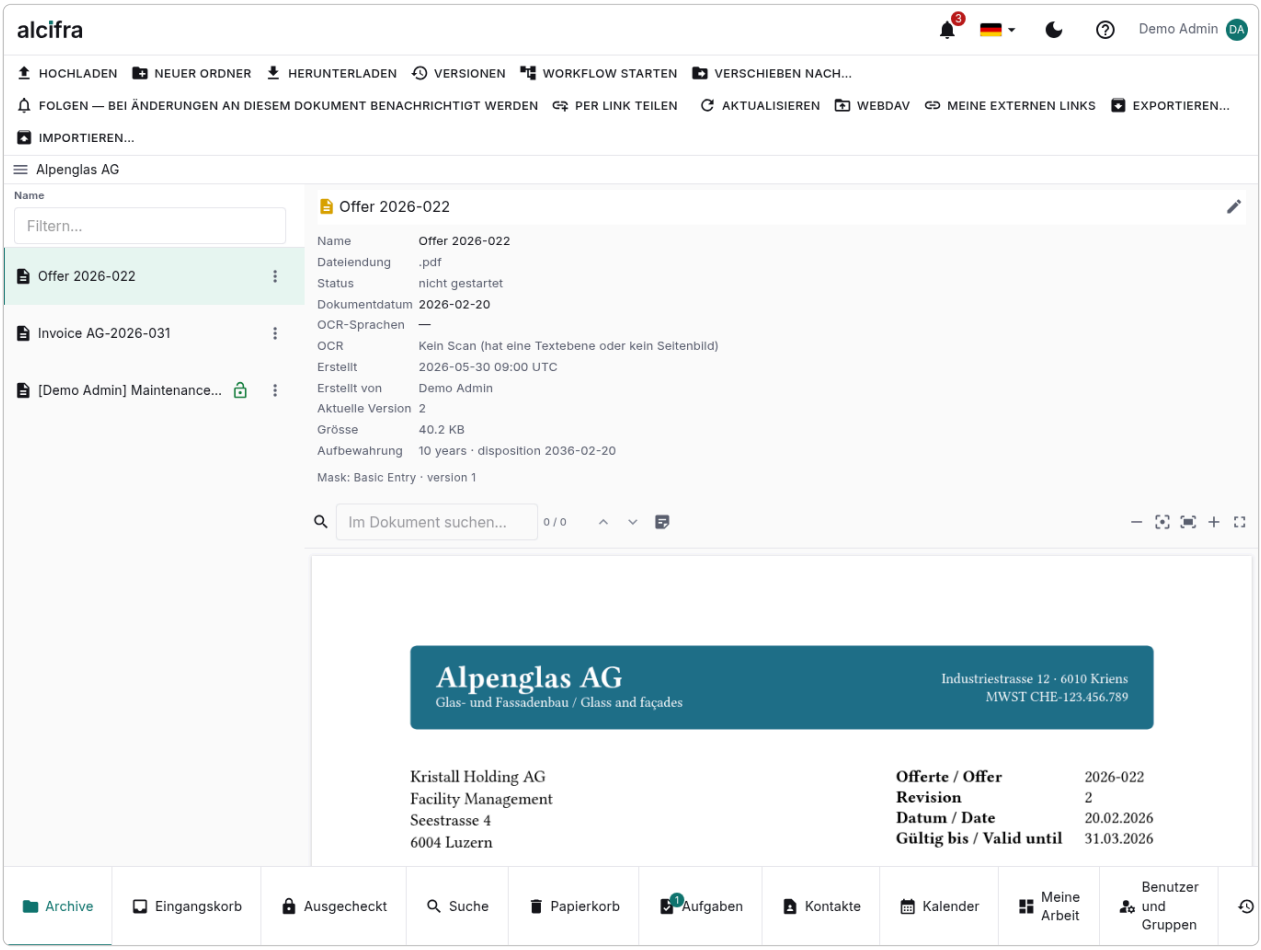



Abbildung 24: Quer, mit geöffnetem Dokument: die Liste neben dem Dokument. Der Baum ist einen Tipp entfernt.

### 7.9.3 Was jede Breite zeigt

| Bildschirm | Was Sie sehen |
|---|---|
| Desktop | Alle vier Bereiche – Baum, Inhalt, Dokument, Kommentare –, in der Grösse veränderbar und pro Browser gespeichert |
| Tablet, quer | Zwei Bereiche: Baum und Inhalt oder Inhalt und Dokument |
| Tablet, hochkant | Ein Bereich, Baum in einer Schublade |
| Telefon | Ein Bereich, Baum in einer Schublade, Dokument bildschirmfüllend |

Der Kommentarbereich verschwindet als erster, wenn der Bildschirm schmaler wird, der Indexdatenbereich als nächster – beide kehren als Tabs in der Dokumentansicht zurück, sodass nichts unerreichbar wird. Es wandert nur.

> **Schaltflächen sind beschriftet, wo Sie nicht mit der Maus darüberfahren können.** Auf einem Desktop ist eine Schaltfläche im Menüband ein Symbol, und ihr Name erscheint beim Darüberfahren. Ein Touchscreen kennt kein Darüberfahren und deshalb keinen Tooltip, also behalten dieselben Schaltflächen ihre Beschriftung – ein unbeschriftetes Symbol, das man nicht befragen kann, ist ein Ratespiel.

Dieses Kapitel handelt vom Archiv **im Browser**. Wie die Mail-, Kontakte-, Kalender- und Dateien-Apps Ihres Geräts ganz ohne Browser auf das Archiv zugreifen, steht in Abschnitt 8.

# 8 Ihr eigenes Gerät

Alles in diesem Kapitel besitzen Sie bereits. Alcifra installiert **nichts** auf Ihrem Telefon, Tablet oder Laptop — das Archiv spricht die Protokolle, die diese Geräte von Haus aus mitbringen, also sind das Mailprogramm, das Adressbuch, der Kalender und der Dateimanager, die Sie schon verwenden, der Client. Es gibt keine App zu suchen, keine Version aktuell zu halten und nichts zu deinstallieren, wenn Sie gehen.

Das heisst auch: Das Archiv gehorcht auf Ihrem Gerät denselben Regeln wie in der Arbeitsoberfläche. Was Sie sehen dürfen, sehen Sie; ein Ordner, auf den Sie keine Rechte haben, ist schlicht nicht da, statt da zu sein und Sie abzuweisen.

## 8.1 Was womit spricht

| Auf Ihrem Gerät | Protokoll | Was Sie bekommen |
|---|---|---|
| Mailprogramm | **IMAP** | Das Archiv als Mailordner — siehe Abschnitt 6.2 |
| Adressbuch | **CardDAV** | Kontakte, in beide Richtungen synchronisiert — siehe Abschnitt 7.3 |
| Kalender | **CalDAV** | Kalender und Ihre Aufgabenfristen — siehe Abschnitt 7.3 |
| Dateimanager | **WebDAV** | Ein einbindbares Laufwerk — siehe Abschnitt 6 |
| Notizen-App | IMAP | Notizen mit echtem Versionsverlauf — siehe Abschnitt 6.2 |
| Browser | — | Die vollständige Arbeitsoberfläche, auf jedem Bildschirm — ausser zum Öffnen verschlüsselter Inhalte, siehe Abschnitt 14.1 |

## 8.2 Ein Passwort für jedes Gerät

Jedes Gerät, das Sie verbinden — ein Telefon, das E-Mail-Programm eines Laptops, der Kalender eines Tablets —, erhält **sein eigenes Passwort**, und keines davon ist Ihr Anmeldepasswort. Öffnen Sie **Geräte…** im Kontomenü:

- **Gerät anmelden…** fragt nach einem Namen («Annas Telefon») und danach, was es erreicht — **E-Mail**, **Dateien**, **Kalender**, **Kontakte**, alle eingeschaltet, solange Sie keines ausschalten. Das Passwort wird **einmal** angezeigt, mit einem QR-Code davon, und daneben jede Serveradresse, jeweils mit einer Schaltfläche **Kopieren**.
- Erreicht das Gerät E-Mail, Kalender oder Kontakte, öffnet ein zweiter QR-Code auf einem Telefon ein **Einrichtungsprofil**: Scannen Sie ihn mit der Kamera, und das Telefon richtet die Konten selbst ein. Der Link funktioniert **einmal, innerhalb von zehn Minuten**, und ist nach Gebrauch weg.
- **Ändern** benennt ein Gerät um oder schaltet ein und aus, was es erreicht; **Widerrufen** trennt dieses Gerät sofort, und nur dieses. **Ein verlorenes Telefon kostet einen Widerruf**: Ihre anderen Geräte und Ihre Anmeldung bleiben, wie sie sind.
- **E-Mail-Inhalt verschlüsseln** versiegelt, was das E-Mail-Programm dieses Geräts abruft, an Ihren eigenen Hardware-Schlüssel, sodass nur ein Gerät, das ihn hält, es lesen kann. Zum Einschalten braucht es einen angemeldeten, attestierten Hardware-Schlüssel; wo Ihre Organisation alle E-Mails versiegelt, ist es eingeschaltet und lässt sich nicht ausschalten. Nicht jedes E-Mail-Programm kann versiegelte E-Mails lesen, was der Dialog neben dem Schalter sagt.

Passwörter, die vor den Geräten ausgestellt wurden — eines für Dateien, Kalender und Kontakte, eines für E-Mail —, erscheinen in der Liste als **Früheres WebDAV-/Kalender-Passwort** und

**Früheres IMAP-Passwort**. Sie funktionieren weiter, bis Sie sie widerrufen; melden Sie Ihre Geräte an und widerrufen Sie sie dann.

## 8.3 Verschlüsselung ist nicht optional

Richten Sie Ihre Geräte auf eine `https://`-Adresse ein, und stellen Sie sicher, dass das Mailkonto **TLS** verwendet (Port 993). Das ist nicht nur gute Praxis — manche Notizen-Clients **verweigern stillschweigend** eine unverschlüsselte Verbindung: Sie fragen den Server, was er unterstützt, mögen die Antwort nicht und legen auf, ohne Ihnen überhaupt etwas anzuzeigen. Ein Server, der aus jeder anderen App einwandfrei funktioniert, kann aus dieser einen defekt wirken, und der Grund erscheint nie auf dem Bildschirm.

> **Wenn ein Gerät sich verbindet, aber nichts anzeigt**, verdächtigen Sie die Verbindung vor dem Konto. Ein falsches Passwort erzeugt eine Fehlermeldung, die Sie lesen können; eine abgewiesene unverschlüsselte Verbindung erzeugt Stille.

## 8.4 Was jedes davon nicht bietet

Die Grenze zu benennen ist das, was verhindert, dass eine funktionierende Funktion defekt wirkt:

- **Ein Mailprogramm zeigt das Archiv, nicht die Anwendung.** Kein Papierkorb, kein Workflow, kein Berechtigungsdialog, keine Suche über Metadaten — all das lebt in der Arbeitsoberfläche.
- **Ein eingebundenes Laufwerk zeigt den Baum, nicht den Verlauf.** Versionen, Kommentare und Indexdaten sind keine Dateien, also erscheinen sie nicht; eine Datei zu überschreiben erzeugt eine neue Version — das einzige Stück Verlauf, das das Laufwerk ausdrücken kann.
- **Kalender und Adressbücher tragen nur ihre eigenen Einträge.** Ein Kalender enthält Termine; er zeigt Ihnen nicht die Dokumente, die daneben abgelegt sind.
- **Aufgabensammlungen sind schreibgeschützt.** Sie sehen, was wartet; das Genehmigen wird in der Arbeitsoberfläche festgehalten, zusammen damit, wer es getan hat und warum.

## 8.5 Auf einem kleinen Bildschirm

Die Arbeitsoberfläche selbst passt sich an, statt Sie auf eine separate mobile Website zu schicken, und sie entscheidet danach, was Sie in der Hand halten, nicht danach, wie breit das Fenster ist — ein Tablet wird an seinem **Touch**-Bildschirm erkannt, sodass es beim Drehen nicht zum Laptop wird.

- **Telefon und hochkant gehaltenes Tablet** — ein Bereich nach dem anderen. Der Ordnerbaum gleitet von links herein, der Ordnerinhalt füllt den Bildschirm, und das Öffnen eines Dokuments überdeckt ihn mit den Tabs **Vorschau**, **Details** und **Chat**. Ein einzelnes Tippen navigiert, statt des Klickens und Doppelklickens am Desktop.
- **Quer gehaltenes Tablet** — zwei Bereiche. Beim Durchblättern steht der Baum neben dem Ordnerinhalt; das Öffnen eines Dokuments tauscht den Baum gegen das Dokument, sodass das, woher Sie kommen, neben dem bleibt, was Sie geöffnet haben. Der Baum ist immer ein Tippen entfernt, über die Schaltfläche ☰.
- **Laptop oder Desktop** — die vollständige Arbeitsoberfläche, mit in der Grösse veränderbaren Bereichen, die sich ihre Breiten merken.

**Was Sie mit einem Dokument tun, steht in seinem Kontextmenü und im Menüband.** Der Detailbereich enthält nur, was zu den Details gehört: den Stift, mit dem Sie sie bearbeiten (Speichern und Abbrechen treten an seine Stelle, solange Sie bearbeiten), die Schlagwörter, die Pfeile, die den Bereich einklappen, und den Stand einer Prüfung. Alles, was Sie **mit** dem Dokument tun — **Folgen**, **Per Link teilen**, **Erinnern**, **Versionen vergleichen**, **Zugriff verwalten**, den nächsten

Schritt einer Prüfung (**Genehmigen**, **Ablehnen**, …) und was immer ein Modul hinzufügt, etwa **Buchungen…** für einen Besprechungsraum — steht im Kontextmenü des Dokuments (ein Rechtsklick am Desktop, das ⋮ am Ende der Zeile im Web) und in der Dokumentgruppe des Menübands, neben Öffnen, Umbenennen und Auschecken. Die Schritte der Prüfung sind unter **Workflow-Schritt** gruppiert, was ein Modul hinzufügt, unter **Aktionen**.

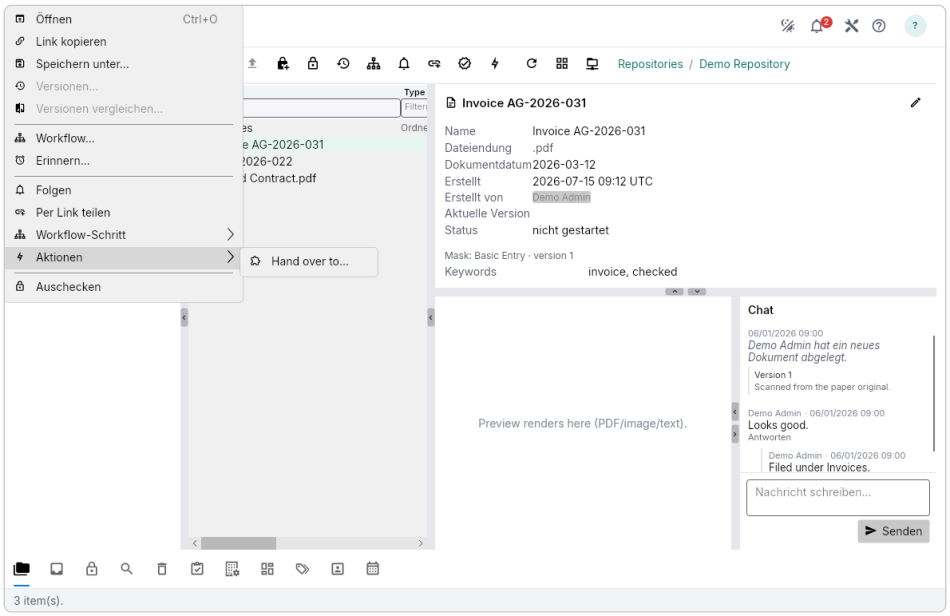



Abbildung 25: Das Kontextmenü eines Dokuments im Desktop-Client: die eigenen Aktionen des Dokuments — Folgen, Per Link teilen — dann **Workflow-Schritt**, die nächsten Schritte einer laufenden Prüfung, und **Aktionen**, was ein Modul für dieses Dokument anbietet.

# 9 Metadaten & Klassifizierung

Jedes Dokument hat eine **Maske** (Dokumenttyp), die seine **Indexfelder** festlegt — typisierte Metadaten wie eine Rechnungsnummer oder ein Datum. Öffnen Sie den Bearbeitungsschalter des **Detail**-Bereichs, um sie auszufüllen. Ein Dokument trägt ausserdem ein **Dokumentdatum** und eine oder mehrere **OCR-Sprachen**, mit denen Scans durchsuchbar gemacht werden. Wo die automatische Erkennung entschieden hat, dass sich die Umwandlung eines Scans nicht lohnt, sagt der Detailbereich, warum. Um das zu übersteuern, checken Sie das Dokument aus: **Durchsuchbar machen** steht im Menüband des Tabs **Ausgecheckt**.

Ein Feld, das auf ein anderes Dokument einer bestimmten Art zeigt, etwa das Vorschaubild eines Videos, wird **ausgewählt**: Tippen Sie einen Teil des Namens, und die Dokumente dieser Art werden mit ihren Bildern aufgelistet. Wo das Feld genau eine Art annimmt, legt **Aus einer Datei…** ein neues neben dem Dokument ab und wählt es aus.

> Indexfelder werden durch die Maske geprüft — ein als Pflichtfeld markiertes Feld muss ausgefüllt sein, und Format- und Bereichsregeln werden beim Speichern durchgesetzt. Bekannte Masken (Folder, Basic Entry, e-Mail) gibt es in jedem Mandanten; Administratoren können weitere hinzufügen.

# 10 Suche

Der Tab **Suche** führt eine Volltextsuche über den **Inhalt**, die **Namen** und die Werte der **Indexfelder** von Dokumenten aus, nach Relevanz sortiert und mit hervorgehobenen Treffern in der Vorschau — so findet ein markantes Wort, das tief im Text eines Dokuments steckt (etwa ein Produktname auf einer Rechnung), genau dieses Dokument. **Verfeinerungsfilter** und **Facetten** grenzen die Ergebnisse ein — nach Dokumenttyp, Datum, Vertraulichkeit und mehr —, und Sie können eine Suche **speichern**, um sie später erneut auszuführen oder zu teilen.

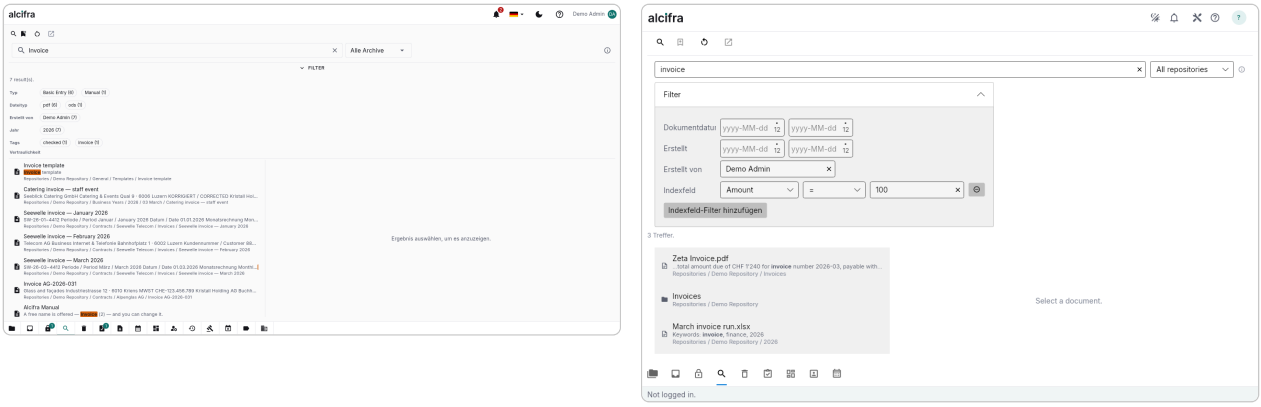



Abbildung 26: Volltextsuche mit Verfeinerungsfiltern und Facetten, im Web-Client (links) und im Desktop-Client (rechts).

**Wortteile.** Die Suche findet zuerst ganze Wörter, was das relevanteste Dokument oben hält. Findet sie damit nichts, wird die Suche wiederholt und sucht Ihren Text **innerhalb** von Wörtern — so findet `montage` ein Dokument, in dem nur `Montagehalterung` steht, und `sechskant` findet das längere zusammengesetzte Wort, das es enthält. Das ist vor allem im Deutschen wichtig, wo ein Wort die Arbeit von mehreren erledigt. Der zweite Versuch ist langsamer und seine Rangfolge flacher, deshalb läuft er nur, wenn der erste gar nichts gefunden hat.

**Was das Feld nicht tut.** Operatoren werden nicht ausgewertet: Anführungszeichen, `AND`, `field:value` und Platzhalter werden bewusst als wörtlicher Text gesucht — eine Abfrage kann nie an einem verirrten Zeichen scheitern. Strukturiertes Eingrenzen — nach Dokumenttyp, Besitzer, Jahr, Schlagwörtern oder einem bestimmten Indexfeld — gehört in die Verfeinerungsfilter neben den Ergebnissen, nicht ins Textfeld.

# 11 Zusammenarbeit

Dokumente sind gemeinschaftlich: Schreiben Sie **Kommentare** in einen Verlauf, bringen Sie **Anmerkungen** (Haftnotizen, Hervorhebungen und Formen) auf der Vorschau an, und **folgen** Sie einem Dokument oder Ordner, um über Aktivitäten **benachrichtigt** zu werden. Setzen Sie sich eine **Erinnerung**, und behalten Sie alles, was Ihnen zugewiesen ist, im Dashboard **Meine Arbeit** im Blick. Um ein Dokument exklusiv zu bearbeiten, **checken Sie es aus** — andere sehen, dass es gesperrt ist —, und **checken** Sie Ihre Änderungen dann als neue Version **ein**.

**Der Chatverlauf.** Jedes Dokument hat seinen eigenen Verlauf, neben der Vorschau angezeigt. Nutzen Sie ihn für das Gespräch über das Dokument — eine Frage zu einer Zahl, ein Hinweis, dass eine Überarbeitung unterwegs ist —, damit diese Diskussion beim Dokument bleibt statt im Postfach von irgendjemandem. Antworten werden unter der Nachricht eingerückt, auf die sie antworten, und der Verlauf hält auch fest, was mit dem Dokument geschehen ist: Eine neue Version, eine Ablage und andere Aktivitäten erscheinen in derselben Zeitleiste, sodass Sie beim Lesen sowohl erfahren, was gesagt wurde, als auch, was sich geändert hat.

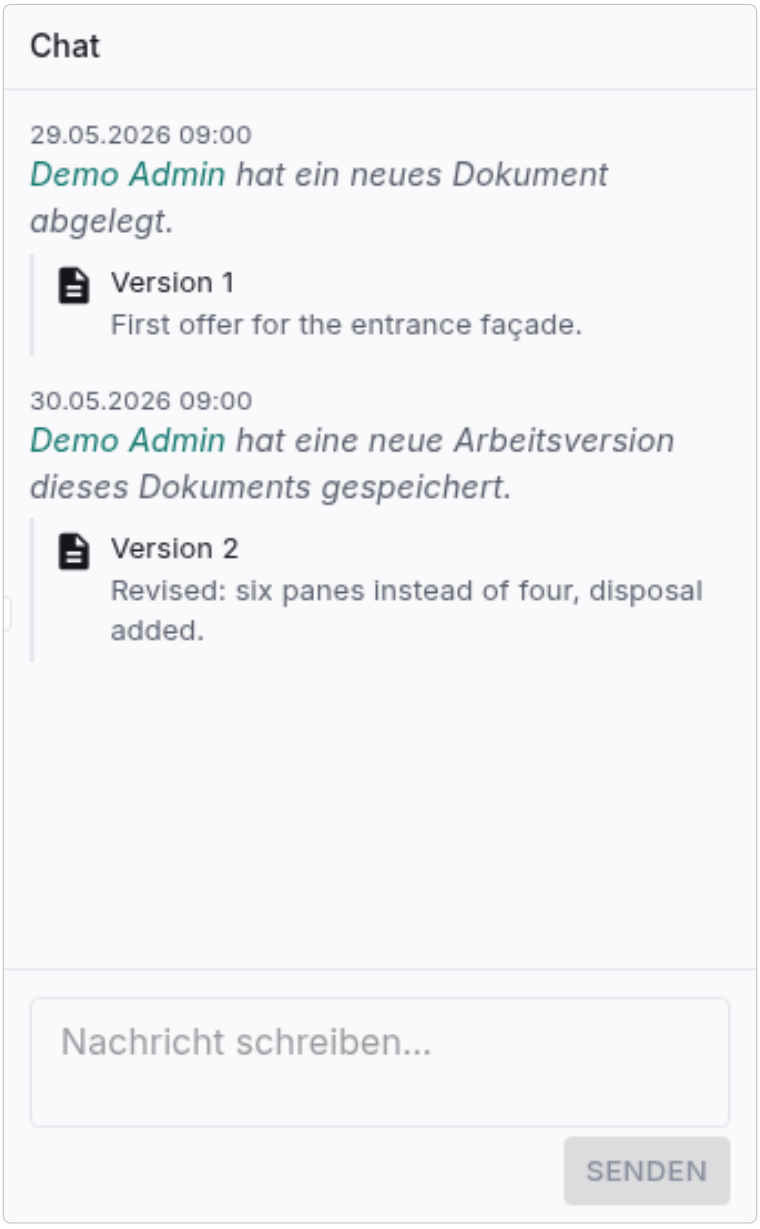



Abbildung 27: Der Chatbereich eines Dokuments: ein Gesprächsverlauf, verwoben mit den Aktivitäten des Dokuments selbst — hier eine Frage und ihre Antwort, gefolgt von den beiden Versionen, wie sie gespeichert wurden.

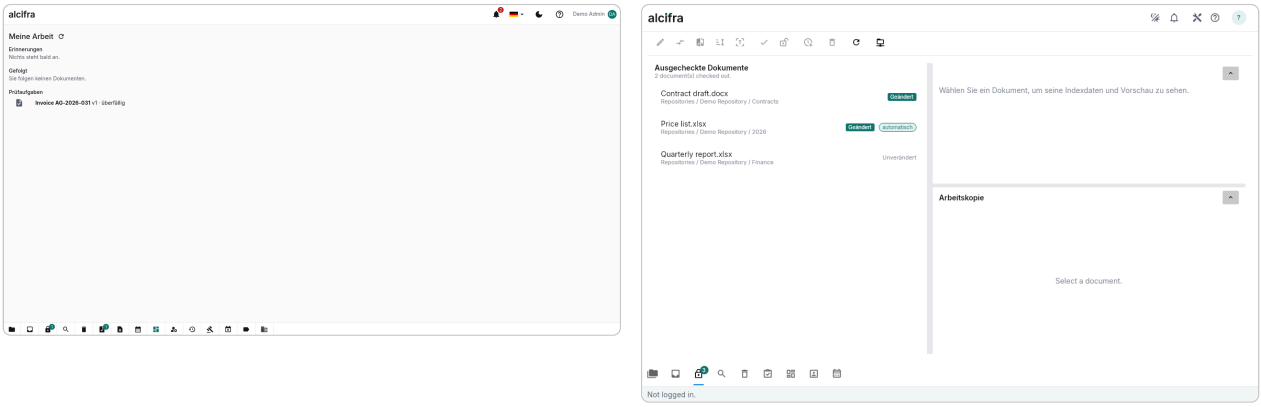



Abbildung 28: Links: das Dashboard **Meine Arbeit**. Rechts: der Tab **Ausgecheckt** mit den für die exklusive Bearbeitung gesperrten Dokumenten — hier eines bearbeitet (*Geändert*) und eines unberührt (*Unverändert*).

**Ihre Bearbeitung sehen, bevor Sie sie festschreiben.** Der Tab **Ausgecheckt** zeigt, was Sie **gleich einchecken werden**, nicht, was bereits archiviert ist. Wählen Sie ein Dokument, das Sie ausgecheckt haben, und der Bereich neben der Liste zeigt seine Indexdaten und eine Vorschau Ihrer **Arbeitskopie** — der Datei, wie Sie sie bearbeitet haben. Das ist die Version, die die Aktion **Einchecken** erzeugen wird, also können Sie sie ansehen, bevor Sie sie festschreiben, ohne den Tab zu verlassen und die archivierte Kopie zu suchen (die Ihnen genau das zeigen würde, was mit Sicherheit nicht Ihre Bearbeitung ist).

Ein Dokument, das Sie bearbeitet haben, ist als **Geändert** markiert, und nur diese bieten die Aktionen an, die für eine Bearbeitung sinnvoll sind:

| Aktion | Was sie tut |
|---|---|
| **Vergleichen** | Eine eingebettete Gegenüberstellung dessen, was sich zwischen der archivierten Version und Ihrer Arbeitskopie geändert hat. |
| **Beyond Compare** | Öffnet dieselben zwei Dateien in Beyond Compare, falls Sie es verwenden — eine Annehmlichkeit nur am Desktop, da ein Browser keine andere Anwendung starten darf. Nicht mit Alcifra verbunden; die Schaltfläche verweist Sie an den Hersteller, wenn Sie es nicht haben. |
| **Einchecken** | Legt Ihre Arbeitskopie als neue Version ab und hebt die Sperre auf. |
| **Verwerfen** | Wirft die Arbeitskopie weg und hebt die Sperre auf; die archivierte Version bleibt unberührt. |

> Wenn Sie noch nichts in Ihre Arbeitskopie gespeichert haben, bleibt die Vorschau leer, statt die archivierte Version zu zeigen. Es gibt tatsächlich nichts in der Vorschau zu zeigen, und dort die archivierte Datei anzuzeigen, würde eine andere Frage beantworten.

# 12 Teilen ausserhalb von Alcifra

Alles oben Beschriebene setzt voraus, dass die andere Person ein Konto hat. Ein **externer Link** ist für den Fall, dass sie keines hat: eine einfache URL, die ein einziges Dokument öffnet, für jeden, der sie hat, ohne Anmeldung. Verwenden Sie ihn für die Kundin, die den unterschriebenen Vertrag braucht, oder den Revisor, der eine einzige Rechnung braucht — nicht als allgemeinen Weg, Dokumente herumzuschieben.

**Einen erstellen.** Wählen Sie das Dokument und dann **Per Link teilen** — im Kontextmenü oder im Menüband. Legen Sie fest, wann er ablaufen soll und wie oft er geöffnet werden darf, und erstellen Sie ihn.

> **Die URL wird einmal angezeigt, beim Erstellen, und danach nie wieder.** Kopieren Sie sie, bevor Sie den Dialog schliessen. Sie erscheint danach in keiner Liste — mit Absicht, denn eine Liste wird viel breiter und viel beiläufiger gelesen als der Moment, in dem Sie bewusst etwas erstellt haben.

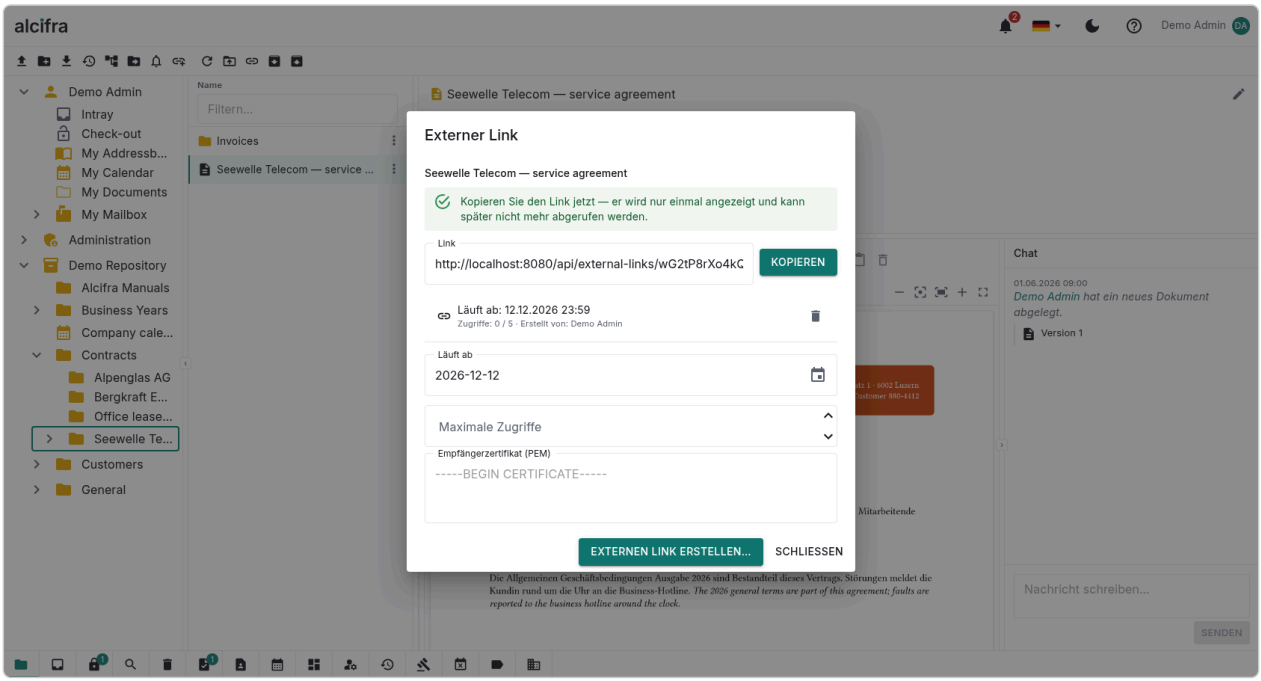



Abbildung 29: Einen externen Link erstellen. Die URL wird einmal, hier, angezeigt und kann später nicht mehr abgerufen werden.

**Verwalten, was Sie geteilt haben. Meine externen Links** im Menüband listet Ihre aktiven Links auf: welches Dokument, wann er abläuft, wie oft er geöffnet wurde. Von einer Zeile aus können Sie zum Dokument springen, die Details eines Links ansehen oder ihn **widerrufen**. Ein Administrator sieht die Links aller, gefiltert nach Benutzer oder Gruppe.

Ein Link kurz vor seinem Ablauf kann **verlängert** werden — aber nur innerhalb von 30 Tagen vor dem Ablauf, um höchstens 90 Tage, und gemessen ab heute, statt zur verbleibenden Zeit addiert. So ist eine Verlängerung eine bewusste Erneuerung und kein Weg, einen unbefristeten Link anzusammeln.

> **Widerrufen löscht die Zeile nicht.** Es markiert sie als widerrufen und lässt den Eintrag stehen — wer was geteilt hat, mit Wirkung ab wann. Nachdem ein Link durchgesickert ist, ist genau

dieser Eintrag das, was die Untersuchung braucht, und er wäre verschwunden, wenn das Widerrufen ihn wegräumen würde.

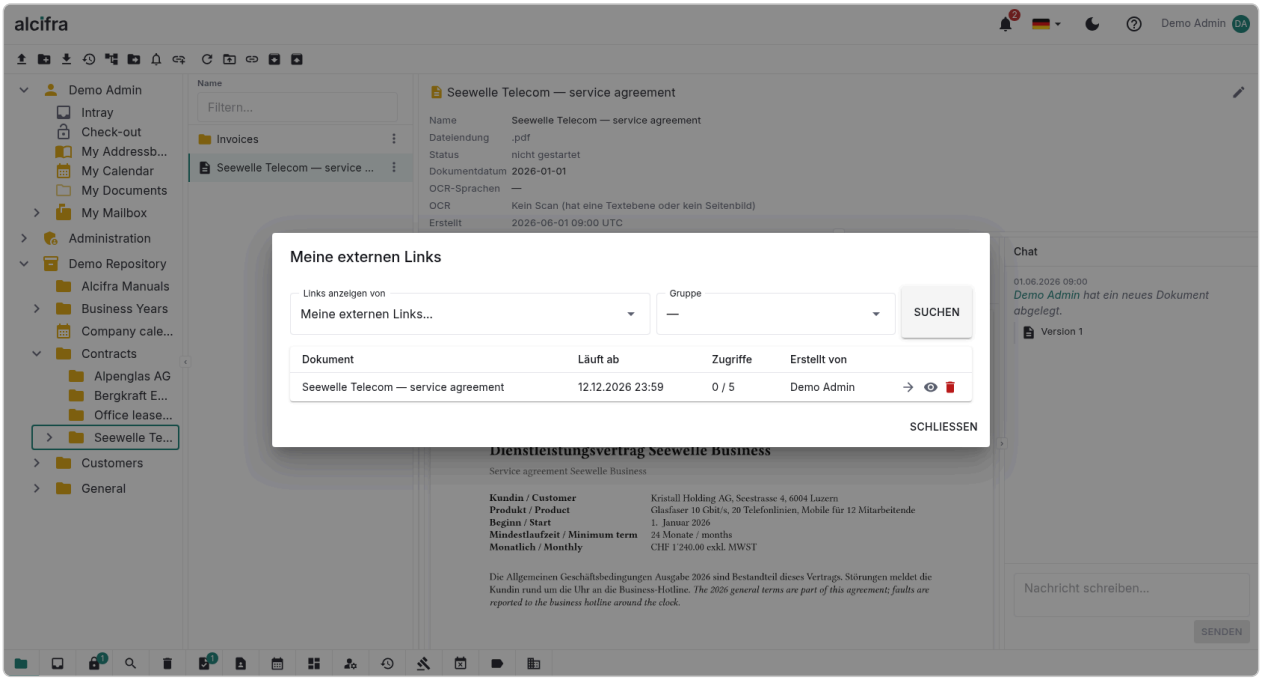



Abbildung 30: **Meine externen Links** — jeder aktive Link, den Sie geteilt haben, mit Springen, Details und Widerrufen in jeder Zeile.

**Was der Empfänger sieht.** Eine einzige Seite mit dem Namen des Dokuments, einem Bild seiner ersten Seite und Schaltflächen zum Öffnen oder Herunterladen — wobei die Seitenzahl auf dem Bild vermerkt ist, wenn es mehr als eine gibt, damit er weiss, was er gleich öffnet. Sonst nichts: kein Baum, keine Navigation, kein Weg zu irgendeinem anderen Dokument.

Das Bild wird beim Erstellen des Links gezeichnet, nicht wenn der Empfänger ihn öffnet, also muss niemand warten. Ein Dokument, von dem sich kein Bild zeichnen lässt — ein Archiv, eine Binärdatei —, zeigt einfach seinen Namen und die Schaltflächen.

Ein unbekannter, abgelaufener, aufgebrauchter oder widerrufener Link erzeugen alle **dieselbe** Antwort. Das ist Absicht — einem Fremden zu sagen, welchen dieser Fälle er getroffen hat, würde bestätigen, dass ein echter Link existiert, und andeuten, wie man an einen brauchbaren kommt.

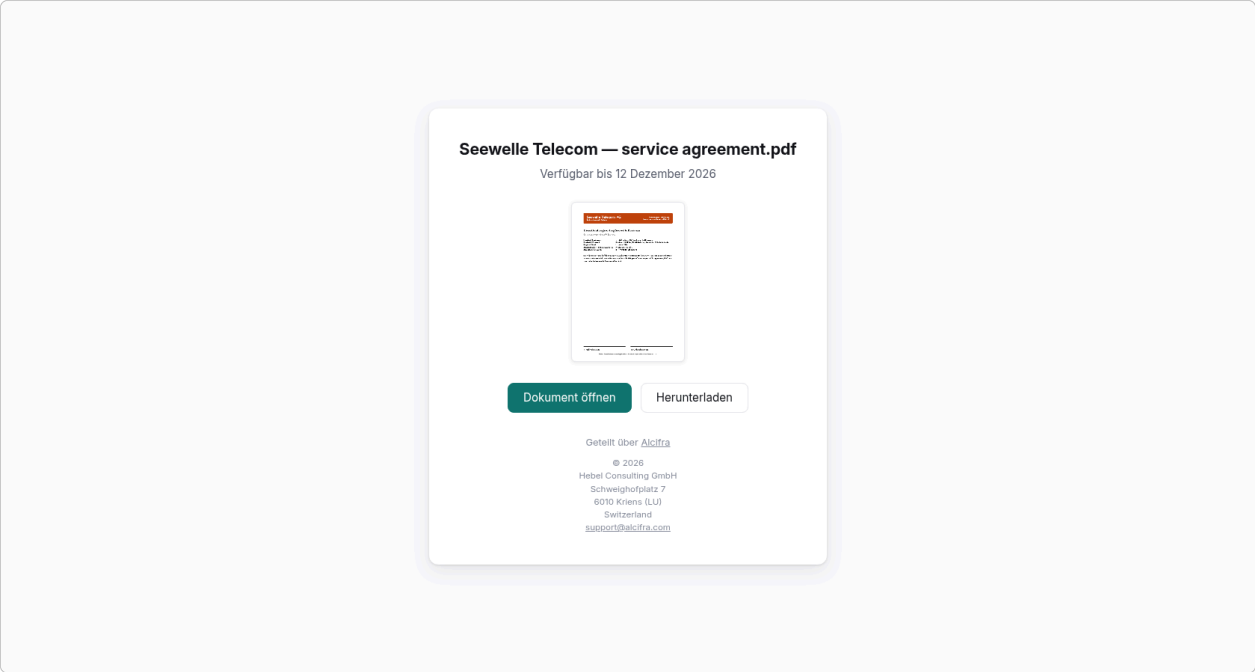



Abbildung 31: Die Ansicht des Empfängers: der Name des Dokuments und ein Bild seiner ersten Seite. Dieses hat nur eine Seite und trägt daher keine Seitenzahl-Markierung. Kein Konto, ein Dokument, nichts anderes von dort aus erreichbar.

## 12.1 An einen namentlich bestimmten Empfänger teilen

Ein externer Link ist von seiner Bauart her offen: Wer die URL hat, kann das Dokument öffnen. Wenn das zu viel ist, kann der Link stattdessen **an ein Zertifikat adressiert** werden — und dann kann nur der Inhaber des passenden privaten Schlüssels lesen, was er ausliefert.

**So gehen Sie vor.** Fügen Sie im Erstellungsdialog das Zertifikat des Empfängers (seine `.pem`- oder `.crt`-Datei — nur das Zertifikat, niemals einen privaten Schlüssel) in das Zertifikatsfeld ein, bevor Sie den Link erstellen. Der Dialog liest es und zeigt Ihnen den gefundenen **Antragsteller** und den **Fingerabdruck** an.

> **Prüfen Sie Antragsteller und Fingerabdruck, bevor Sie den Link senden.** Sie sind Ihre einzige Bestätigung, dass das Zertifikat das gemeinte ist, und ein Dokument an den falschen Schlüssel zu adressieren lässt sich nicht rückgängig machen: Die Person, die Sie meinten, wird es nicht öffnen können, und wer den tatsächlich verwendeten Schlüssel hat, schon. Die Abhilfe ist, den Link zu widerrufen und einen neuen zu erstellen — ein bestehender Link kann nicht neu adressiert werden.

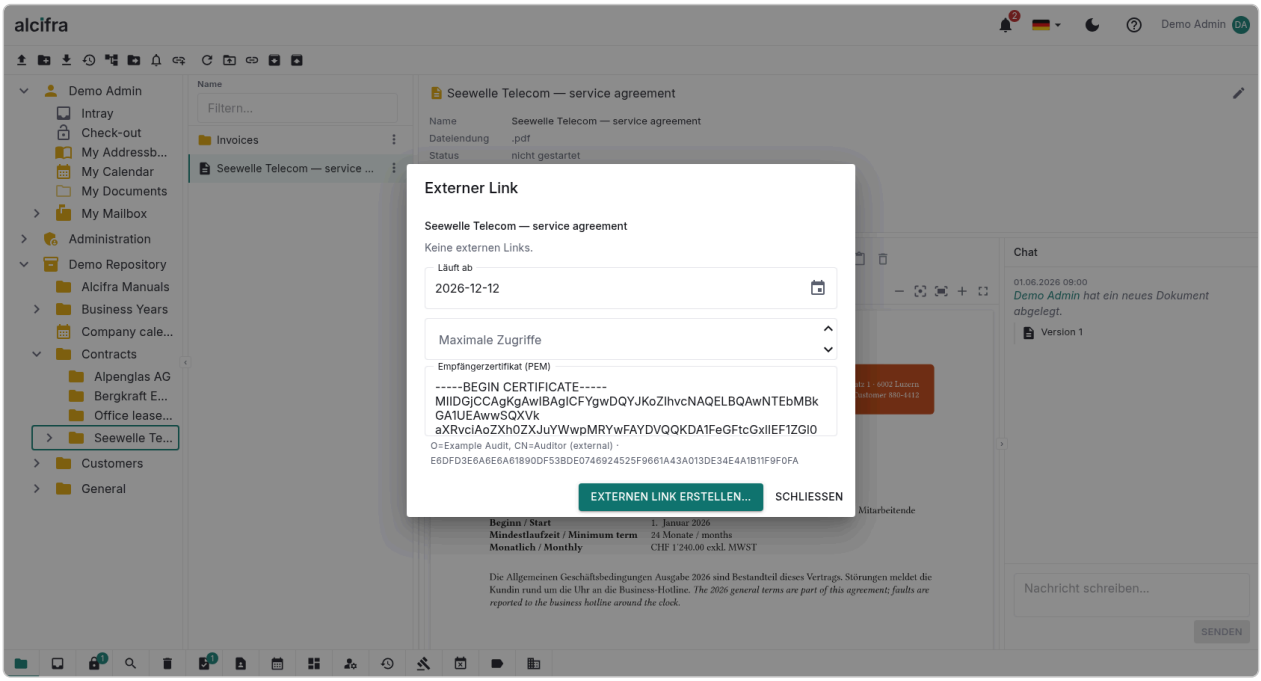



Abbildung 32: Einen Link an einen Empfänger adressieren: Das eingefügte Zertifikat wird mit Antragsteller und Fingerabdruck beschrieben — das ist es, was Sie vor dem Senden der URL prüfen.

**Was der Empfänger bekommt.** Die Landeseite sieht gleich aus, aber der Download liefert ihm eine `.p7m` — das Dokument in einem verschlüsselten Umschlag, adressiert an sein Zertifikat. Mailsoftware, die S/MIME beherrscht, öffnet sie mit seinem eigenen Schlüssel; ein Browser oder Dateimanager kann das nicht und speichert einfach eine Datei, die er mit dem richtigen Programm öffnen muss. Sagen Sie ihm, dass er damit rechnen soll, denn eine `.p7m`, vor der niemand gewarnt hat, sieht aus wie ein fehlerhafter Download.

**Wo das Archiv selbst verschlüsselt ist, ist dies der einzige Weg, nach aussen zu teilen.** Auf einer solchen Installation liefert das Archiv überhaupt keine lesbaren Inhalte aus, also wäre ein Link ohne Empfänger einer, den es nie erfüllen könnte — und der Dialog **verweigert das Erstellen**, statt Sie eine URL senden zu lassen, die beim Öffnen scheitert. Das Zertifikat ist dort keine Option, sondern die Voraussetzung. Zwei kleinere Unterschiede folgen aus derselben Ursache: Die Seite des Empfängers trägt **kein Bild der ersten Seite** (das Bild ist ebenfalls Inhalt), und **Dokument öffnen** hat nichts eingebettet anzuzeigen, also ist das Herunterladen des Umschlags alles, was der Link tut.

## 12.2 Die Steuerungen, die ein Administrator in der Hand hat

Nach aussen zu teilen ist die eine Aktion, die das System verlässt, deshalb ist sie doppelt abgesichert und kann mit einem einzigen Handgriff gestoppt werden.

- **Zwei Schranken beim Erstellen eines Links.** Der mandantenweite Schalter **Externe Links zulassen** muss eingeschaltet sein, und die einzelne Person braucht das Recht **Externen Link erstellen**, vergeben pro Benutzer oder Gruppe unter **Benutzer und Gruppen**. Jede der beiden allein genügt, um das Teilen zu verhindern; beide müssen vorhanden sein, um es zu erlauben. Ein Dienstkonto kann nie einen erstellen — nur ein Mensch teilt, also gibt es immer jemanden, der für die Existenz eines Links verantwortlich ist.
- **Der Notschalter.** Ob **Externe Links zulassen** ausgeschaltet ist, wird geprüft, wenn ein Link **geöffnet** wird, nicht nur, wenn einer erstellt wird — so stoppt er jeden Link, der bereits draussen in der Welt ist, nicht bloss künftige. Das ist die Steuerung, zu der Sie greifen, wenn etwas durchgesickert ist, und es lohnt sich, sie zu kennen, bevor Sie sie brauchen.
- **Die Obergrenzen, die Sie setzen. Maximale Link-Laufzeit** (Standard 180 Tage) und **Standardmässige maximale Zugriffe** (Standard 5) sind die Leitplanken, innerhalb derer sich alle anderen bewegen. Verschärfen Sie sie gemäss Ihren eigenen Richtlinien, statt sich darauf zu verlassen, dass alle gut wählen.

# 13 Workflow & Schriftgutverwaltung

**Genehmigungs-Workflow.** Reichen Sie ein Dokument zur Prüfung ein, und es durchläuft einen festen Zustandsautomaten — Entwurf → In Prüfung → Genehmigt / Abgelehnt → Freigegeben. Der Detailbereich sagt, in welchem Zustand sich ein Dokument befindet; der nächste Schritt, den Sie gehen dürfen — genehmigen, ablehnen, neu zuweisen, freigeben —, steht unter **Workflow-Schritt** in seinem Kontextmenü und im Menüband. Prüfende handeln in ihrem Tab **Aufgaben** — sortierbar nach jeder Spalte (ein Klick auf eine Spaltenüberschrift; standardmässig steht die nächste Frist oben, Überfälliges in Rot zuerst) und eingrenzbar über die sichtbare Filterzeile: Dokument- und Versionstext sowie ein Schalter **Nur überfällige**. Prüfungen können neu zugewiesen werden, und überfällige Prüfungen eskalieren.

**Schriftgutverwaltung.** Eine **gesetzliche Sperre** friert Dokumente ein, sodass sie weder geändert noch gelöscht werden können. **Aufbewahrungsrichtlinien** sondern Dokumente aus, sobald ihre Aufbewahrungsfrist endet (mit Prüfung vor der Aussonderung, falls verlangt). Gelöschte Dokumente liegen im **Papierkorb**, aus dem ein Administrator sie wiederherstellen oder endgültig löschen kann.

Am Desktop erscheint die Zahl der auf Sie wartenden Aufgaben auch auf dem Anwendungssymbol selbst — als Kennzeichen im macOS-Dock, als Überlagerung in der Windows-Taskleiste —, sodass Ihnen auch ein minimiertes Fenster noch sagt, dass etwas zu tun ist.

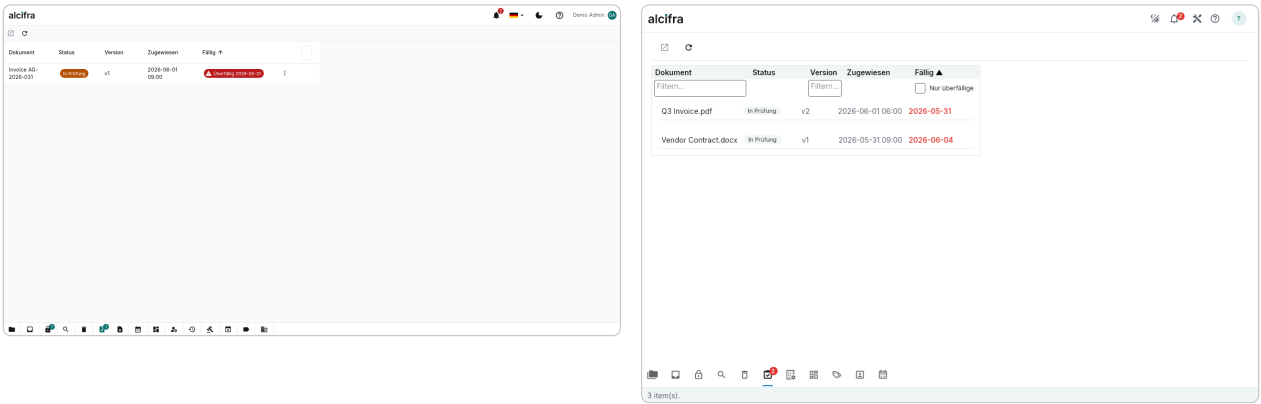



Abbildung 33: Der Tab Aufgaben — die Genehmigungswarteschlange einer prüfenden Person — im Web-Client (links) und im Desktop-Client (rechts).

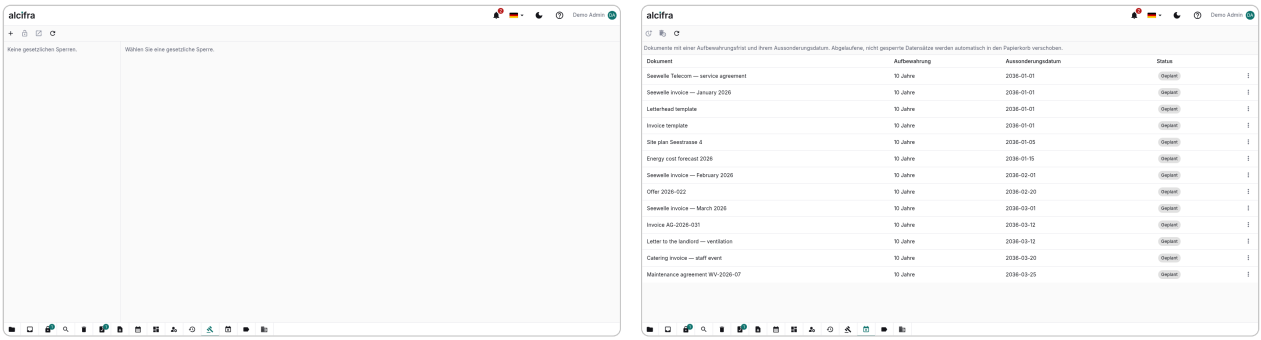



Abbildung 34: Schriftgutverwaltung: **Rechtliche Sperren** (links) frieren Dokumente ein; die **Aufbewahrung** (rechts) regelt die Aussonderung.

# 14 Administration & Konto

Administratoren verwalten **Benutzer und Gruppen** und die ihnen erteilten **Rechte**, konfigurieren die Einstellungen des **Mandanten** und prüfen das manipulationssichere **Audit-Protokoll**. Sie pflegen ausserdem Kataloge (Vertraulichkeitsstufen, Schlagwörter), legen das **Speicherkontingent** fest und führen **Import / Export** durch. Jeder Benutzer verwaltet die **Sicherheit seines eigenen Kontos** — Passwort, Mehr-Faktor-Authentifizierung (Authenticator-App oder Passkeys) und Profilbild.

Ihr eigenes Konto erreichen Sie über **Profil bearbeiten…** im Avatar-Menü (oben rechts in beiden Clients). Es zeigt, mit welchem Konto Sie angemeldet sind, Ihr aktuelles Profilbild samt Zuschnitt, um es zu ersetzen, und eine Schaltfläche, die zum Ändern Ihres Passworts führt. Zwei-Faktor-Authentifizierung, Passkeys und Ihre Geräte bleiben eigene Einträge in diesem Menü, da jedes davon ein separates Anmeldemerkmal ist und nicht Teil Ihres Profils.

Eines sollten Sie vom Authenticator-Code erwarten: Er ist **nur einmal verwendbar**. Ein sechsstelliger Code wird einmal akzeptiert und danach für den Rest der halben Minute abgelehnt, während der er noch angezeigt wird. Genau das bedeutet «Einmalpasswort», und es verhindert, dass ein Code, der Ihnen über die Schulter abgelesen wurde — oder von einer Seite weitergereicht, die sich als diese ausgibt —, hinter Ihrem Rücken erneut verwendet wird. Wenn Sie sich eben mit dem angezeigten Code irgendwo angemeldet haben, warten Sie auf den nächsten, statt ihn nochmals einzutippen.

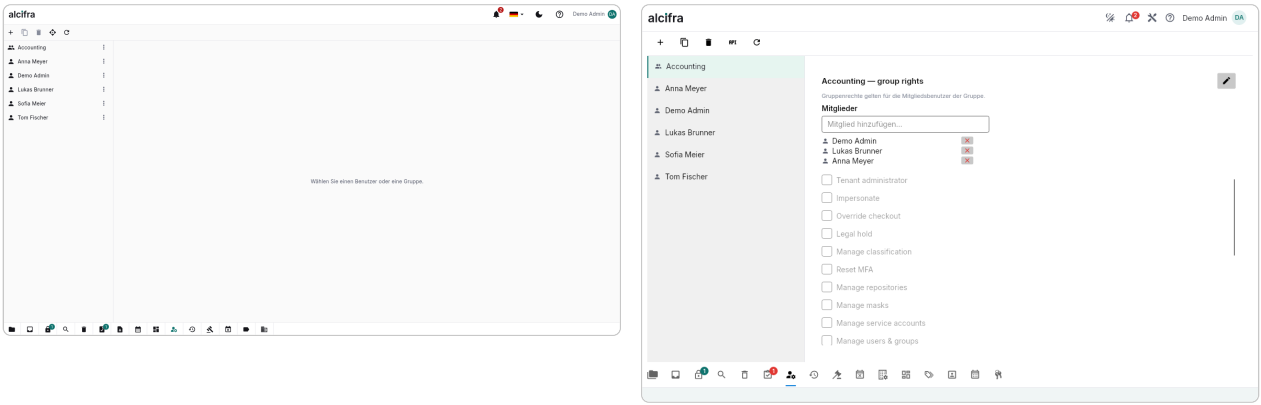



Abbildung 35: Verwaltung von Benutzern und Gruppen im Web-Client (links) und im Desktop-Client (rechts).

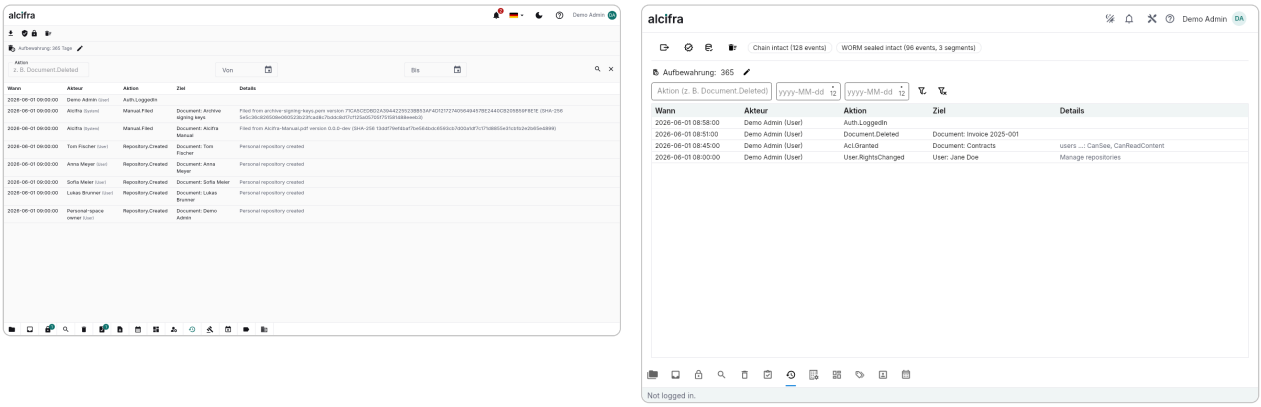



Abbildung 36: Das Audit-Protokoll — ein nur fortschreibbares, hash-verkettetes Log — im Web-Client (links) und im Desktop-Client (rechts).

Was in dieses Protokoll gelangt, verdient eine genaue Beschreibung, denn ein Audit-Protokoll lesen Menschen, die entscheiden, ob etwas geschehen ist — und ein Protokoll, von dem

man glaubt, es enthalte alles, prüft niemand nach. Es verzeichnet **Anmelde- und Kontoereignisse** (Anmelden, Abmelden, ein abgelehntes Anmeldemerkmal, ein nach wiederholten Versuchen gesperrtes Konto), **Dokumentvorgänge** (Ablegen, Versionieren, Verschieben, Löschen, Wiederherstellen, Rechteänderungen, Legal Holds, Aussonderung), **Administration** (Benutzer, Gruppen, Mandanteneinstellungen, Dienstkonten, Zertifikatsregistrierung) und die **bewusst gefährlichen** Vorgänge — Impersonation, endgültiges Löschen, Rotation und Stilllegung von Verschlüsselungsschlüsseln.

Es ist **keine** Aufzeichnung buchstäblich jedes Schreibvorgangs. Eine kleine, benannte und schrumpfende Menge von Operationen ändert noch immer Daten, ohne einen Eintrag zu hinterlassen — vor allem einige Unterelemente von Dokumenten, etwa das Bearbeiten von Terminen und Kontakten —, und das Projekt führt diese Menge ausdrücklich, statt eine Abdeckung zu behaupten, die es nicht hat. Wenn das Fehlen eines Eintrags für Sie ein Beweis wäre, vergewissern Sie sich, dass der Vorgang, um den es Ihnen geht, zu den aufgezeichneten Arten gehört, statt anzunehmen, dass Schweigen bedeutet, er habe nicht stattgefunden.

Eine abgelehnte Anmeldung und eine Sperrung werden erst seit Kurzem aufgezeichnet. Vorher enthielt das Protokoll nur erfolgreiche Anmeldungen, sodass man sehen konnte, dass jemand **hineingekommen** war, nicht aber, dass es jemand eine Stunde lang versucht hatte — und das ist die Frage, die eine Untersuchung tatsächlich stellt.

Zu den Mandanteneinstellungen gehört das Konto, über das Ihre Benachrichtigungen **versandt werden**. Die meisten Installationen betreiben kein eigenes Mail-Relay und authentifizieren sich bei einem gewöhnlichen Anbieter — und ein solches Konto gehört naturgemäss zum einzelnen Mandanten, denn die E-Mails jedes Mandanten sollen von dessen eigener Domain kommen. Tragen Sie einen Server ein, erscheinen dazu Port, Verschlüsselung, Benutzername, Passwort und Absenderadresse; lassen Sie den Server leer, wird das eigene Konto der Installation verwendet — so wie es jede bestehende Installation weiterhin tut.

Das Passwort kann nur geschrieben werden. Kein Bildschirm zeigt es Ihnen je wieder an: Der Bereich sagt, ob eines hinterlegt ist, und ein leeres Feld beim Speichern bedeutet **das vorhandene behalten**, nicht **löschen**, damit eine Änderung des Ports nicht stillschweigend das Anmeldemerkmal entfernt. **Testnachricht senden** wird angeboten, ob dieser Mandant ein eigenes Konto hat oder nicht — ohne eigenes prüft es das der Installation, das Ihre E-Mails dann tatsächlich verwenden würden. Sinn der Sache ist, dass der Fehler vor jemandem auftritt, der ihn beheben kann, und nicht um drei Uhr morgens in einer Erinnerung, die niemand erhält.

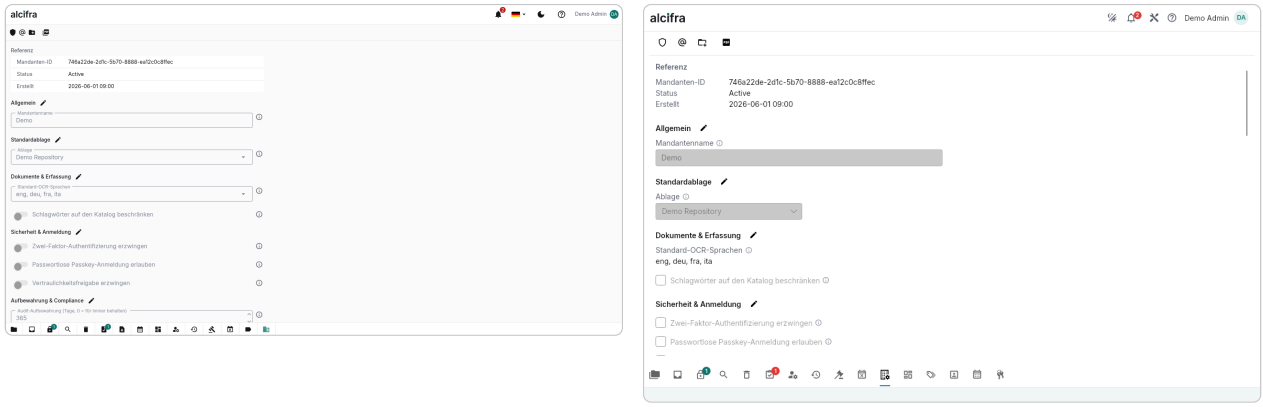



Abbildung 37: Mandanteneinstellungen im Web-Client (links) und im Desktop-Client (rechts).

Der Desktop-Client kann sich mit **mehreren Servern** verbinden; seine Server-Verwaltung speichert für jeden ein Profil (Name + Adresse). Ein Server ist kein Mandant: Eine Installation von Alcifra beherbergt viele Mandanten, und zu welchem Mandanten Sie gehören, ergibt sich aus dem Konto, mit dem Sie sich anmelden.

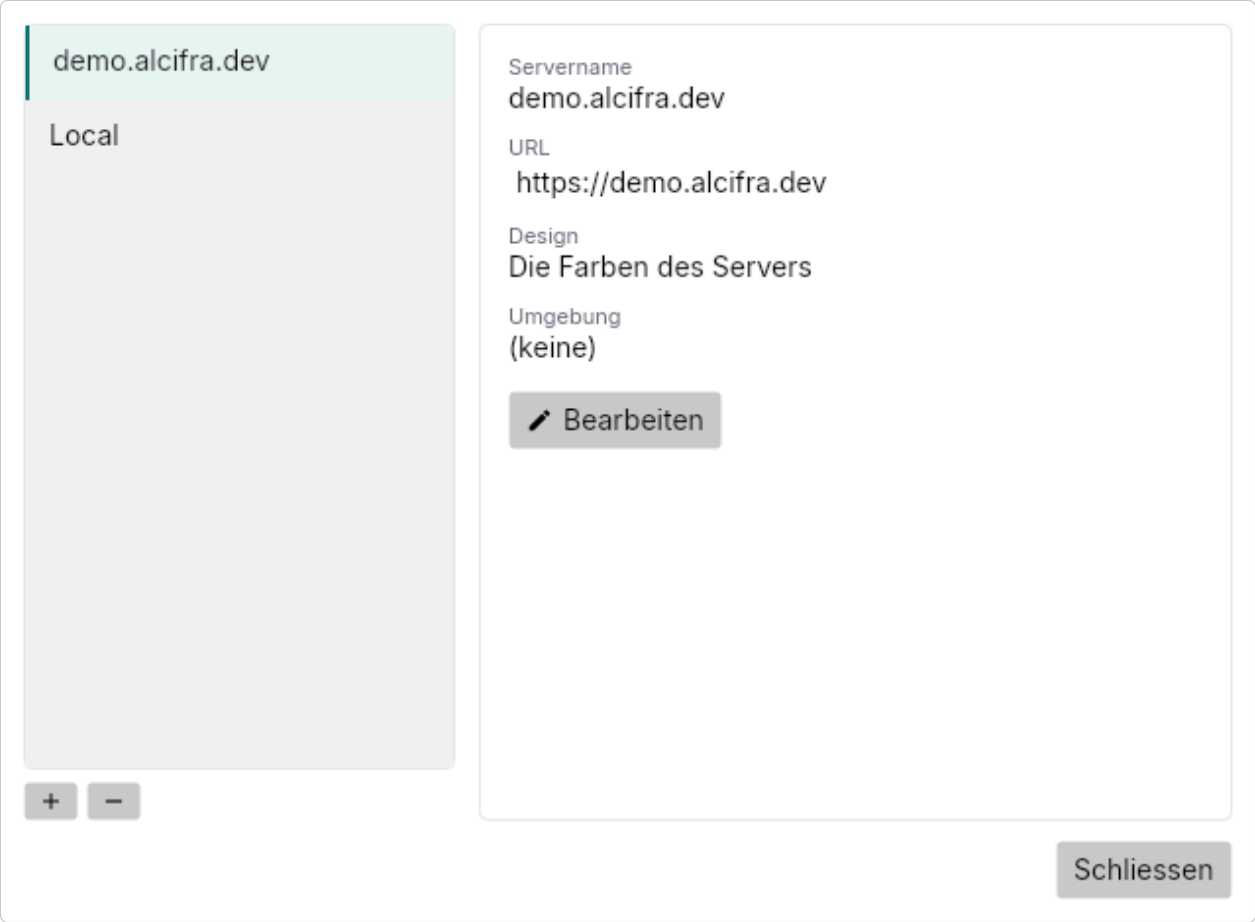



Abbildung 38: Die Server-Verwaltung des Desktop-Clients: Verbindungsprofile für mehrere Server von Alcifra.

## 14.1 Wenn das Archiv Ihnen verschlüsselte Inhalte liefert

Auf einer entsprechend konfigurierten Installation liefert das Archiv überhaupt keine lesbaren Dokumentinhalte aus. Was ankommt, ist ein **an Ihre eigenen Zertifikate adressierter Umschlag** — die Leserzertifikate, die Sie hinterlegt haben (siehe Abschnitt 15.8), dieselben, an die Ihre E-Mails versiegelt werden —, und er wird auf Ihrem eigenen Rechner, mit Ihrem eigenen Schlüssel, von dem Client geöffnet, in dem Sie arbeiten.

> **Dies beschreibt die strikte Stufe.** Ein Administrator kann auch eine Stufe einstellen, auf der Dokumente **auf beide** Arten angeboten werden — als Umschlag für alle, die einen öffnen können, und auf die gewöhnliche lesbare Art für alle anderen. Dort bleiben die unten genannten Schaltflächen, wo sie sind, und funktionieren weiter, der Web-Client zeigt weiterhin Dokumente an, und es ändert sich nur, dass der Desktop-Client über Ihre Karte liest. Wenn Ihre Schaltflächen funktionieren, befinden Sie sich auf jener Stufe und nicht auf dieser, und nichts hier ist schiefgegangen. Abschnitt 14.2 erläutert die Stufen.

Zwei Folgen lernen Sie besser in einem Handbuch kennen als in der Anwendung, denn keine von beiden sieht aus wie das, was sie ist.

**Ohne registriertes Zertifikat werden Herunterladen und Vorschau nicht angeboten** — auf der strikten Stufe. Nicht mit einer Fehlermeldung abgelehnt — sondern **nicht vorhanden**. Das Dokument, seine Indexdaten und sein Verlauf werden weiterhin angezeigt; die Schaltflächen, die Ihnen Inhalte liefern würden, sind einfach nicht da. Das ist Absicht: Eine Schaltfläche, die beim Klicken scheitert, lehrt nichts, während eine fehlende, neben dem Zertifikatseintrag in

Ihrem Kontomenü, auf die Abhilfe verweist. Registrieren Sie ein Zertifikat, und die Schaltflächen erscheinen — und beachten Sie, dass es auf einer Installation mit Zertifikatsverwaltung dort **zwei** Einträge gibt, von denen nur einer Dokumente an Sie adressiert. Abschnitt 15.8 erläutert, welcher.

**Der Desktop-Client öffnet diese Umschläge; der Web-Client kann es nicht.** Ein Browser hat keinen Zugriff auf den Zertifikatsspeicher, in dem Ihr privater Schlüssel liegt, daher ist das Lesen von Dokumenten auf einer solchen Installation Sache des Desktop-Clients. Die Vorschau des Web-Clients meldet *Dieses Dokument ist versiegelt. Öffnen Sie es in der Desktop- oder Smartphone-App.* und bleibt für alles voll nutzbar, was nicht Inhalt ist — Navigieren, Indexdaten, Suchergebnisse, Workflow, Administration.

**Die Suche im Dokument folgt derselben Linie, aus demselben Grund.** Um Ihre Suchbegriffe auf der Seite hervorzuheben, braucht es die Wörter und ihre Positionen, und auf einer solchen Installation hat der Server sie nicht — er hält nur den Umschlag. Der Desktop-Client sucht innerhalb eines Dokuments, weil er diesen Umschlag bereits geöffnet hat und die Seite im Klartext vorliegen hat; der Web-Client kann das nicht, daher wird das Suchfeld dort nicht angeboten. Enthält ein Dokument keinen eigenen Text — ein Foto oder ein Scan, der nie erkannt wurde —, hat die Suche nichts zu durchsuchen und sagt das auch, in beiden Clients.

> **Ein auf einer Smartcard gehaltener Schlüssel verlässt diese nie.** Liegt Ihr privater Schlüssel auf einer Karte oder einem Token statt in einer Datei, führt die Karte die eine Operation aus, die jeden Umschlag öffnet, und der Schlüssel selbst wird nie ausgelesen — nicht vom Archiv, nicht vom Client, nicht von irgendetwas anderem, das auf dem Rechner läuft.

**Lesen mit Ihrer Karte.** Das erste Dokument, das Sie öffnen, fragt einmal nach Ihrer **Karten-PIN**. Sie wird nicht erneut abgefragt, solange Sie angemeldet bleiben und die Karte im Lesegerät steckt — die Vorschau eines Dokuments, seine Seitenbilder und sein durchsuchbarer Text sind drei getrennte Lesevorgänge, und eine Abfrage für jeden wäre unbrauchbar. Die PIN selbst wird nicht gespeichert: Was der Client behält, ist die entsperrte Verbindung zur Karte, nicht die Zahl, die Sie eingetippt haben.

**Zwei Karten gleichzeitig in Lesegeräten sind kein Problem.** Stecken mehrere Karten — Ihre eigene und die eines Kollegen, oder eine Karte, die Sie neben der Ihren, mit der Sie arbeiten, vorbereiten —, fragt der Client zuerst das **Dokument**, an wen es adressiert wurde, und vergleicht das mit dem, was jede Karte enthält. Diese Frage wird anhand öffentlicher Informationen beantwortet, daher wird **eine Karte, die das Dokument nicht öffnen kann, nie nach ihrer PIN gefragt**: Eine Abfrage, deren Antwort ohnehin nein gewesen wäre, ist genau das, womit Menschen lernen, Abfragen wegzuklicken.

Wo **mehrere** Karten es öffnen könnten — eine Karte und eine Identität auf dem Laptop gehören zu einer Person, und ein Dokument ist an alle adressiert —, wird jede der Reihe nach versucht, und die PIN-Abfrage **nennt die Karte, um die es geht**. Wenn Sie also eine ablehnen oder sich bei ihr vertippen, geht kein Dokument verloren, das eine andere Karte geöffnet hätte. Eine Auswahl zwischen ihnen wird Ihnen bewusst nicht angeboten: Jede Karte, die es öffnen kann, öffnet dasselbe Dokument, die Wahl hätte also kein Ergebnis, das Sie sehen könnten.

**Wenn Sie Ihre Karte herausziehen, wird geschlossen, was sie geöffnet hat.** Wenige Sekunden nach dem Entfernen der Karte wird jedes angezeigte Dokument, das sie entschlüsselt hat, geschlossen, und die von ihr gezeichneten Seiten werden verworfen. Sie bleiben angemeldet und können weiterhin Ordner, Indexdaten und Suchergebnisse durchsehen — nichts davon ist verschlüsselt —, und wenn Sie die Karte wieder einstecken, können Sie wieder Dokumente öffnen. Das schützt das Dokument, das Sie auf einem unbeaufsichtigten Bildschirm zurückge-

lassen haben; es meldet Sie nicht ab, sperren Sie Ihren Computer also wie gewohnt, wenn Sie ihn verlassen.

**Nur Ihre eigenen Schlüssel werden verwendet.** Der Client öffnet einen Umschlag nur mit einem Schlüssel, der für **den angemeldeten Benutzer** eingetragen ist. Die Karte eines Kollegen im Lesegerät — oder dessen Zertifikat auf dem Computer — wird nicht verwendet und nie nach ihrer PIN gefragt, selbst wenn das Dokument an sie adressiert ist: Ein Administrator, der die versiegelten Elemente eines Kollegen im Archiv sehen darf, kann sie trotzdem nicht mit dem Schlüssel des Kollegen lesen. Das gilt für Dokumente, den Reiter Nachrichten und den Reiter Passwörter gleichermassen.

**Bleibt ein Dokument versiegelt, sagt die Vorschau, warum** — anstelle des Dokuments, mit **Mit meinem Schlüssel öffnen**, um es erneut zu versuchen:

- *Dieses Dokument ist versiegelt. Stecken Sie Ihren Schlüssel «…» ein.* — es ist für einen Ihrer eingetragenen Schlüssel versiegelt, der genannt wird und nicht im Lesegerät steckt. Stecken Sie ihn ein; das Wiedereinstecken einer Karte lässt die Vorschau es von selbst erneut versuchen. Wo mehrere Ihrer Schlüssel passen würden oder Sie die PIN-Abfrage abgebrochen haben, verlangt sie *einen Hardware-Schlüssel, der es öffnen kann*.
- *Für andere Schlüssel versiegelt. — Keiner Ihrer eingetragenen Schlüssel gehört dazu.* Das Dokument wurde für Schlüssel versiegelt, die nicht (oder nicht mehr) für Sie eingetragen sind.
- *Dieser Schlüssel ist nicht für Sie eingetragen. — Melden Sie sich als Inhaber des Schlüssels an, oder verwenden Sie einen für Sie eingetragenen Schlüssel.* Der Schlüssel im Lesegerät könnte das Dokument öffnen, gehört aber jemand anderem.
- *Ihre eingetragenen Schlüssel konnten nicht geprüft werden.* — der Client konnte nicht ermitteln, welche Schlüssel für Sie eingetragen sind, und verwendet daher keinen.

Ein Dokument, das beschädigt ankam oder nicht abgerufen werden konnte, sagt das an derselben Stelle offen.

Wie Sie eine Karte überhaupt vorbereiten — einen Schlüssel darauf erzeugen, ein Zertifikat darauf bringen und dieses Zertifikat hier registrieren —, erläutert Abschnitt 15.

## 14.2 Verschlüsselung des Archivs selbst

Die Verschlüsselung von Alcifra wird durch **zwei separate kostenpflichtige Produkte** erweitert, und welches Sie brauchen, hängt davon ab, was Sie erreichen wollen. Sie werden hier genannt, weil die Aufteilung nicht dort verläuft, wo die meisten sie vermuten.

**Der Encryption Service** verschlüsselt **Inhalte dort, wo sie gespeichert sind**, mit Schlüsseln, die in Hardware unter der Kontrolle der betreibenden Organisation liegen.

**Das Encryption Module** verwaltet **Zertifikate im Massstab einer Organisation**: mehrere pro Person — eines pro Gerät, sodass eine Smartcard in einem Computer und eine Identität auf einem Smartphone gleichzeitig adressiert werden können —, Registrierung **im Namen anderer** und in grosser Zahl, **Widerruf** und eine **Mandantenrichtlinie**, die festlegt, was ein Zertifikat überhaupt annehmbar macht (Mindestschlüssellängen, zulässige Kurven, die eigene E-Mail-Adresse des Inhabers darin). Es ist ausserdem **die Quelle der Zertifikate eines Lesers**, überall dort, wo Inhalte als Umschlag ausgeliefert werden.

Überraschen mag Sie, was in **keiner** der beiden Listen steht. **Um ein Dokument an Ihr eigenes Zertifikat zu adressieren, brauchen Sie keines der beiden Produkte.** Diese Anwendung kann das mit dem Zertifikat, das Sie selbst registriert haben — es ist derselbe Mechanismus, der Ihre E-Mails nur auf Ihren eigenen Geräten lesbar macht (siehe Abschnitt 6.2). Was die kostenpflich-

tigen Produkte hinzufügen, ist der Schutz der gespeicherten Bytes und die Mittel, Zertifikate für Hunderte von Personen statt für eine zu betreiben.

Wo der Service installiert ist, legt ein Administrator eine **Stufe pro Mandant** fest, sodass ein Archiv, das dies braucht, neben einem stehen kann, das es nicht braucht. Drei dieser Stufen betreffen Sie als Leser, und sie unterscheiden sich darin, was geschieht, wenn Sie noch kein Zertifikat haben. Die erste braucht nur den Service; die beiden anderen liefern Umschläge aus und brauchen daher auch das Module, in dem Ihre Zertifikate registriert werden:

**Verschlüsselt gespeichert** Inhalte werden dort verschlüsselt, wo sie aufbewahrt werden. An der Art, wie Sie sie lesen, ändert sich nichts.

**Probelauf** Jedes Dokument wird **zusätzlich** als Umschlag für alle angeboten, die einen öffnen können, während jeder gewöhnliche Weg des Lesens offen bleibt. Die Stufe existiert, damit eine Organisation herausfinden kann, ob ihre Rechner und Karten bereit sind, **bevor** die strikte Stufe eingeschaltet wird — niemand wird blockiert, während die Lücken gefunden werden. Sie ist eine Bereitschaftsübung und **kein** zusätzlicher Schutz: Alles, was vorher lesbar war, ist weiterhin lesbar, für alle, die es vorher lesen konnten.

**Strikt** Inhalte werden **nur** als Umschlag ausgeliefert. Dies ist die Stufe, die Abschnitt 14.1 beschreibt, und diejenige, auf der ein fehlendes Zertifikat bedeutet, dass es überhaupt keine Inhalte gibt.

**Chats werden nie versiegelt**. Auf jeder Stufe, auch auf der strikten, ist der Chat eines Dokuments weder im Ruhezustand verschlüsselt noch für seinen Leser verschlüsselt: Die Stufen schützen den **Inhalt** eines Dokuments, seine Dateien, nicht das Gespräch daneben. Wie alles, was die Clients mit dem Server austauschen, wird ein Chat dennoch verschlüsselt über das Netzwerk übertragen (TLS); was ihm fehlt, ist die Verschlüsselung pro Leser. Was geschützt bleiben muss, gehört in das Dokument, nicht in seinen Chat.

Alles Weitere, was diese Produkte tun, einschliesslich dessen, was ihr Schutz leistet und was nicht, ist in **ihren eigenen Handbüchern** beschrieben: Es sind separate Produkte mit eigenen Releases, und sie doppelt zu dokumentieren, ist der Weg, auf dem die beiden Beschreibungen auseinanderlaufen.

### 14.2.1 Was die Verschlüsselung hier nicht behauptet

Eine Frage verdient überall dort eine Antwort, wo Verschlüsselung beschrieben wird, denn die ehrliche Antwort ist nicht die, die das Wort «verschlüsselt» nahelegt: **Dies ist quantenmigrierbar, nicht quantenresistent**.

Der **Inhalt** hält stand. Dokumente und Nachrichten werden mit AES-256 verschlüsselt, und ein Quantencomputer bricht das nicht — der beste bekannte Angriff halbiert die effektive Schlüsselstärke, womit 256-Bit-AES auf einem Niveau bleibt, das weiterhin als sicher gilt. Der Grossteil dessen, was gespeichert ist, ist daher in Ordnung.

Nicht stand hält jeder **asymmetrische** Schritt daneben: das Einpacken eines Inhaltsschlüssels unter einem in Hardware gehaltenen Schlüssel und das Adressieren eines Umschlags an das Zertifikat einer Person. Diese beruhen auf RSA und der Mathematik elliptischer Kurven, die ein ausreichend leistungsfähiger Quantencomputer vollständig bricht.

Die Folge hat einen Namen — **harvest now, decrypt later** (jetzt sammeln, später entschlüsseln). Ein Angreifer, der heutige eingepackte Schlüssel und Umschläge kopiert, kann sie an dem Tag entschlüsseln, an dem eine solche Maschine existiert. Für etwas, das eine Woche halten soll, ist das akademisch. Für ein **Archiv**, dessen ganzer Zweck es ist, Dokumente über Jahrzehnte lesbar zu halten, überschneidet sich die Zeit, in der der Inhalt geschützt bleiben muss, plausibel mit der

Zeit, in der diese Maschine erscheinen könnte; deshalb lohnt es sich, das klar auszusprechen, statt es im Kleingedruckten zu lassen.

**Migrierbar** ist die Behauptung, die zutrifft. Die Inhaltsschlüssel müssen sich nie ändern: Der Wechsel zu einem Post-Quanten-Schutz bedeutet, diese Schlüssel unter einem neuen Verfahren neu einzupacken, nicht ein einziges Dokument neu zu verschlüsseln — und im Encryption Service sind die bereits vorhandenen rollierenden Schlüsselgenerationen genau der Mechanismus, der das erledigen würde. Was heute fehlt, ist nicht das Design, sondern die Bausteine: Hersteller von Hardware-Sicherheitsmodulen, Kartenhersteller und E-Mail-Clients liefern noch keine Post-Quanten-Unterstützung.

Die eigenen Handbücher der beiden kostenpflichtigen Produkte behandeln dies ausführlicher, jedes für seine Hälfte. Es wird hier wiederholt, weil jemand, der **dieses** Handbuch liest, jene vielleicht nie öffnet — und von einer Grenze, die niemand benennt, nimmt ein Leser an, dass es sie nicht gibt.

# 15 Anhang — eine Smartcard oder ein Token vorbereiten

Dies ist die einmalige technische Einrichtung hinter Abschnitt 14.1: einen Schlüssel auf eine Karte bringen, ein Zertifikat darauf ablegen und dieses Zertifikat im Archiv registrieren. Das ist Arbeit für die Person, die die Karten verwaltet — eine gewöhnliche Benutzerin oder ein gewöhnlicher Benutzer hat nur mit dem letzten Schritt zu tun.

Das folgende Verfahren gilt für eine **PIV**-Karte oder ein PIV-Token, denn PIV ist die Sprache der Clients des Archivs. Als durchgehendes Beispiel dient ein bestimmtes Gerät, weil die Befehle zur Schlüsselerzeugung zum eigenen Werkzeug der Karte gehören und sich je nach Hersteller unterscheiden; ab der Zertifikatsanforderung ist alles für jedes PIV-Gerät gleich.

**Zum Gerät im Beispiel.** Dieses Handbuch verwendet einen YubiKey, weil er weit verbreitet und erschwinglich ist, was das Nachvollziehen des Beispiels erleichtert. Das ist keine Empfehlung, und das Archiv verlangt nichts von diesem Hersteller: Jede PIV-fähige Karte und jedes PIV-fähige Token funktioniert, und nur die Befehle in den Schritten 1, 2 und 3 — diejenigen, die direkt mit der Karte sprechen — wären anders. Setzen Sie dort das Werkzeug Ihres eigenen Geräts ein.

## 15.1 Was erfüllt sein muss, und warum

Vier Entscheidungen sind nicht frei. Ist eine falsch, entsteht eine Karte, die richtig aussieht und kein Dokument lesen kann.

- **Slot 9D (Key Management).** Das ist der Slot für die Entschlüsselung. 9A dient der Authentisierung und 9C der Signatur; ein Zertifikat in einem dieser beiden kann keinen Umschlag öffnen, und den falschen zu verwenden ist der klassische erste Fehler.
- **Eine elliptische Kurve (P-256) ist vorzuziehen; RSA 2048 funktioniert ebenfalls.** Beide werden adressiert: ein EC-Schlüssel per Schlüsselvereinbarung, ein RSA-Schlüssel per Schlüsseltransport. EC ist auf einem modernen Token die bessere Wahl und ist das, was der unten gezeigte Bereitstellungsbefehl wählt, wenn nichts anderes angegeben ist. Dieses Handbuch sagte **RSA, keine elliptische Kurve**, bis der EC-Weg fertiggestellt und auf zwei Karten nachgewiesen war — trägt Ihre Karte bereits einen RSA-Schlüssel, gibt es keinen Grund, ihn zu ersetzen.
- **PIN-Richtlinie ein, Touch-Richtlinie AUS.** Eine Touch-Anforderung bedeutet ein physisches Antippen **pro Entschlüsselung** — und die Vorschau, die Seitenbilder und der durchsuchbare Text eines einzigen Dokuments sind drei getrennte Lesevorgänge. Für das Signieren annehmbar, für ein Archiv unbrauchbar.
- **Der Schlüssel wird AUF der Karte erzeugt.** Darum geht es überhaupt: Er kann nicht herauskopiert werden, also gibt es keine Datei davon, die verloren gehen könnte.

## 15.2 Werkzeuge

Zwei werden gebraucht, ein drittes nicht.

- **Das eigene Werkzeug der Karte**, um den Schlüssel zu erzeugen und das Zertifikat zurückzuschreiben. Die Personalisierung der Karte und die Schlüsselerzeugung sind Operationen des Karten-Applets, keine PKCS#11-Operationen. In diesem Beispiel ist das `ykman`.
- **Das PKCS#11-Modul**, damit der Desktop-Client die Karte überhaupt erreicht. Installieren Sie **OpenSC**; der Client sucht `opensc-pkcs11` an den üblichen Orten und bietet eine Dateiauswahl an, wenn es anderswo liegt.
- **`caconsole`**, das Zertifikatswerkzeug, wenn das Zertifikat von Ihrer eigenen Zertifizierungsstelle ausgestellt wird. Es wird aus dem öffentlichen Paket-Feed installiert und braucht keine Zugangsdaten:

```
dotnet tool install --global HebelConsulting.CAManagement.Cli

# ONCE PER MACHINE: a global tool lands in ~/.dotnet/tools, which is not on PATH by default.
# Without this the next line fails with "command not found: caconsole".
export PATH="$PATH:$HOME/.dotnet/tools"   # add to ~/.zshrc to keep it

caconsole list-slots --module <the PKCS#11 module>
```

> **«command not found: caconsole» bedeutet nicht, dass die Installation fehlgeschlagen ist.** Fast immer bedeutet es, dass `~/.dotnet/tools` nicht in Ihrem PATH liegt — das Installationsprogramm gibt diese Warnung einmal aus, und sie ist leicht zu übersehen. Prüfen Sie mit `dotnet tool list --global`: Führt die Tabelle das Paket und den Befehl `caconsole` auf, ist das Werkzeug vorhanden und nur der PATH fehlt. Bis dahin startet `~/.dotnet/tools/caconsole` es.

**Wo das Modul liegt.** `list-slots` braucht den Pfad zur PKCS#11-Bibliothek von OpenSC, und dieser ist je nach System verschieden. Das sind die Orte, an denen der Desktop-Client selbst sucht, also ist einer davon fast sicher der richtige:

**macOS, Homebrew auf Apple Silicon**
: `/opt/homebrew/lib/opensc-pkcs11.so`

**macOS, Homebrew auf Intel**
: `/usr/local/lib/opensc-pkcs11.so`

**macOS, das Installationspaket von OpenSC**
: `/Library/OpenSC/lib/opensc-pkcs11.so`

**Windows**
: `C:\Program Files\OpenSC Project\OpenSC\pkcs11\opensc-pkcs11.dll`

**Linux, Debian und Ubuntu**
: `/usr/lib/x86_64-linux-gnu/opensc-pkcs11.so`

**Linux, Fedora und RHEL**
: `/usr/lib64/opensc-pkcs11.so`

Ein funktionierender Aufruf nennt das Token, statt still zu bleiben — mit eingesteckter Karte gibt er die Cryptoki-Version und eine Tabelle mit einer Zeile pro Slot aus, und die Token-Spalte zeigt `PIV_II` für eine personalisierte Karte. Ist die Tabelle leer, wurde das Modul geladen, aber das Lesegerät sieht keine Karte; scheitert der Befehl am Modulpfad, ist der Pfad falsch und nicht die Karte.

> **Zwei Werkzeuge, zwei Aufgaben — und beide sind inzwischen beteiligt.** `caconsole` gehört zur Zertifizierungsstelle: Es bereitet die Karte vor und stellt das Zertifikat aus. `alcifra` gehört

zum Archiv: Es **hinterlegt** ein fertiges Zertifikat für eine Person, listet auf, was hinterlegt ist, und widerruft eines (`alcifra certificates enrol|list|revoke`).

Dieses Handbuch sagte, `alcifra` habe keine Zertifikatsbefehle, was stimmte, bis sie hinzukamen. Die Aufteilung gilt weiterhin und lohnt sich klar im Kopf zu behalten: Die Zertifizierungsstelle stellt aus, das Archiv hinterlegt.

## 15.3 Ein Befehl, wenn Ihre eigene Zertifizierungsstelle das Zertifikat ausstellt

Stammt das Zertifikat von einer Zertifizierungsstelle, die Sie mit `caconsole` betreiben, ist der ganze nächste Abschnitt ein einziger Befehl:

```
caconsole yubikey provision --holder anna@example.test \
    --token-label ca-token --pin "$CA_PIN" --ca-label ca-root --ca-cert ca.crt \
    --label "YubiKey 5C" --manifest enrolments.json
```

Er erzeugt den Schlüssel in Slot 9D, lässt die **Karte selbst** die Zertifikatsanforderung signieren — der einzige verfügbare Nachweis, dass der private Schlüssel wirklich vorhanden und erreichbar ist —, stellt ein Zertifikat für die Entschlüsselung aus, importiert es und liest den Slot zurück, um zu bestätigen, was die Karte jetzt enthält.

Drei Dinge tut er nicht stillschweigend:

- **Er überschreibt keine Karte, ohne dass man es ihm sagt.** Enthält der Slot bereits etwas, gibt er aus, was dort ist, und hält an. `--force` ersetzt das **Zertifikat** und behält den Schlüssel — das ist die Reparatur für eine Karte, deren Zertifikat die falsche Verwendung angibt —, und `--regenerate-key` ersetzt den **Schlüssel**, was unumkehrbar ist: Alles, was an den alten verschlüsselt wurde, wird unlesbar. Ein bereits im Slot vorhandenes Zertifikat wird zuerst neben dem neuen gesichert.
- **Er vertraut keiner Karte, die nicht antworten kann.** Ein Token mit einer PIV-Firmware älter als 5.3 meldet `Private key type: EMPTY`, ob ein Schlüssel vorhanden ist oder nicht — es gibt diese Angabe schlicht nicht heraus. Der Befehl behandelt «leer» auf einer solchen Karte als **unbekannt** statt als **nicht vorhanden** und weigert sich, darüber einen Schlüssel zu erzeugen.
- **Er verbirgt nicht, was er getan hat.** Jeder Befehl, den er an die Karte richtet, und die Antwort der Karte werden ausgegeben — ohne PIN und Management Key.

Mit `--manifest` hält er ausserdem fest, was an wen ausgestellt wurde, in einer Datei, die `alcifra certificates import` liest — so wird eine Schachtel vorbereiteter Karten in einem Durchgang hinterlegt statt Karte für Karte:

```
alcifra certificates import enrolments.json --dry-run   # what would change
alcifra certificates import enrolments.json
```

Ein erneuter Aufruf ist unbedenklich: Ein bereits hinterlegtes Zertifikat wird als **unverändert** gemeldet statt als Fehler, sodass ein unterbrochener Import durch erneutes Ausführen abgeschlossen wird. (`alcifra certificates enrol <file> --holder <email>` ist das Gegenstück für ein einzelnes Zertifikat, für eine Karte, die für sich allein vorbereitet wurde.)

## 15.4 Schritt für Schritt

Das ist, was der Befehl oben tut, und der Weg, den Sie gehen, wenn das Zertifikat von anderswo kommt — von einer Zertifizierungsstelle des Unternehmens oder auf einer Karte, die bereits personalisiert eintrifft.

**1 — Die Karte personalisieren,** einmal pro Karte. Diese beiden Objekte müssen existieren, bevor sich irgendetwas anderes korrekt verhält.

```
ykman piv objects generate chuid
ykman piv objects generate ccc
```

**2 — Den Schlüssel auf der Karte erzeugen,** im Key-Management-Slot.

```
ykman piv keys generate 9d public.pem \
    --algorithm rsa2048 --pin-policy once --touch-policy never
```

**3 — Ein Zertifikat in den Slot legen.** Der Slot braucht eines, bevor irgendetwas den Schlüssel überhaupt verwenden kann: Ein PKCS#11-Modul zeigt keinen PIV-Slot an, der nur einen Schlüssel enthält. Es gibt zwei Wege, und **für dieses Archiv genügt der einfache** — darum steht er zuerst und nicht als Nachtrag.

**3a — Selbstsigniert, ganz ohne Zertifizierungsstelle.** Das eigene Werkzeug der Karte erstellt das Zertifikat und schreibt es in einem einzigen Befehl in den Slot.

```
ykman piv certificates generate 9d public.pem \
    --subject "CN=Card Holder,O=Example,C=CH" --valid-days 730
```

> **Das Archiv akzeptiert ein selbstsigniertes Zertifikat, und das ist Absicht, kein Versehen.** Nichts auf dem Leseweg prüft eine Kette oder einen Aussteller: Inhalte werden in einen Umschlag für einen **öffentlichen Schlüssel** gepackt, und das Einzige, was den Umschlag öffnen kann, ist der private Schlüssel auf der Karte. Eine Zertifizierungsstelle beantwortet eine andere Frage — **wer bürgt dafür, dass dieser Schlüssel jener Person gehört** —, die für eine Organisation wichtig ist, die Identitäten ausgibt, und überhaupt nicht dafür, ob sich ein Dokument öffnet.
>
> Was das Archiv prüft, ist, dass sich die Datei als X.509 lesen lässt und einen **RSA**- oder einen Schlüssel auf einer **elliptischen Kurve** trägt — die beiden Arten, die **Was erfüllt sein muss, und warum** oben nennt, die eine über Schlüsseltransport adressiert, die andere über Schlüsselvereinbarung.
>
> **Achten Sie auf die Gültigkeitsdauer.** `--valid-days` ist standardmässig **365**, und obwohl das Archiv selbst ein abgelaufenes Zertifikat auf dem Leseweg nicht ablehnt, **weigert** sich der Verschlüsselungsdienst, eines zu registrieren — ein bereits abgelaufenes Zertifikat kann also nach einem Zurücksetzen oder einem Umzug auf eine andere Installation nicht erneut registriert werden. Wählen Sie eine Gültigkeitsdauer, mit der Sie leben können.

**3b — Oder von Ihrer eigenen Zertifizierungsstelle ausgestellt,** wenn Ihre Organisation Identitäten möchte, die sie selbst kontrolliert — einen gemeinsamen Vertrauensanker, einen Namen, der ihr gehört, ein Verzeichnis, wer was erhalten hat. Lassen Sie die Karte eine Anforderung erstellen, stellen Sie sie aus und schreiben Sie das Ergebnis zurück.

```
ykman piv certificates request 9d public.pem holder.csr \
    --subject "CN=Card Holder,O=Example,C=CH"

caconsole issue --token-label ca --pin <ca-pin> \
    --ca-label root --ca-cert ca.crt --csr holder.csr --days 365 --out holder.crt
```

```
ykman piv certificates import 9d holder.crt
```

> **Verwenden Sie für die Anforderung das Werkzeug der Karte, nicht das Zertifikatswerkzeug.** `caconsole` kann eine Anforderung aus einem Schlüssel erstellen, der auf einem Token liegt — aber ein PKCS#11-Modul zeigt einen PIV-Slot erst an, wenn dieser Slot ein **Zertifikat** enthält, und dieser hat noch keines. Fragt man zuerst das Zertifikatswerkzeug, scheitert es mit `No private key with label '…' found on the token`, was nach einer falschen Bezeichnung aussieht und keine ist.

> **Ein leeres `ERROR:` ohne Meldung bedeutet, dass der Slot keinen Schlüssel hat.** Beide Befehle in 3a und 3b signieren mit dem privaten Schlüssel in Slot 9D, also scheitert jeder von ihnen vor Schritt 2 — und das Werkzeug der Karte meldet das als nacktes `ERROR:` ohne etwas nach dem Doppelpunkt, was über die Ursache überhaupt nichts aussagt. Prüfen Sie mit `ykman piv info`: Hat die Ausgabe keinen Abschnitt **Slot 9D**, gibt es dort noch keinen Schlüssel.
>
> Genau das hinterlässt auch ein **Zurücksetzen**. `ykman piv reset` — der Ausweg aus einer gesperrten PIN, wenn auch der PUK gesperrt ist — löscht jeden Schlüssel und jedes Zertifikat auf der Karte, bringt Sie also zu Schritt 1 zurück und nicht dorthin, wo Sie aufgehört haben. Ziehen Sie `ykman piv access unblock-pin` vor, das den PUK verlangt und den Schlüssel behält.

**4 — Die Karte entfernen und wieder einstecken.** Das Betriebssystem legt seine Sicht auf ein Token an, wenn die Karte **eingesteckt** wird, sodass eine an Ort und Stelle personalisierte Karte noch für nichts sichtbar ist. Wer diesen Schritt auslässt, lässt eine korrekt vorbereitete Karte defekt erscheinen.

## 15.5 Den Schlüssel im Desktop-Client testen

**Hardware-Schlüssel testen** ist das Werkzeugsymbol (ein Schraubenzieher und ein Schraubenschlüssel) im Anmeldefenster — es funktioniert also schon vor der Anmeldung — und der erste Eintrag im Werkzeugmenü neben dem Hilfesymbol in der Titelleiste des Hauptfensters. Stecken Sie den Schlüssel ein und drücken Sie **Test starten**.

Der Test liest das Zertifikat im Key-Management-Slot des Schlüssels (ohne PIN), versiegelt auf Ihrem Computer eine frische Zufallsnachricht dafür, fragt nach der PIN, öffnet die Nachricht mit dem Schlüssel und vergleicht. Er braucht keinen Server, sendet nichts irgendwohin und funktioniert für jeden RSA- oder EC-Schlüssel, den das Archiv akzeptiert, ob es Ihrer ist oder einer, den Ihre Organisation ausgegeben hat. Jeder Schritt wird aufgeführt, während er läuft; der erste, der scheitert, sagt warum, mit dem genauen Code, den die Smartcard-Software geantwortet hat (`CKR_PIN_INCORRECT` für eine falsche PIN — achten Sie auf den Fehlversuchszähler).

**Der Bericht für den Support.** Unter den Schritten steht ein Bericht, den Sie kopieren und an die Person senden können, die Sie unterstützt. Das Fenster sagt, was er enthält, bevor Sie ihn kopieren: die App- und Systemversionen, die gefundene PKCS#11-Bibliothek, Ihre Lesegeräte, Hersteller, Modell, Firmware und **Seriennummer** des Schlüssels, seine Zertifikate und jeden Schritt mit seinem Ergebnis. Sind Sie angemeldet, ergänzt ein Schalter (eingeschaltet, sofern Sie ihn nicht ausschalten) die Seite des Archivs: Adresse und Version des Servers, ob das getestete Zertifikat für Sie hinterlegt ist, die PIN-Richtlinie und den Verschlüsselungsmodus Ihrer Organisation. Der Bericht enthält nie Ihre PIN, Dokumente, Anmelde-Tokens oder andere Geheimnisse.

## 15.6 Die Karte prüfen, bevor Sie sich auf sie verlassen

Neben dem Fenster oben bringt der Desktop-Client zwei Einstiegspunkte mit, die die Frage **«wird diese Karte tatsächlich funktionieren?»** ohne Server, Konto oder Dokument beantworten. Es lohnt sich, sie vor jeder Registrierung auszuführen, und sie sind das Erste, wonach Sie greifen sollten, wenn sich eine Karte später seltsam verhält.

Beide sind der **installierte Desktop-Client**, im Terminal mit einem Schalter aufgerufen — es muss nichts zusätzlich installiert und kein Quellcode gebaut werden.

```
# The installed executable. This is the macOS path; the others are below.
CLIENT=/Applications/Alcifra.app/Contents/MacOS/Alcifra.DesktopClient
```

**macOS**

```
/Applications/Alcifra.app/Contents/MacOS/Alcifra.DesktopClient
```

**Windows, im entpackten Ordner**

```
Alcifra.DesktopClient.exe
```

**Linux, im entpackten Ordner**

```
./Alcifra.DesktopClient
```

**Was der Client sehen kann** — ohne PIN, denn Zertifikate sind öffentlich:

```
$CLIENT --card-test
```

Er gibt das gefundene PKCS#11-Modul aus, dann jedes Zertifikat auf jedem Token in jedem Lesegerät, mit dem Inhaber (Subject), dem Ablaufdatum und einem **Bedenken** (concern) — `KeyUsage`, wenn das Zertifikat die Schlüsselverschlüsselung (key encipherment) nicht erwähnt, `Expired` oder `None`. Eine Karte, die hier nichts zeigt, zeigt auch im Dialog nichts, und die Ursache liegt dann beim Modul oder beim Lesegerät, nicht beim Archiv.

**Ob sie tatsächlich entschlüsseln kann** — dieser Test braucht die PIN:

```
CARD_PIN=<pin> $CLIENT --card-open-test
```

Er baut einen Umschlag **so, wie der Server ihn baut**, adressiert an das Zertifikat auf der Karte, und öffnet ihn über denselben Code, den ein echtes Dokument durchläuft. `MATCHES: True` in der letzten Zeile bedeutet, dass die ganze Kette funktioniert: das Zertifikat, der Schlüssel dahinter, die PIN, das Modul und der eigene Leseweg des Clients.

> **Das ist der Test, der Streitfragen entscheidet, und er ist der einzige, der das kann.** Ein Zertifikat sieht gleich aus, ob ein brauchbarer privater Schlüssel dahintersteht oder nicht — und auf YubiKey-Firmware älter als 5.3 meldet `ykman piv info` für einen Slot mit einem einwandfreien Schlüssel `Private key type: EMPTY`, weil es vor dieser Version keine Schlüssel-Metadaten gab. Liest man das als «es gibt keinen Schlüssel» und erzeugt einen neuen, zerstört man den echten. Nur eine Entschlüsselung beweist, dass der Schlüssel da ist.
>
> Er unterscheidet ausserdem eine **falsche PIN** von einer **defekten Karte**: Der Fehler nennt `CKR_PIN_INCORRECT`, statt zu melden, dass nichts den Umschlag öffnen konnte. Achten Sie beim Probieren auf den Fehlversuchszähler — drei falsche Eingaben sperren die PIN.

## 15.7 Im Archiv registrieren

Öffnen Sie im Desktop-Client **Zertifikat hinterlegen…** im Kontomenü und wählen Sie **Karte oder Token hinzufügen…**. Der Dialog listet jedes Zertifikat auf jedem Gerät in einem Lesegerät auf — nicht nur das erste —, weil eine Karte mehrere tragen kann und ein Computer mehr als ein Lesegerät haben kann. Wählen Sie das aus dem Key-Management-Slot und hinterlegen Sie es. Es wird keine PIN verlangt: Ein Zertifikat ist öffentlich, und nur das Lesen eines **Dokuments** braucht den Schlüssel.

Von da an adressiert das Archiv die Inhalte dieser Person an dieses Zertifikat, und Abschnitt 14.1 beschreibt, was sie sieht.

> **Eine Warnung zur Schlüsselverwendung ist zu erwarten und kein Problem.** Viele Zertifizierungsstellen kennzeichnen ein Key-Management-Zertifikat nur für das Signieren. Die Karte entschlüsselt trotzdem — weder das Archiv noch die Karte setzt dieses Feld durch —, also sagt der Dialog das und lässt Sie fortfahren, statt ein funktionierendes Zertifikat abzulehnen.

## 15.8 Selbst hinterlegen, wo Ihnen das offensteht

**Zertifikat hinterlegen…** im Kontomenü ist der Ort, an dem jedes Leserzertifikat hinterlegt wird, in beiden Clients und auf jeder Installation. Ohne das **Encryption Module** (Abschnitt 14.2) führt eine Person höchstens **zwei** Zertifikate — etwa eine Karte für den Schreibtisch und einen Sicherheitsschlüssel für unterwegs; mit ihm entscheidet seine Zertifikatsrichtlinie, wie viele, und was als annehmbares Zertifikat gilt. Ein widerrufenes Zertifikat zählt nicht mehr zu den zweien.

**Ob Sie ihn benutzen dürfen, entscheidet Ihre Organisation, und der Dialog sagt es Ihnen**, statt dass das Menü ihn verbirgt. Das Hinterlegen des eigenen Zertifikats ist **ausgeschaltet**, bis eine Administratorin oder ein Administrator es öffnet — wo es geschlossen ist, sagt der Dialog also, dass es geschlossen ist und dass jemand, der Zertifikate verwaltet, eines für Sie hinterlegen oder es öffnen kann. Das ist bewusst nicht dieselbe Meldung wie «diese Installation kann das überhaupt nicht»: Das eine kann eine Kollegin noch heute Nachmittag ändern, und ein fehlender Eintrag könnte die beiden nicht auseinanderhalten.

**Das Hinterlegen geschieht im Desktop-Client, nicht im Browser.** Ein Leserzertifikat wird nur angenommen, wenn sein Schlüssel **bestätigt** ist — das Token selbst weist nach, dass der Schlüssel auf ihm erzeugt wurde und es nicht verlassen kann (Abschnitt 15.10) —, und nur ein Programm, das mit dem Token spricht, kann diesen Nachweis lesen. Der Dialog des Web-Clients zeigt deshalb die für Sie hinterlegten Zertifikate, jedes mit seinem Bestätigungsstatus, und verweist Sie an den Desktop-Client (oder das Smartphone, oder `alcifra`); **Karte oder Token hinzufügen…** im Desktop-Client liest das Zertifikat **und** seine Bestätigung in einem Schritt vom Token.

**Verlangt wird das Zertifikat** — vom Token oder dessen öffentlicher Teil als Datei (`.pem`, `.crt`, `.cer` oder das binäre `.der`, das Kartenwerkzeuge exportieren). Eine Datei trägt keine Bestätigung, also wird sie nur angenommen, wo Ihre Organisation Hardware ohne Bestätigung erlaubt. **Eine Datei, die einen privaten Schlüssel enthält, wird abgelehnt, bevor irgendetwas gesendet wird**, mit Begründung: Der private Schlüssel gehört auf die Karte oder in den Schlüsselspeicher, der ihn erzeugt hat, und der richtige Moment, das zu sagen, ist, solange er sich noch ausschliesslich auf Ihrem eigenen Rechner befindet.

**Sie geben dem Schlüssel ausserdem einen Namen**, den Sie wiedererkennen — «YubiKey 5C», «Arbeits-Laptop». Das verhindert, dass mehrere Zertifikate pro Person später verwechselt werden, und es lohnt einen kurzen Gedanken, weil ein Dokument an **alle** adressiert wird: Die

Karte auf Ihrem Schreibtisch und die Identität auf Ihrem Laptop öffnen dasselbe Dokument, ohne dass irgendetwas raten muss, an welchem Gerät Sie gerade sitzen.

**Eine Ablehnung nennt, welcher von vier Fällen eingetreten ist**, weil die Abhilfe jedes Mal eine andere ist und nur einer davon bei Ihnen liegt (und ein fünfter, **Sie führen bereits zwei**, wo die Grenze gilt: Widerrufen Sie zuerst eines): Das Hinterlegen steht Ihnen hier nicht offen (Sache der Administration); das Zertifikat ist keines, das das Produkt überhaupt verwenden kann (eine Neuausstellung); die Richtlinie Ihrer Organisation akzeptiert dieses nicht, weil sein Schlüssel zu kurz ist, seine Kurve nicht auf der Liste der zugelassenen steht oder die E-Mail-Adresse darauf nicht Ihre ist (verlangen Sie eines, auf dem sie es ist — Abschnitt 15.11); oder es ist bereits hinterlegt (nichts zu tun). Der Satz kommt von der Zertifikatsverwaltung selbst, in Ihrer eigenen Sprache, statt eines einzigen «konnte nicht hinterlegt werden», das alle vier an dieselbe Stelle schicken würde.

> **Ein Speicher.** Frühere Versionen hatten neben diesem einen zweiten Eintrag, **Verschlüsselte E-Mail (S/MIME)…**, mit einem Zertifikat pro Person. Er ist ausser Dienst gestellt: Die hier hinterlegten Zertifikate sind die einzigen, an die das Archiv Dokumente und E-Mails adressiert, also widerruft ein Widerruf überall.

## 15.9 Einen Schlüssel widerrufen

**Meine Schlüssel…** im Kontomenü listet die für Sie hinterlegten Schlüssel mit ihrem Zustand und bietet bei jedem noch gültigen **Widerrufen…** an. Wer Benutzer verwaltet, findet dieselbe Liste unter **Schlüssel…** bei einer Person in **Benutzer und Gruppen**; sonst kann niemand Ihren Schlüssel widerrufen. Der Widerruf fragt nach dem **Grund** — verloren, gestohlen oder kompromittiert, durch einen neuen Schlüssel ersetzt, der Inhaber hat die Organisation verlassen, oder in eigenen Worten —, und dieser Grund bleibt beim Schlüssel. Hat jemand anderes Ihren Schlüssel widerrufen, sagt Ihnen eine Benachrichtigung, welchen, wer und warum.

**Ersetzen Sie einen Schlüssel? Hinterlegen Sie zuerst den neuen, widerrufen Sie dann den alten.** Ab dem Widerruf wird nichts mehr für ihn versiegelt, und was er lesen konnte, wird als offengelegt markiert; war es Ihr einziger gültiger Schlüssel, warnt der Dialog, denn bis ein weiterer hinterlegt ist, lassen sich versiegelte Objekte nicht öffnen. Ein Widerruf lässt sich nicht rückgängig machen. Auf der Kommandozeile: `alcifra certificates revoke --thumbprint … --reason lost`.

## 15.10 Nur bestätigte Hardware-Schlüssel werden hinterlegt

**Ein Leserzertifikat wird nur angenommen, wenn sein Schlüssel bestätigt ist**: Das Token signiert mit einem Bestätigungsschlüssel, den sein Hersteller darauf angebracht hat, eine Erklärung, dass es diesen Schlüssel selbst erzeugt hat, und das Archiv prüft diese Erklärung, bevor es irgendetwas ablegt. Ein Schlüssel, der je ausserhalb eines Tokens war — in Software erzeugt oder auf die Karte importiert —, kann nicht bestätigt werden, also kann er nicht versehentlich wie Hardware hinterlegt werden.

**Welche Hersteller zählen, entscheidet Ihre Installation.** Die Plattform-Administration schaltet die Bestätigungs-Stammzertifikate der Hersteller ein, denen die Installation vertraut (`alcifra attestation-roots`); eine frische Installation vertraut keinem. Eine Mandanten-Administratorin oder ein Mandanten-Administrator darf einige davon für den Mandanten **ausschalten**, nie eines hinzufügen (`alcifra certificates attestation-roots`). Wo ein Token überhaupt keine Bestätigung liefern kann — viele Karten können das nicht —, darf die Administration für den Mandanten **Hardware ohne Bestätigung** erlauben (`alcifra certificates settings set --unattested-hardware allowed`); solche Zertifikate werden dann als **nicht bestätigt** gekennzeichnet.

**Jedes Zertifikat zeigt seinen Status** im Hinterlegungsdialog beider Clients und in `alcifra certificates list`: **bestätigt durch** den Namen des Stammzertifikats und die Seriennummer des Tokens; **nicht bestätigt**; oder bestätigt durch ein Stammzertifikat, dem hier nicht vertraut wird. Nur der erste Fall adressiert Sie, wo Ihre Organisation eine Bestätigung verlangt, und ein Umschalten wirkt sofort: Für einen Schlüssel, dessen Stammzertifikat ausgeschaltet wurde, wird nichts Neues versiegelt. Bereits dafür versiegelte Dokumente öffnen sich weiterhin damit — es wird nie etwas neu versiegelt.

Mit `alcifra` reist die Bestätigung als zwei Dateien, die das eigene Werkzeug des Tokens exportiert — das Bestätigungszertifikat des Slots und das Bestätigungszertifikat des Tokens, das es signiert hat (für Slot 9D: `attest 9d` und `export f9`):

```
alcifra certificates enrol holder.crt --holder anna@example.test \
    --attestation attestation-9d.pem --attestation-intermediate f9.pem --slot 9d
```

Ein Manifest für `alcifra certificates import` trägt dieselben zwei Zertifikate pro Zeile, als `attestation`-Objekt.

## 15.11 Ein Zertifikat trägt die Adresse seiner Inhaberin oder seines Inhabers

**Ein Leserzertifikat wird nur für die Person hinterlegt, deren E-Mail-Adresse es trägt**. An Sie adressierte Dokumente werden für die **für Sie** hinterlegten Zertifikate versiegelt; ein Zertifikat, das auf die Adresse einer Kollegin ausgestellt ist und unter Ihrem Namen hinterlegt wird, würde Ihre Dokumente also mit dem Schlüssel Ihrer Kollegin lesbar machen — ob Sie es selbst hinterlegt haben oder eine Administratorin Sie als Inhaber angegeben hat (`alcifra certificates enrol … --holder`). Deshalb muss die Adresse im Zertifikat (seine E-Mail-Adresse im Subject Alternative Name, ohne Beachtung der Gross- und Kleinschreibung verglichen) die eigene des Kontos sein, und eine Abweichung wird unter Nennung beider Adressen abgelehnt:

```
This tenant requires a certificate to carry the e-mail address of the account it is enrolled
for.
This one says 'florian@example.test' and the account is 'crypt@example.test'.
[CERTIFICATE_POLICY_REFUSED]
```

Die Abhilfe ist ein Zertifikat, das auf die richtige Adresse oder auf einen der Identitäts-Aliase des Kontos ausgestellt ist. **Diese Bindung, strict, ist die Voreinstellung für jede Organisation, die nichts anderes festgelegt hat.** Eine Zertifizierungsstelle, deren Zertifikate überhaupt keine E-Mail-Adresse tragen, kann sie nicht erfüllen; für diesen Fall kann die Administration Schlüssel stattdessen über den **Besitz** binden. Dann braucht ein Zertifikat keine bestimmte Adresse. Mitglieder hinterlegen ihr eigenes, indem sie den Besitz des Schlüssels nachweisen: Der Server versiegelt eine Aufgabe an das Zertifikat, und der Client öffnet sie mit dem Schlüssel und fragt wie bei jedem versiegelten Dokument nach der PIN. Die Administration kann ein Zertifikat auch für seine Inhaberin oder seinen Inhaber hinterlegen und bürgt damit dafür, wessen Schlüssel es ist. Unter beiden Bindungen gehört ein Schlüssel im Mandanten einer Person, auch unter einem zweiten Zertifikat.

```
alcifra certificates policy show
alcifra certificates policy set --binding possession   # an authority without e-mail
addresses
alcifra certificates policy set --binding strict       # back to the default
```

Um nur Zertifikate Ihrer eigenen Zertifizierungsstellen zuzulassen, nennen Sie diese als Vertrauensanker: ein Zertifikat oder mehrere in einer PEM-Datei, von denen eines genügt.

```
alcifra certificates policy set --trust-anchors our-authorities.pem
alcifra certificates policy set --trust-anchors none   # any authority again
```

**Die Regel wird beim Hinterlegen eines Zertifikats angewendet, nie rückwirkend.** Das Einschalten lehnt nichts bereits Hinterlegtes ab, markiert nichts und prüft nichts erneut; ein Zertifikat, das hinterlegt wurde, während sie ausgeschaltet war, adressiert seine Inhaberin oder seinen Inhaber weiter, bis es widerrufen wird. Eine Organisation, die ihre eigene Zertifikatsrichtlinie gespeichert hat, bevor dies zur Voreinstellung wurde, behält, was sie gespeichert hat, und das lautete **aus**: `alcifra certificates policy show` sagt, was gilt, und `set … on` übernimmt die Voreinstellung.

## 15.12 Ihr Schlüssel öffnet keine neuen Dokumente mehr: hinterlegen Sie ihn erneut

Als Ihre Organisation begann, bestätigte Schlüssel zu verlangen, wurde ein Zertifikat, das Sie **vorher** — ohne die Bestätigung des Schlüssels — hinterlegt hatten, nicht mehr adressiert: Dokumente, die Sie vorher öffnen konnten, öffnen sich weiterhin, aber nichts **Neues** wird für diesen Schlüssel versiegelt. Der Hinterlegungsdialog zeigt es als **Nicht bestätigt: nichts Neues wird dafür versiegelt. Registrieren Sie ihn erneut vom Token.** Sie brauchen keinen neuen Schlüssel:

1. Stecken Sie das Token ein und öffnen Sie den **Desktop-Client**.
2. Öffnen Sie im Kontomenü **Zertifikat hinterlegen…**.
3. Wählen Sie **Karte oder Token hinzufügen…**, wählen Sie das zuvor hinterlegte Zertifikat und bestätigen Sie. Der Dialog meldet, dass die Bestätigung des Schlüssels vom Token gelesen wurde.
4. **Hinterlegen**. Die Liste unter dem Formular zeigt das Zertifikat nun als **bestätigt durch** den Hersteller Ihres Tokens, mit der Seriennummer des Tokens, und neue Dokumente werden wieder dafür versiegelt.

Dafür braucht es keine Administration, wo Ihre Organisation Sie Ihre eigenen Zertifikate hinterlegen lässt; wo nicht, erledigt eine Administratorin oder ein Administrator dasselbe für Sie mit `alcifra certificates enrol … --attestation …`.

**Sagt der Dialog, das Token biete für den Schlüssel keine Bestätigung an,** wurde der Schlüssel höchstwahrscheinlich auf das Token **importiert** statt auf ihm erzeugt — und ein Token bestätigt nur Schlüssel, die es selbst erzeugt hat. Dieser Schlüssel kann nie bestätigt werden. Die Administration lässt dann einen neuen Schlüssel **auf** dem Token erzeugen und ein Zertifikat dafür ausstellen (Schritt für Schritt oben, ab Schritt 2), und Sie hinterlegen dieses. Fragen Sie nach, bevor etwas gelöscht wird: Der alte Schlüssel öffnet weiterhin jedes Dokument, das für ihn versiegelt wurde.

## 15.13 Wenn das Zertifikat abläuft, und einen Schlüssel ersetzen

**Der Schlüssel läuft nicht ab; das Zertifikat schon.** Gültigkeitsdaten sind eine Eigenschaft des Zertifikats, und der private Schlüssel auf der Karte überdauert sie — er entschlüsselt weiterhin alles, was je an ihn adressiert wurde.

**Der Ablauf wird geprüft, wenn ein Zertifikat REGISTRIERT wird, und danach nie wieder.** Beide Wege lehnen ein bereits abgelaufenes ab: Die eigene Registrierung des Archivs antwortet `it expired <date>`, und ebenso das Hinterlegen im Encryption Module. Danach prüft es nichts mehr. Inhalte werden weiterhin daran adressiert, die Karte öffnet sie weiterhin, und es erscheint keine Warnung — und das ist Absicht, keine Auslassung, denn die Alternative ist schlimmer: Wer seine Verlängerung eine Woche zu spät erhält, würde gar nichts mehr empfangen, während der Schlüssel, der die bestehenden Dokumente öffnet, noch in der Tasche steckt.

> **Ein abgelaufenes Zertifikat ist also ein VERBORGENES Problem, kein unmittelbares.** Alles funktioniert bis zu dem Tag, an dem es erneut registriert werden muss — eine neue Installation, eine nach einem Zurücksetzen neu ausgegebene Karte, dieselbe Person in einem zweiten Archiv —, und erst dann wird es abgelehnt. Die Lösung ist zu diesem Zeitpunkt ein neues Zertifikat, und kommt damit ein neuer **Schlüssel**, öffnet sich kein Dokument mehr, das an den alten adressiert war. Verlängern Sie vor diesem Tag, nicht danach.

### 15.13.1 Einen Schlüssel ersetzen, ohne die Vergangenheit zu verlieren

Inhalte werden an ein **Zertifikat** adressiert, also kann das Archiv die Vergangenheit nicht für Sie neu adressieren — dafür bräuchte es den Klartext, den es bewusst nie aufbewahrt. Überschreiben Sie Slot 9D mit einem frischen Schlüssel, wird alles unlesbar, was für den alten in einen Umschlag gepackt wurde, und es gibt kein Zurück.

**Ein PIV-Slot enthält genau einen Schlüssel und ein Zertifikat**, also kann 9D nicht den alten und den neuen zugleich halten. Was ein YubiKey hinzufügt, sind **zwanzig ausgemusterte Key-Management-Slots** (retired) — `82` bis `95` —, genau für diesen Zweck gedacht: Der alte Schlüssel wird beiseitegelegt, statt zerstört zu werden.

> **Das Archiv braucht dafür keine Konfiguration, und es muss nichts ein zweites Mal registriert werden.** Der Desktop-Client zählt **jedes** Zertifikat auf dem Token auf, statt in einem bestimmten Slot nachzusehen, und ein Umschlag nennt das Zertifikat, für das er versiegelt wurde — ein alter Schlüssel in einem ausgemusterten Slot wird also automatisch gefunden und verwendet, wenn ein altes Dokument geöffnet wird. Neue Dokumente gehen an das neue Zertifikat, alte öffnen sich weiterhin, und wer liest, merkt keinen Unterschied.

**Zwei praktische Vorsichtsmassnahmen.** `ykman piv keys move` gibt es, aber ob sich ein Schlüssel zwischen Slots verschieben lässt, hängt von der Firmware der Karte ab — probieren Sie es an einer Ersatzkarte aus, bevor Sie sich darauf verlassen, statt die Grenze an der Karte zu entdecken, die die einzige Kopie eines Schlüssels hält. Und eine Karte hat zwanzig ausgemusterte Slots, keine unbegrenzte Zahl: Sie bieten Platz für die Schlüsselwechsel eines Berufslebens, nicht für das Aufbewahren von allem für immer.

## 15.14 Eine gesperrte PIN, ein gesperrter PUK und das Zurücksetzen des Tokens

Die PIV-Anwendung eines Hardware-Schlüssels schützt ihre Schlüssel mit zwei Codes: der **PIN**, die Sie eingeben, um ein versiegeltes Dokument zu öffnen, und dem **PUK**, der nur dazu da ist, die PIN zu entsperren. Beide erlauben standardmässig drei Fehlversuche.

1. **Die PIN ist gesperrt** nach dem letzten Fehlversuch. Es geht nichts verloren: Mit dem PUK setzen Sie eine neue (`ykman piv access unblock-pin` im Verwaltungswerkzeug dieses Beispiels, zuerst der PUK, dann die neue PIN).
2. **Auch der PUK ist gesperrt.** Jetzt bleibt nur ein **Zurücksetzen der PIV-Anwendung** (`ykman piv reset`). Das Token erlaubt es nur, solange PIN und PUK beide gesperrt sind, und es **löscht jeden PIV-Schlüssel und jedes PIV-Zertifikat darauf** und stellt PIN, PUK und Management Key auf die Werkseinstellungen zurück. Das Token wird nicht beschädigt, und die Bestätigung seines Herstellers bleibt erhalten, sodass ein danach darauf erzeugter Schlüssel wieder bestätigt werden kann (siehe Abschnitt 15.10).
3. **Die anderen Anwendungen des Tokens sind davon getrennt.** Passkeys, Einmalpasswörter und andere haben ihre eigenen PINs und ihr eigenes Zurücksetzen; ein PIV-Zurücksetzen berührt sie nicht, und ihres berührt PIV nicht.

> **Was ein Zurücksetzen in diesem Archiv kostet: Der Schlüssel in Slot 9D ist endgültig weg.** Ein danach erzeugter Schlüssel ist ein **anderer** Schlüssel, also kann alles, was nur für den alten versiegelt war — Dokumente, Passworteinträge, Unterhaltungsschlüssel —, von niemandem mehr geöffnet werden. Das Archiv kann nicht helfen, weil es den Klartext nie besitzt. Der einzige Schutz ist ein **zweiter hinterlegter Schlüssel**: Alles wird für **alle** hinter-

> legten Schlüssel einer Person versiegelt, also öffnet ein Ersatzschlüssel weiterhin, was der zurückgesetzte öffnen konnte. Hinterlegen Sie ihn, **bevor** Sie ihn brauchen.

**Nach einem Zurücksetzen** erzeugen Sie einen neuen Schlüssel auf dem Token, lassen sein Zertifikat ausstellen und hinterlegen es mit seiner Bestätigung (Abschnitt 15.8); dann entfernen Sie das alte Zertifikat. Sein Widerruf markiert jeden Passworteintrag, den dieser Schlüssel lesen konnte, als *Offengelegt seit…* — mehr Vorsicht, als ein Zurücksetzen braucht, da der Schlüssel zerstört und nicht gestohlen wurde, aber unschädlich: Der Speicher verlangt ein erneutes Versiegeln, und das Ändern dieser Passwörter entfernt die Markierung. Bewahren Sie den PUK dort auf, wo Sie einen Ersatz-Hausschlüssel aufbewahren würden; er ist der einzige Weg zurück aus einer gesperrten PIN, der nicht den Schlüssel kostet.

## 15.15 Was eine Karte abdeckt, und was nicht

Die Zertifikate, die Sie hinterlegen, werden für **zwei** verschiedene Dinge verwendet: Das Archiv packt Dokumentinhalte für sie in Umschläge, und es packt die E-Mails, die ein Gerät abholt, für sie in Umschläge, wo bei diesem Gerät **E-Mail-Inhalt verschlüsseln** eingeschaltet ist (siehe Abschnitt 6.2). Diese werden von unterschiedlicher Software gelesen, und ein Schlüssel auf einer Karte ändert, was sie lesen kann.

- **Der Desktop-Client öffnet Inhalte, deren Schlüssel auf einer Karte liegt.** Das ist es, was Abschnitt 15 vorbereitet, und es ist der Fall, den dieses Handbuch von Anfang bis Ende beschreibt.
- **Ihr E-Mail-Programm ist eine eigene Frage.** Es kann an eine Karte adressierte E-Mails nur öffnen, wenn es selbst ein Hardware-Token für S/MIME verwenden kann. Manche Desktop-E-Mail-Programme können das, über die Smartcard-Funktionen ihres Betriebssystems; ob Ihres es kann, ist eine Frage für seine Dokumentation, nicht für dieses Handbuch.
- **Auf einem iPhone oder iPad kann es das nicht.** Mail liest S/MIME dort mit einer auf dem Gerät installierten Identität, und es gibt keinen Weg, wie eine E-Mail-App eine Karte verwenden könnte — weder über NFC noch anders. Ein Zertifikat auf einer Karte lässt E-Mails auf diesen Geräten deshalb unlesbar, auch während sich Dokumente auf dem Desktop ganz normal öffnen.

> **Wählen Sie also Gerät für Gerät danach, was Sie lesen müssen.** Ob E-Mails versiegelt werden, ist die Einstellung jedes Geräts (Abschnitt 8.2): Lassen Sie **E-Mail-Inhalt verschlüsseln** auf einem Telefon aus, dessen E-Mail-App die Karte nicht verwenden kann, und schalten Sie es für ein Desktop-E-Mail-Programm ein, das es kann. Dokumente werden so oder so an die Karte versiegelt. Wo Ihre Organisation alle E-Mails versiegelt, werden die E-Mails jedes Geräts versiegelt, und nur Programme, die die Karte verwenden können, lesen sie.

## 15.16 Wenn zwei Zertifikate pro Person nicht genügen

Ohne das Encryption Module hinterlegt eine Person bis zu **zwei** Zertifikate, jedes neben dem anderen adressiert, sodass sich dasselbe Dokument mit jedem der beiden Schlüssel öffnet — etwa eine Karte auf dem Schreibtisch und ein mitgeführter Sicherheitsschlüssel. Beide sind Hardware-Schlüssel unter denselben Bestätigungsregeln (Abschnitt 15.10).

Mehr Zertifikate pro Person und das **Hinterlegen** für mehr Personen, als eine Administratorin oder ein Administrator von Hand vorbereiten möchte, gehören zum separaten **Encryption Module**, das in Abschnitt 14.2 beschrieben ist. Brauchen Sie eines davon, wenden Sie sich an den Support und fragen Sie danach; es ist eine kostenpflichtige Erweiterung. Nichts in diesem Anhang ist vergeblich, wenn Sie diesen Weg gehen — die Karte wird gleich vorbereitet, und Abschnitt 15.8 bleibt der Schritt, der sie hinterlegt.

## 15.17 Wenn etwas nicht stimmt

- **Der Dialog sagt, es sei keine Smartcard-Software gefunden worden.** OpenSC ist nicht installiert oder liegt an einem ungewöhnlichen Ort — verwenden Sie **Modul auswählen…** und zeigen Sie darauf.
- **Er sagt, es befinde sich keine Karte und kein Token in einem Lesegerät,** obwohl die Karte offensichtlich im Lesegerät steckt. Entfernen Sie sie und stecken Sie sie wieder ein (siehe Schritt 4), und prüfen Sie, dass nichts anderes auf dem Rechner gleichzeitig mit der Karte spricht.
- **Das eigene Werkzeug der Karte meldet den privaten Schlüssel als `EMPTY`.** Auf Firmware älter als 5.3 lässt sich die Karte nicht fragen, was ein Slot enthält, also gibt das Werkzeug das aus, ob ein Schlüssel vorhanden ist oder nicht. Es ist kein Beweis. Klären Sie es, indem Sie den Schlüssel verwenden, statt eine Zusammenfassung zu lesen.

# 16 Anhang — Glossar & Links

**Archiv** — ein Stammordner (ein Dokument ohne übergeordnetes Element). **Maske** — ein Dokumenttyp / ein Satz von Indexfeldern. **ACL** — die Zugriffssteuerungsliste eines Dokuments. **Version** — eine unveränderliche Momentaufnahme der Datei eines Dokuments. **Rechtliche Sperre** — ein Einfrieren, das Änderung und Löschung verhindert. **Aufbewahrung** — eine Richtlinie, die Dokumente nach einer Frist entsorgt. **vCard** / **iCalendar** — die Standard-Dateiformate, in denen ein Kontakt und ein Kalendereintrag gespeichert werden (`.vcf` / `.ics`). **CardDAV** / **CalDAV** — die Standards, mit denen ein Telefon oder Mailprogramm Adressbücher und Kalender synchronisiert. **UID** — die Kennung, an der diese Programme ein Element geräteübergreifend wiedererkennen; wer sie ändert, erzeugt ein Duplikat statt einer Änderung. **SLA** — die Prüffrist, die ein Dokumenttyp festlegt; sie gibt einer Aufgabe ihr Fälligkeitsdatum.

Weiterführende Informationen:

- Die aktuelle API-Beschreibung — das OpenAPI-Dokument unter `/openapi/v1.json`.
- Downloads des Desktop-Clients — der Download-Bereich unter `/download`.

Die Bildschirmfotos dieses Handbuchs werden bei jeder Veröffentlichung aus der laufenden Anwendung neu erzeugt und veralten deshalb nie.

# 17 Anhang: das Protokoll des Desktop-Clients

Wenn sich der Desktop-Client merkwürdig verhält — eine Vorschau bleibt leer, ein Server lässt sich nicht verbinden, eine Datei öffnet sich nicht —, steht der Grund meist in seinem Protokoll. Der Client schreibt pro Tag eine fortlaufende Protokolldatei, immer mit voller Detailtiefe; es gibt also nichts, was nachträglich eingeschaltet werden müsste: Was gerade schiefgegangen ist, ist bereits aufgezeichnet.

**Wo Sie es finden.** Am einfachsten in der App selbst: **Hilfe ▸ Protokollordner anzeigen** öffnet den Ordner direkt. Der Speicherort je nach Betriebssystem:

- Windows — `%APPDATA%\Alcifra\logs`
- macOS — `~/Library/Application Support/Alcifra/logs`
- Linux — `~/.config/Alcifra/logs`

Die Dateien heissen `simplarchive-YYYYMMDD.log`; die neueste ist die von heute. Das Protokoll ist bewusst klein (es wechselt bei 4 MB die Datei und behält sieben Dateien) und enthält nie ein Passwort oder ein Token; Sie können es deshalb unverändert einer Supportanfrage beilegen.

**Live mitverfolgen.** Starten Sie den Client aus einem Terminal mit dem Schalter `--verbose`, dann wird dieselbe volle Detailtiefe laufend im Terminal ausgegeben — nützlich, wenn Sie ein Problem Schritt für Schritt nachstellen:

- Windows — `Alcifra.DesktopClient.exe --verbose`
- macOS — `Alcifra.app/Contents/MacOS/Alcifra.DesktopClient --verbose`
- Linux — `./Alcifra.DesktopClient --verbose`

Ohne den Schalter zeigt ein Terminal nur die wichtigen Zeilen; die Datei enthält immer alles, mit oder ohne Schalter.

# 18 Anhang — wer was tut

Eine kurze Übersicht darüber, was jede Art von Beteiligten tun kann, für Leserinnen und Leser, die die Gestalt des Systems vor seinen Einzelheiten brauchen: wer es bewertet, wer als Administrator eine Einführung plant, oder wer entscheiden möchte, welches Kapitel dieses Handbuchs er tatsächlich braucht. Alles hier ist in den vorangehenden Kapiteln ausführlich beschrieben; dies ist die Karte, nicht das Gelände.

**Die Rechte aller gelten pro Dokument.** Keine der folgenden Listen hebt das auf. Was eine Person mit einem bestimmten Dokument tun darf, ergibt sich aus den Berechtigungen dieses Dokuments (und den Gruppen, denen sie angehört), vererbt den Baum hinunter, sofern ein Ordner die Vererbung nicht unterbricht. Eine Aktion, die in der Oberfläche fehlt, ist meist keine fehlende Funktion — es ist der Server, der sie hier, Ihnen, jetzt nicht anbietet.

## 18.1 Die alltägliche Benutzerin, der alltägliche Benutzer

| | |
|---|---|
| **Finden und lesen** | Den Baum durchsuchen, einen Ordner öffnen, ein Dokument ohne Herunterladen in der Vorschau ansehen, nach Inhalt oder Indexdaten suchen, zu einem Suchtreffer innerhalb der Seite springen und Referenzen zu allen anderen Stellen folgen, an denen ein Dokument abgelegt ist. |
| **Hinzufügen und ändern** | Per Ziehen oder über das Menüband hochladen, einem bestehenden Dokument eine neue **Version** hinzufügen, Arbeit im **Eingangskorb** bereithalten, bis sie abgelegt werden kann, ein Dokument **auschecken** und wieder **einchecken** sowie Indexdaten bearbeiten. |
| **Ordnen** | Ordner anlegen, Dokumente verschieben, eine **Referenz** setzen, damit ein Dokument in einem zweiten Ordner erscheint, verschlagworten und mit einem **Dokumenttyp** (Maske) klassifizieren. |
| **Zusammenarbeiten** | Im Chat eines Dokuments kommentieren und Kolleginnen und Kollegen erwähnen, eine Seite annotieren, ein Dokument abonnieren, um über Änderungen informiert zu werden, eine Erinnerung setzen und die Aufgaben erledigen, die ein Workflow Ihnen zuweist. |
| **Teilen** | Einen **externen Link** für jemanden ohne Konto erstellen — zeitlich und im Zugriff begrenzt — und ihn widerrufen. |
| **Anderswo arbeiten** | Das Archiv im Dateimanager des Betriebssystems einbinden, Kontakte und Kalender mit einem Telefon synchronisieren, die Mailordner des Archivs in einem Mailprogramm lesen und ein Dokument aus dem Desktop-Client in seiner nativen Desktop-Anwendung öffnen. |
| **Das eigene Konto** | Sprache und Darstellung, Profilfoto, Passwort, Zwei-Faktor-Authentifizierung und Passkeys sowie die separaten app-spezifischen Passwörter, die ihre Geräte verwenden. |

## 18.2 Die Mandantenadministration

Alles oben Genannte, dazu die Einstellungen, die die eigene Organisation steuern. Eine Mandantenadministratorin, ein Mandantenadministrator erreicht jedes Dokument des eigenen Mandanten: Diese Umgehung ist gewollt, und was sie damit **tun**, wird wie alles andere protokolliert.

| | |
|---|---|
| **Personen** | Benutzer anlegen und deaktivieren, Gruppen bilden, die Systemrechte vergeben, mit denen jemand Benutzer verwalten, das Audit-Protokoll einsehen, importieren oder Akten verwalten darf — und **Servicekonten** für Integrationen ausstellen. |
| **Dokumenttypen** | Masken und ihre Indexfelder definieren, festlegen, in welchen Ordnern sie liegen dürfen, was sie enthalten dürfen, ihre Aufbewahrungsfrist und ihre Standard-Vertraulichkeitsstufe. |
| **Akten** | **Rechtliche Sperren** setzen und aufheben, Dokumente am Ende ihrer Aufbewahrungsfrist prüfen, bevor sie entsorgt werden, und endgültig löschen, wenn das die Entscheidung ist. |
| **Aufsicht** | Das **Audit-Protokoll** lesen, filtern, exportieren und prüfen und es über einen signierten Webhook an ein SIEM streamen. |
| **Richtlinien** | Mehrfaktor-Authentifizierung für alle verlangen, den Speicherplatz begrenzen, externe Links erlauben oder verbieten und ihre Lebensdauer beschränken, Schlagwörter auf einen Katalog einschränken und die Standardwerte für Aufbewahrung und Auschecken festlegen. |

## 18.3 Die Plattformadministration

Betreibt die **Installation**, nicht eine einzelne Organisation darin. Sie legt Mandanten an, sperrt sie und richtet die erste Administratorin, den ersten Administrator jedes Mandanten ein. Sie gehört bewusst keinem Mandanten an und sieht deshalb keine Dokumente; genau diese Trennung ist der Zweck, und sie ist der Grund, warum die Plattformadministration nicht unbemerkt das Archiv einer Kundin oder eines Kunden lesen kann.

## 18.4 Das Servicekonto

Eine Maschinenidentität für eine Integration — einen Scanner, ein Fachsystem, ein Skript. Es meldet sich mit einer Client-ID und einem Geheimnis statt mit einem Passwort an, hat genau die Rechte, die ihm gewährt wurden (und nie mehr, als die Person hatte, die sie gewährt hat), und erscheint im Audit-Protokoll unter seinem eigenen Namen. Es ist der vorgesehene Weg, Dokumente automatisch einzuliefern, und der Grund, warum niemand die Anmeldedaten eines Menschen mit einem Roboter teilen muss.

## 18.5 Die Empfängerin, der Empfänger eines externen Links

Jemand ganz ohne Konto, der eine URL in der Hand hat. Er kann das eine Dokument öffnen, das sie nennt — und kein anderes —, bis der Link abläuft oder seine erlaubte Anzahl Aufrufe aufgebraucht ist. Nichts sonst im Archiv ist von dort aus erreichbar, und der Link lässt sich in dem Moment widerrufen, in dem sich zeigt, dass er nicht hätte verschickt werden sollen.

## 18.6 Programme, nicht Personen

| | |
|---|---|
| **Ein Dateimanager** | Bindet das Archiv über WebDAV ein und zeigt genau den Baum, den auch der Arbeitsbereich zeigt. Öffnen, Bearbeiten und Speichern einer Datei funktionieren wie auf einem Netzlaufwerk. |
| **Ein Telefon oder ein Kalenderprogramm** | Synchronisiert Kontakte und Kalender über CardDAV und CalDAV. Was es ändert, behält das Archiv — und versioniert es. |
| **Ein Mailprogramm** | Liest die Mailordner des Archivs über IMAP und kann eine Nachricht im Archiv ablegen, indem es sie dorthin kopiert. |
| **Ein Mailserver** | Stellt Mail direkt in den Eingangskorb einer Benutzerin, eines Benutzers zu, sodass sich etwas allein dadurch ablegen lässt, dass man an eine Adresse schreibt. |

> Alle vier verwenden **ein Passwort pro Gerät**, ausgestellt über **Geräte…** im Kontomenü und einzeln widerrufbar — nie das Passwort, mit dem Sie sich anmelden. Ein verlorenes Telefon kostet einen Widerruf, keinen Passwortwechsel.

# 19 Anhang — wie Alcifra aufgebaut ist

Das Vokabular, in dem das System tatsächlich denkt. Zehn Minuten wert, wenn Sie es bewerten, es anbinden oder sich fragen, warum sich etwas so verhält, wie es sich verhält — mehrere Antworten in diesem Handbuch sind Folgen der unten beschriebenen Gestalt, nicht eines bestimmten Bildschirms.

## 19.1 Das Dokument ist das Rückgrat

Fast alles ist ein **Dokument**. Ein Dokument hat einen Namen, einen Platz im Baum, eigene Berechtigungen und — meistens — Inhalt.

| | |
|---|---|
| **Ein Ordner** | Ein Dokument ohne Inhalt. Das ist der ganze Unterschied: Ordner sind keine eigene Gattung, deshalb hat ein Ordner Indexdaten, Berechtigungen, einen Chatverlauf und eine Historie wie alles andere. |
| **Ein Archiv** | Ein Dokument ohne übergeordnetes Element — eine Wurzel. Wiederum keine eigene Gattung, deshalb erreichen dieselben Berechtigungsregeln die Spitze des Baums ohne Sonderfall. |
| **Ihr eigener Bereich** | Ein Archiv, das einer Person gehört, für sie eingerichtet, mit ihrem **Eingangskorb** und ihren ausgecheckten Dokumenten. Deshalb hat jede Benutzerin, jeder Benutzer einen Ort, an dem etwas liegen kann, bevor entschieden ist, wohin es gehört. |

## 19.2 Inhalt lebt in Versionen

Die Datei eines Dokuments ist eine **Version**, und Versionen sind unveränderlich. Erneutes Hochladen fügt eine neue hinzu; die alte bleibt lesbar. Das macht «eine alte Version wiederherstellen» ehrlich — nichts wird überschrieben, also muss nichts gerettet werden.

> **Metadaten gehören zum Dokument, Inhalt gehört zur Version.** Benennen Sie ein Dokument um, klassifizieren Sie es neu oder bearbeiten Sie seine Indexdaten, bleibt die Historie unberührt; laden Sie eine neue Datei hoch, werden die Metadaten übernommen. Diese Trennung ist der Grund, warum ein Dokument beim Umlegen nie seine Historie verliert und warum sich eine Version wiederherstellen lässt, ohne etwas zu kopieren.

## 19.3 Dokumenttypen und Indexdaten

Eine **Maske** ist ein Dokumenttyp: ein benannter Satz von **Indexfeldern** mit ihren Typen, Prüfungen und Standardwerten. Wer einem Dokument eine Maske zuweist, legt fest, was darüber erfasst werden darf, und — über die Maske — wo es liegen darf und was es enthalten darf.

Masken sind **versioniert und unveränderlich**. Eine Änderung veröffentlicht eine neue Version; bereits klassifizierte Dokumente behalten die Version, unter der sie klassifiziert wurden. Die Bedeutung eines Feldes ändert sich deshalb nie rückwirkend; das macht ein zehn Jahre altes Dokument auch nach seinen eigenen Massstäben noch lesbar.

## 19.4 Wer was darf

Berechtigungen sind eine **Zugriffssteuerungsliste pro Dokument** — ein Satz von Rechten, die einem Benutzer, einer Gruppe oder einem Servicekonto gewährt werden. Rechte vererben sich den Baum hinunter, bis ein Ordner die Vererbung unterbricht; ab dort beginnt dieser Teilbaum neu mit dem, was dort gewährt ist.

Zwei Regeln lohnt es sich zu kennen, weil sie Ablehnungen erklären:

- **Niemand kann ein Recht gewähren, das er selbst nicht hat.** Wer einen Ordner verwaltet, kann jemand anderem keinen Zugriff darauf verschaffen, der über den eigenen hinausgeht.
- **Ein deaktivierter Benutzer und ein gesperrter Mandant haben überhaupt keine Rechte**, entschieden vor jeder administrativen Umgehung — deshalb wirkt das Deaktivieren eines Kontos sofort und vollständig, statt dass Berechtigungen einzeln entzogen werden müssten.

## 19.5 Eine Installation, viele Organisationen

Ein **Mandant** ist eine Organisation. Jede Zeile, die zu einem gehört, trägt ihren Mandanten, und die Trennung wird an einer einzigen Stelle durchgesetzt — einem Filter, den der Datenbankkontext auf jede Abfrage anwendet —, statt dass jede Funktion daran denken müsste. Benutzer, Gruppen, Masken, Dokumente, Schlagwörter und Audit-Ereignisse sind alle mandantengebunden; die **Plattformadministration** gehört bewusst keinem Mandanten an.

## 19.6 Was an einem Dokument hängt

| | |
|---|---|
| **Chat, Erwähnungen** | Das Gespräch über ein Dokument und die Systemeinträge, die festhalten, was mit ihm geschehen ist — eine abgelegte Version, eine ältere, die wieder zur aktuellen wurde, ein abgelehnter Anhang. |
| **Annotationen** | Markierungen auf einer Seite, verankert an der Version, auf der sie gezeichnet wurden. |
| **Referenzen** | Dasselbe Dokument in einem zweiten Ordner. Ein Dokument, zwei Orte — keine Kopie, also gibt es nichts, was auseinanderlaufen könnte. |
| **Schlagwörter** | Freie oder auf einen Katalog beschränkte Bezeichnungen, unabhängig vom Baum. |
| **Abonnements, Erinnerungen** | Wer über Änderungen informiert werden will, und wann jemand erinnert werden möchte. |
| **Externe Links** | Zeitlich und in der Anzahl Aufrufe begrenzter Zugriff für jemanden ohne Konto. |

| | |
|---|---|
| **Rechtliche Sperren, Aufbewahrung** | Ein Einfrieren, das Änderung und Löschung verhindert, und eine Richtlinie, die schliesslich entsorgt, was nicht mehr gebraucht wird. Eine Sperre hat immer Vorrang. |
| **Workflow** | Der Zustand, in dem sich ein Dokument befindet, und die Spur der Übergänge, die es dorthin gebracht haben. |
| **Audit-Ereignisse** | Was getan wurde, von wem, woran — per Hash verkettet, sodass eine Lücke oder eine Änderung erkennbar ist. |

## 19.7 Worin das Archiv es speichert

Inhalt geht in den Objektspeicher, nie durch die Anwendung hindurch: Der Browser und der Desktop-Client übertragen die Bytes direkt über eine kurzlebige signierte URL. Metadaten, Berechtigungen und das Audit-Protokoll gehen nach PostgreSQL. Die Volltextsuche ist ein separater Index, der aus dem extrahierten Text aufgebaut wird, und das Archiv funktioniert auch ohne ihn — die Suche weicht dann auf die Metadaten allein aus, statt zu scheitern.

> Nichts davon ist eine Eigenheit des Web-Clients oder des Desktop-Clients. Beide sind Sichten auf dasselbe Modell; deshalb ist ein Dokument, das aus dem Kalender eines Telefons, von einem Mailserver, aus einem Dateimanager oder über den Arbeitsbereich abgelegt wurde, danach dieselbe Art von Ding — und deshalb bedeuten die Berechtigungen darauf in allen vier dasselbe.

# 20 Anhang — Sicherheitslage

Eine Selbstbewertung anhand der **OWASP Top 10 (2021)** und eine Zusammenfassung anhand von **ASVS Level 2**, für alle, die für das, was sie betreiben, Rechenschaft ablegen müssen.

> **Was dies ist und was nicht.** Es ist eine strukturierte Prüfung der Software durch die Leute, die sie geschrieben haben, und wird mit dem Code aktuell gehalten. Es ist **kein** Penetrationstest und keine Zertifizierung durch Dritte, und es sagt nichts über Netzwerk, Datensicherung oder Betriebsabläufe einer bestimmten Installation aus. Die Unterscheidung, die das Projekt auch anderswo festhält, gilt hier ebenso: Das Produkt ist produktive Software; die öffentliche Demonstrationsinstanz ist es nicht und ist auch so dokumentiert.

## 20.1 Der Befund, der zählte

Das nützlichste Ergebnis der Prüfung war keine einzelne Schwachstelle. Es war ein **Muster**: Die vier Lücken, die sie am höchsten einstufte, waren alle **beschlossen, aufgeschrieben und nie gebaut** worden. Antwort-Header, Drosselung von Anmeldeversuchen, ein Schutz für ausgehende Anfragen und eine Inhaltsprüfung beim Hochladen hatten je einen Architekturentscheid, der sie festlegte — in einem Fall mit den genauen vier Kontrollen —, und keine der vier existierte im Code. Nichts war sichtbar kaputt, und genau deshalb überlebten sie: Das Fehlen einer vorbeugenden Kontrolle ist unsichtbar bis zu dem Tag, an dem sie gebraucht wird.

Alle vier sind inzwischen gebaut, jede mit einem eigenen Entscheid, der erklärt, was beschlossen wurde und was dafür in Kauf genommen wird. Die Lehre bleibt: Ein aufgeschriebener Entscheid ist kein umgesetzter Entscheid, und nur ein Test kann die beiden unterscheiden.

## 20.2 OWASP Top 10 (2021)

| | |
|---|---|
| **A01 Fehlerhafte Zugriffskontrolle** | Berechtigungen sind eine Zugriffssteuerungsliste pro Dokument, aufgelöst von einer einzigen Berechnung, durch die jeder Aufruf geht — mit Gruppenauflösung, Vererbung und ausdrücklichen Unterbrechungen. Niemand kann ein Recht gewähren, das er selbst nicht hat. Ein deaktivierter Benutzer oder eine gesperrte Organisation hat überhaupt keine Rechte, entschieden **vor** jeder administrativen Umgehung. Die Mandantentrennung ist ein Abfragefilter, der an einer einzigen Stelle angewendet wird, statt in jeder Funktion daran zu denken, und eine Testreihe stellt sicher, dass ein Mandant die Daten eines anderen nicht erreicht. |
| **A02 Kryptografische Fehler** | Passwörter werden nur als Hashes gespeichert und nie protokolliert. Geheimnisse — Datenbank-Anmeldedaten, Schlüssel für den Objektspeicher, Zertifikate zum Signieren von Tokens — kommen aus einem Geheimnisverwaltungssystem, wenn eines konfiguriert ist; die Datenbank-Anmeldedaten werden bei jedem Start neu ausgestellt, und die Anwendung verwendet nie den Datenbank-Superuser. Ausserhalb der Entwicklung wird ein Geheimnis, das die Anwendung speichern muss — der Startwert für Einmalcodes —, vom Geheimnisverwaltungssystem verschlüsselt, und die Startprüfung verweigert den Betrieb ohne ein solches, statt das Geheimnis im Klartext |

| | |
|---|---|
| | zu speichern. Die Transportsicherheit wird nur gelockert, wenn die Anwendung im **Entwicklungsmodus** läuft: Die Lockerung ist an diesen Modus gebunden, nicht an eine Einstellung, es gibt also keinen Konfigurationsschalter, der sie in einer betriebenen Installation abschaltet. |
| **A03 Injection** | Der Datenzugriff erfolgt ausschliesslich über eine typisierte Abfrageschicht: Die Anwendung enthält **ausserhalb ihrer Schemamigrationen nirgends rohes oder per Zeichenkettenverkettung zusammengesetztes SQL**. Ausgaben in beiden Clients werden vom Framework maskiert, und die Richtlinie für Antwort-Header blockiert Inline-Skript, statt es zuzulassen. XML von aussen wird über eine einzige Hilfsfunktion geparst, die Dokumenttyp-Definitionen verbietet, keine externen Entitäten auflöst und keine expandiert — per Zusicherung, sodass eine geänderte Framework-Voreinstellung daran nichts ändern würde. |
| **A04 Unsicheres Design** | Zunehmende Drosselung des Erratens von Anmeldedaten an jeder Stelle, die solche prüft; eine Inhaltsprüfung beim Hochladen, die ausführbare Dateien und Skripte an ihren Bytes ebenso wie an ihren Namen ablehnt; Speicherkontingente; Verbindungsobergrenzen am Mail-Endpunkt; Begrenzung der Seitengrösse bei jeder Auflistung. Die eigenen Invarianten des Archivs — keine Zyklen im Baum, keine doppelten Namen unter Geschwistern, unveränderliche Dokumenttypen — werden an der einzigen Stelle durchgesetzt, an der Daten gespeichert werden, nicht von jedem Aufrufer. |
| **A05 Sicherheitsrelevante Fehlkonfiguration** | Eine Startprüfung verweigert ausserhalb der Entwicklung den Betrieb, sobald irgendeine Einstellung von Entwicklungsqualität vorhanden ist — Entwicklungszertifikate, Bootstrap-Geheimnisse, Standard-Anmeldedaten für den Speicher, ein ungestempelter Build —, und es gibt **keinen Schalter, um sie zu umgehen**. Antworten tragen eine Content-Security-Policy, Einschränkungen für Frames und Referrer sowie eine Festlegung des Inhaltstyps; jeder Header wird nur gesetzt, wenn er fehlt, sodass eine Installation, die ihre eigene Edge betreibt, die Kontrolle darüber behält. Weitergeleitete Header eines Reverse-Proxys werden nur von den Proxys berücksichtigt, die eine Installation benennt, und die Startprüfung lehnt die Option ab, wenn keiner benannt ist. |
| **A06 Anfällige und veraltete Komponenten** | Jeder Build durchsucht den Abhängigkeitsbaum nach bekannten Schwachstellen und schlägt bei einem Fund fehl; das Container-Image wird separat geprüft; Aktualisierungen von Abhängigkeiten werden jede Woche automatisch vorgeschlagen. Eine Lizenzprüfung lässt den Build zusätzlich bei jeder Abhängigkeit ausserhalb der erlaubten Menge fehlschlagen. |
| **A07 Fehler bei Identifizierung und Authentifizierung** | Standardbasierte Anmeldung mit Proof-Key-Austausch für die interaktiven Clients. Zweite Faktoren werden als zeitba- |

| | |
|---|---|
| | sierte Codes und als Passkeys unterstützt, einschliesslich passwortloser Anmeldung, und eine Organisation kann sie für alle verlangen. Ein gewähltes Passwort muss mindestens zwölf Zeichen lang sein und darf keines der zehntausend häufigsten kompromittierten Passwörter sein oder nur abwandeln. Fehlgeschlagene Versuche werden pro Konto **und** pro Quelle zunehmend abgewiesen, mit Sperren, die von selbst ablaufen, statt eine Administratorin, einen Administrator zu brauchen. Zugriffstokens leben fünfzehn Minuten und Aktualisierungstokens dreissig Tage, und ein widerrufenes Token wird schon bei seiner nächsten Anfrage abgewiesen, nicht erst am Ende seiner Lebensdauer. |
| **A08 Fehler bei Software- und Datenintegrität** | Hochgeladene Inhalte werden vom Server erneut gelesen und gehasht, statt dem Client zu vertrauen. Versionen können im Speicher für eine Aufbewahrungsfrist unveränderlich gesperrt werden. Das Audit-Protokoll ist per Hash verkettet, sodass ein veränderter oder fehlender Eintrag erkennbar ist. Schemamigrationen werden auf datenzerstörende Operationen geprüft, und eine zerstörende muss mit einer Begründung aufgeführt sein, bevor der Build durchgeht. Veröffentlichte Images sind signiert, tragen Build-Herkunftsnachweise und eine Software-Stückliste, und die Versionshinweise beschreiben, wie sich alle drei prüfen lassen. |
| **A09 Fehler bei Sicherheitsprotokollierung und Überwachung** | Änderungen werden in einem nur anfügbaren, per Hash verketteten Protokoll erfasst, mit Aufbewahrungsrichtlinie, einmal beschreibbaren Archivsegmenten, Export und signiertem Streaming an ein SIEM — einschliesslich einer abgewiesenen Anmeldung, einer Abmeldung und einer Kontosperre. Die Abdeckung wird **nicht** als vollständig behauptet: Eine Build-Prüfung schlägt fehl, wenn ein neuer ändernder Endpunkt nichts aufzeichnet, und die Endpunkte, die noch nichts aufzeichnen, sind eine aufgeführte, begründete Restliste statt einer Annahme. Anfragen tragen durchgehend eine Korrelationskennung, und jede externe Schnittstelle lässt sich bei Bedarf in voller Detailtiefe nachverfolgen. Protokolle enthalten nie ein Passwort, ein Token oder eine signierte URL. |
| **A10 Serverseitige Anfragefälschung (SSRF)** | Die beiden Stellen, die eine vom Aufrufer gelieferte URL annehmen — der Audit-Webhook einer Organisation und der Push-Endpunkt eines Clients —, werden bei der Registrierung der URL geprüft **und noch einmal im Moment des Verbindungsaufbaus**, gegen die tatsächlich aufgelöste Adresse, und die Verbindung geht genau zu dieser Adresse, sodass dazwischen nichts umgelenkt werden kann. Weiterleitungen werden abgelehnt. Private Adressbereiche werden abgelehnt, sofern die eigene Konfiguration der Installation sie nicht erlaubt, und die Metadaten-Adressen von Cloud-Anbietern werden in jedem Fall abgelehnt. |

## 20.3 ASVS Level 2 in Kürze

| | |
|---|---|
| **Architektur** | Die Schichtung wird durch Tests erzwungen, nicht durch Konvention; jeder Architekturentscheid ist festgehalten, auch die später rückgängig gemachten. |
| **Authentifizierung** | Standardbasiert, zweite Faktoren unterstützt und erzwingbar, gedrosselt; gewählte Passwörter erfüllen eine Richtlinie zu Länge und Liste kompromittierter Passwörter; fehlgeschlagene und gedrosselte Anmeldungen landen im Audit-Protokoll. |
| **Sitzungsverwaltung** | Vom Server ausgestellte Tokens mit begrenzter Lebensdauer — fünfzehn Minuten für den Zugriff, dreissig Tage für die Aktualisierung. Eine Abmeldung widerruft die Tokens dieses Clients auf dem Server, und jede Anfrage prüft ihr Token gegen den Eintrag des Servers, sodass ein widerrufenes Token sofort nicht mehr funktioniert. Ein Aktualisierungstoken, das ein zweites Mal verwendet wird, gilt als gestohlen: Die ganze Sitzung, zu der es gehört, wird widerrufen, das Zugriffstoken eingeschlossen. |
| **Zugriffskontrolle** | Pro Objekt, standardmässig verweigert und **serverseitig bei jeder Anfrage** ausgewertet — die Clients entscheiden das nie. Sie blenden zusätzlich eine Aktion aus, die der Server nicht angeboten hat, sodass einem Benutzer selten etwas angeboten wird, das abgelehnt würde; aber das Ausblenden ist Höflichkeit, und die Ablehnung ist die Kontrolle. |
| **Validierung & Kodierung** | Typisierter Datenzugriff, vom Framework maskierte Ausgabe, beim Hochladen geprüfter Inhalt und Uploads, die nie durch die Anwendung hindurchgehen. |
| **Protokollierung** | Strukturiert, korreliert, auf Schwärzung bedacht; das Audit-Protokoll ist vom Betriebsprotokoll getrennt und manipulationserkennbar. |
| **Datenschutz** | Inhalte im Objektspeicher nur über kurzlebige signierte URLs erreichbar; Löschen ist ein zweistufiger Vorgang mit Papierkorb, und die Entsorgung ist prüfbar. |
| **Kommunikation** | Transportsicherheit ausserhalb der Entwicklung erzwungen; die Lockerungen des Demonstrationsstapels gelten bauartbedingt nur für die Entwicklung. |
| **Konfiguration** | Prüfung von Abhängigkeiten, Lizenzen, Geheimnissen und Images bei jedem Build; eine Startprüfung, die Entwicklungseinstellungen im Produktivbetrieb ablehnt. |

## 20.4 Was noch offen ist

Einer Bewertung, die nichts Offenes meldet, sollte man misstrauen. Das Folgende wird verfolgt, und es ist kein aus der Ferne ausnutzbarer Fehler in der ausgelieferten Konfiguration. Jeder Punkt nennt die Aufgabe, die ihn verfolgt, und eine wöchentliche Prüfung schlägt fehl, wenn eine dieser Aufgaben geschlossen wird, während ihr Punkt noch hier steht — denn diese Liste hat einmal weiter ein Produkt beschrieben, das sich längst weiterentwickelt hatte, und zwar im einen Kapitel, das man aufschlägt, um herauszufinden, was nicht erledigt ist.

- **Tokens externer Links im gespeicherten Zustand** (#1579) — das Token hinter einem nach aussen geteilten Link wird so gespeichert, wie es ausgestellt wurde; wer es lesen will, braucht also Datenbankzugriff. Es zu hashen, würde die Möglichkeit nehmen, einen bestehenden Link noch einmal anzuzeigen; deshalb ist es eine Entscheidung und keine Fehlerbehebung.

Kürzlich erledigt, und hier aufgeführt, damit ihr Fehlen oben nicht für ein Versäumnis gehalten wird: Ein widerrufenes oder abgemeldetes Token wird bei seiner nächsten Anfrage abgewiesen, und ein zweimal verwendetes Aktualisierungstoken widerruft seine ganze Sitzung; gewählte Passwörter müssen eine Mindestlänge erfüllen und werden gegen eine Liste häufig verwendeter Passwörter geprüft; die Lebensdauer der Tokens ist bewusst festgelegt, statt bei den Framework-Voreinstellungen zu bleiben; eine Produktivinstallation startet nicht ohne Geheimnisverwaltungssystem, sodass Startwerte für zweite Faktoren und die anderen gespeicherten Geheimnisse nie im Klartext liegen; abgewiesene Anmeldungen und Kontosperren sind Audit-Ereignisse; veröffentlichte Images sind signiert und tragen Herkunftsnachweise und eine Stückliste; XML wird mit per Zusicherung abgelehnten externen Entitäten geparst, und ein Test schlägt fehl, wenn ein Parser ohne diese Einstellung hinzukommt; und eine Installation hinter einem Reverse-Proxy muss die Proxys benennen, denen sie vertraut.

## 20.5 Wie das wahr bleibt

Jede der obigen Aussagen wird von etwas gehalten, das bei jeder Änderung läuft: einem Test, einer Prüfung oder beidem. Der Build schlägt fehl bei einer Abhängigkeit mit bekannter Schwachstelle, bei einer Lizenz ausserhalb der erlaubten Menge, bei einem durchgesickerten Geheimnis, bei einer zerstörenden Migration ohne angegebene Begründung und bei einer Compiler-Warnung. Den Rest halten rund zweitausend automatisierte Tests, darunter End-to-End-Testreihen, die die echte Anwendung über HTTP und einen echten Browser bedienen. Nur deshalb kann ein Dokument wie dieses veröffentlicht und nicht bloss geschrieben werden.

# 21 Stichwortverzeichnis

Begriffe sind dort verzeichnet, wo das Handbuch sie erklärt, nicht bei jeder Erwähnung — die angegebene Seite ist die, die sich aufzuschlagen lohnt.


ACL 2
Angebotene Zeit 23
Anmeldesperre 3
Anmerkungen 43
apass 29
Arbeitskopie 45
Archiv (Ablage) 2
Audit-Protokoll 52
Aufbewahrung 51
Aufgaben 51
Aufgabenzähler 51
Ausführbare Inhalte 7
Ausgehende E-Mail 53
Automatisch drehen 10
Automatisch gerade richten (Deskew) 10
Availability 22
Benachrichtigungen 43
Benutzer und Gruppen 52
Besprechungsraum 21
Bestätigung (Attestierung) 67
Bestätigungscode 27
Blockers 22
Browser-Erweiterung 30
Buchung 21
CalDAV 20, 38
CardDAV 20, 38
Chat / Kommentare 43
Chat, nicht versiegelt 57
Check-out 6, 45
CI/CD-Speicher 31
Desktop-Client 1
Dokument öffnen 4
Dokumentenmanagementsystem 1
Drehen/Sortieren 9, 11
E-Mail-Karte 4
Eingangskorb 6, 15
Einträge zusammenfügen 9
Empfängerkreis 28
Encryption Module 57
Encryption Service 57
Erinnerung 43
Externer Link 46
Externer Link (verschlüsselt) 48
Facetten 42
Folgen / abonnieren 43
Genehmigungs-Workflow 51
Gerätepasswort 38, 77
Gesetzliche Sperre 51
Hardware-Schlüssel-Test 63
Hochladen 6
IMAP 15, 38
Import / Export 6
In Seiten aufteilen 9
Indexfelder 2
Kalender 17
Klicken zum Kopieren 4
Kontakte 17
Kontaktkarte 4
Kontextmenü 39
Lesezeichen 30
Mandant 52
Maske (Dokumenttyp) 2
Mehrfaktor-Authentifizierung 3
Meine Arbeit 43
Messenger 24
Namenskonflikt 7
Notizen 16
OCR 41
Papierkorb 51
Passwortspeicher 26
Persönliches Archiv 12
Profil bearbeiten 52
Quanten 58
Rechte 2
Schedule 22
Schlagwörter 12
Schlüssel widerrufen 67
Schlüssel, für Sie eingetragen 56
Seiten drehen 9
Seiten sortieren 9
Server-Verwaltung 53
Smartcard 16
Souveräner Arbeitsplatz 1
Speicherkontingent 52
Sperre 22
Suche 42
Tablet 31
Trefferhervorhebung 4
Trennblätter 9
Verschlüsselte Inhalte 54
Verschlüsselung (S/MIME) 16
Version 2
Versionskommentar 8
Vertraulichkeitsstufe 12
Verweis 15
Verweis (Verknüpfung) 12
Verweisfeld 41
Vorschau 3
Web-Client 1
WebDAV 13, 38
WebDAV-Direktlink 13
Wortteilsuche 42
Zertifikat hinterlegen 66
Zertifikatsrichtlinie 68
Zoom 4
Zwei-Faktor-Authentifizierung 52